

TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN



Báo cáo Bài tập HW1

Môn: Kiểm thử phần mềm

Họ tên sinh viên: Lê Mạnh Phú

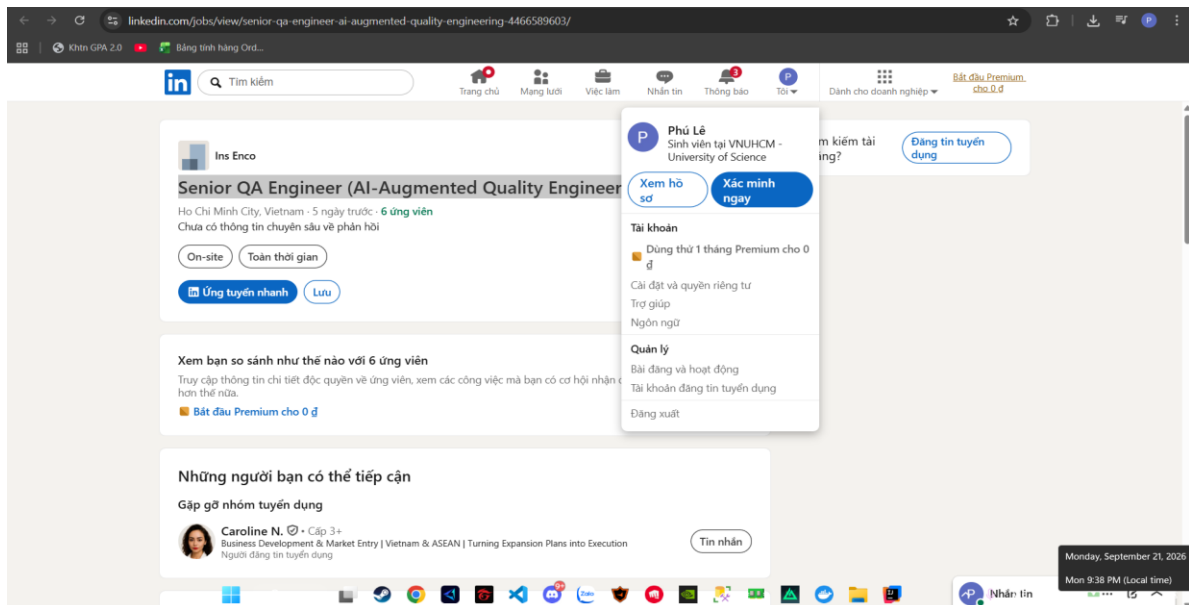
MSSV: 23120325

Gmail: lemanhphu2712@gmail.com

GitHub repo link: <https://github.com/PhuLE2712/hw01-qa-qc>

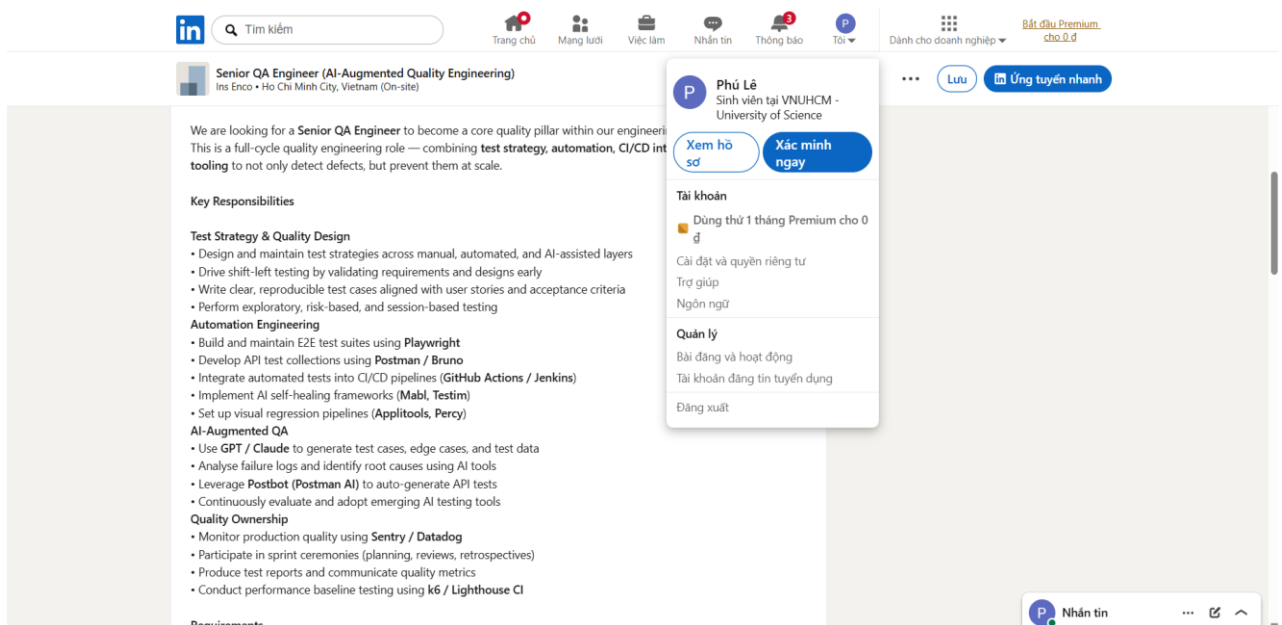
I. Requirement 1 – QA/QC Job Market 2026+

1. Senior QA Engineer (AI-Augmented Quality Engineering)



- Link: <https://www.linkedin.com/jobs/view/senior-qa-engineer-ai-augmented-quality-engineering-4466589603/>

- Job description:



- Required skills:

Senior QA Engineer (AI-Augmented Quality Engineering)
Ins Enco • Ho Chi Minh City, Vietnam (On-site)

Requirements

Must-Have

- 3-6 years of experience in QA / Quality Engineering
- Strong hands-on experience with **Playwright** (E2E automation, CI integration, tracing)
- Solid API testing experience (**Postman / Bruno**, REST & GraphQL)
- Experience with **SQL / database validation**
- Proficiency with **Git and CI/CD pipelines** (GitHub Actions or similar)
- Experience working with **Jira + Xray/Zephyr**
- Strong understanding of Agile development processes

AI-Essential (required for final-stage candidates)

- Hands-on experience using **GPT / Claude** for test generation and analysis
- Familiarity with AI-driven testing tools (**Mabl, Testim**)
- Experience with visual AI testing (**Applitools / Percy**)
- Exposure to **Postbot / AI-generated API testing workflows**

Nice to Have

- Performance testing tools (**k6, Artillery**)
- Security testing (**OWASP ZAP, Snyk**)
- Observability tools (**Sentry, Datadog**)
- ISTQB certification (AI testing module is a plus)

What We Offer

- Salary : 30,000,000-40,000,000 VND gross/ month (depending on experience)
- Performance-based bonuses.
- Flexible, output-driven working environment.
- Access to cutting-edge AI tools + dedicated learning budget.

Location : Ho Chi Minh City – Vinhomes Grand Park, Long Bình, Thủ Đức, TP. HCM.

Phú Lê
Sinh viên tại VNUHCM - University of Science

[Xem hồ sơ](#) [Xác minh ngay](#)

Tài khoản

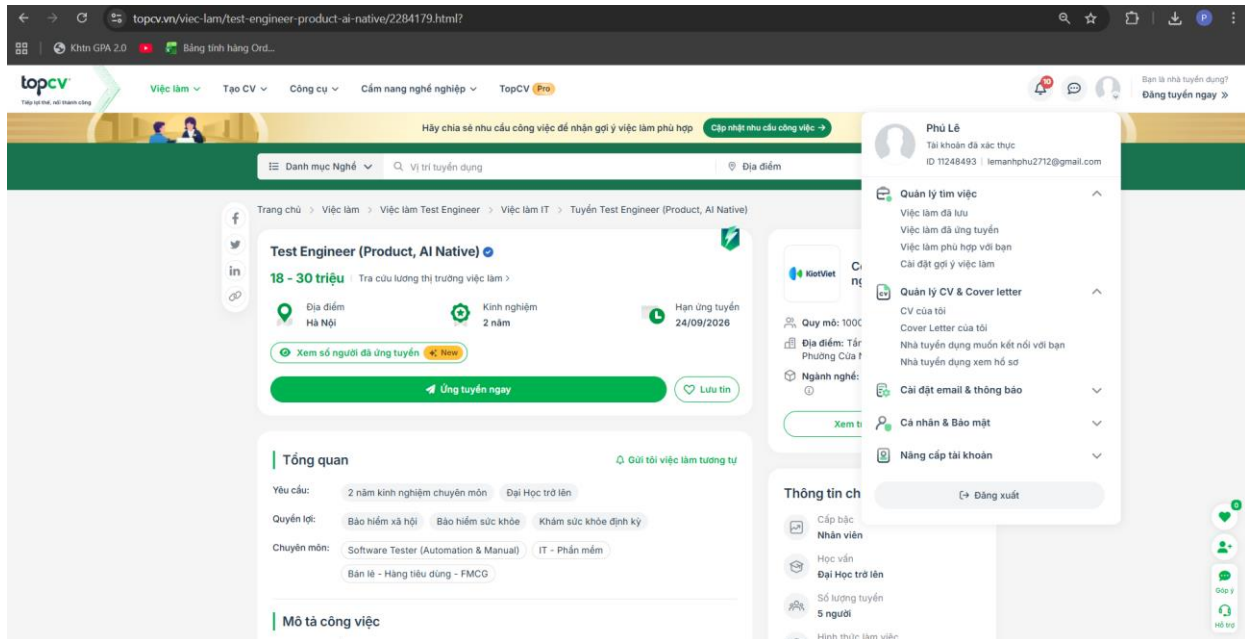
- Dùng thử 1 tháng Premium cho 0 đ
- Cài đặt và quyền riêng tư
- Trợ giúp
- Ngôn ngữ

Quản lý

- Bài đăng và hoạt động
- Tài khoản đăng tin tuyển dụng
- Đăng xuất

- Salary: 30,000,000-40,000,000 VND gross/ month (depending on experience)
- AI Impact Analysis: AI có thể hỗ trợ đáng kể cho vị trí QA này bằng cách tự động tạo test case, test data, phân tích lỗi và hỗ trợ kiểm thử thông qua các công cụ như GPT, Claude, Mabl, Testim và Postbot. Tuy nhiên, kỹ sư QA vẫn cần kiểm tra kết quả do AI tạo ra, xác định các edge case và rủi ro, đồng thời đưa ra quyết định cuối cùng về chất lượng phần mềm.

2. Test Engineer (Product, AI Native)



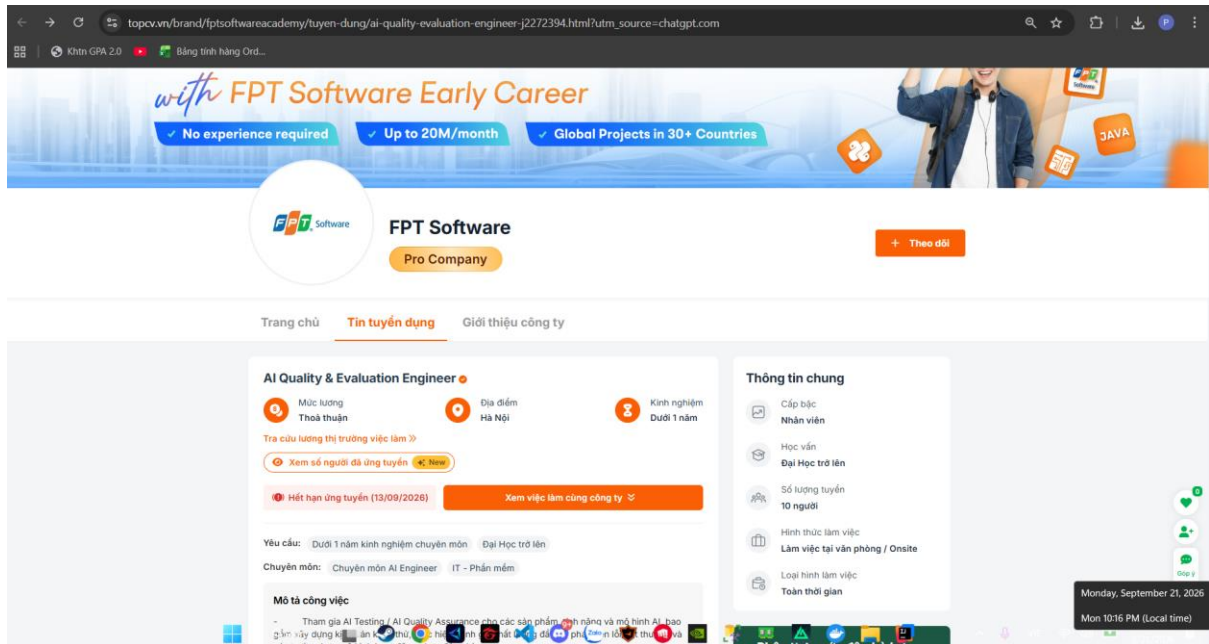
- Link: <https://www.topcv.vn/viec-lam/test-engineer-product-ai-native/2284179.html>

- Job description:

Bạn làm chủ chất lượng của các tính năng/module được giao:

- Phân tích yêu cầu và tài liệu đặc tả (SSOT, Use Case, Business Rule) của sản phẩm phụ trách; phát hiện điểm mơ hồ, thiếu sót hoặc mâu thuẫn nghiệp vụ và trao đổi kịp thời với Dev/PE;
 - Thiết kế kịch bản kiểm thử phủ happy path, alternative path, error path; thực thi kiểm thử thủ công, exploratory và tự động;
 - Viết và maintain script automation cho các tính năng được giao và các bộ regression hiện có;
 - Tiến hành phân tích kết quả kiểm thử và báo cáo lỗi cho nhóm phát triển;
 - Ứng dụng AI vào công việc: sử dụng thành thạo các công cụ AI và được đào tạo sử dụng skill/template có sẵn của nhóm để tăng năng suất (phân tích yêu cầu, sinh test case/kịch bản, sinh dữ liệu test). Đề xuất cải tiến khi thấy điểm chưa hợp lý;
 - Phối hợp chặt chẽ với các nhóm phát triển và quản lý sản phẩm để đảm bảo việc phát triển phần mềm đáp ứng các yêu cầu chất lượng.
- Required skills:

3. AI Quality & Evaluation Engineer



- Link: <https://www.topcv.vn/brand/fptsoftwareacademy/tuyen-dung/ai-quality-evaluation-engineer-j2272394.html>

- Job description:

AI Quality & Evaluation Engineer



Mức lương
Thoả thuận



Địa điểm
Hà Nội



Kinh nghiệm
Dưới 1 năm

[Tra cứu lương thị trường việc làm >>](#)



Xem số người đã ứng tuyển

New

Hết hạn ứng tuyển (13/09/2026)

[Xem việc làm cùng công ty !\[\]\(c444627dab9fee9a1550c053ffaaaae2_img.jpg\)](#)

Yêu cầu: Dưới 1 năm kinh nghiệm chuyên môn Đại Học trở lên

Chuyên môn: Chuyên môn AI Engineer IT - Phần mềm

Mô tả công việc

- Tham gia AI Testing / AI Quality Assurance cho các sản phẩm, tính năng và mô hình AI, bao gồm xây dựng kịch bản kiểm thử, thực hiện đánh giá chất lượng đầu ra, phát hiện lỗi/bất thường và các trường hợp mô hình hoạt động chưa đúng kỳ vọng.
- Hỗ trợ xây dựng dữ liệu, tiêu chí và phương pháp đánh giá chất lượng AI phục vụ cho quá trình kiểm thử, đo lường và cải tiến sản phẩm AI.
- Tham gia kiểm định Harness Validator cho AI Agent và Agentic AI system, bao gồm thiết kế kịch bản đánh giá, chạy thử nghiệm, ghi nhận kết quả và phân tích hành vi của agent; trong đó tập trung kiểm tra các yếu tố như chất lượng RAG retrieval, mức độ phù hợp của context, độ chính xác của tool call, khả năng xử lý lỗi, cơ chế memory và context management.
- Tham gia xây dựng các bộ công cụ/platform hỗ trợ công việc kiểm thử và đánh giá chất lượng AI, bao gồm công cụ tạo dữ liệu kiểm thử, quản lý test case, tự động hóa đánh giá, tổng hợp kết quả và hỗ trợ báo cáo chất lượng.
- Làm việc cùng các kỹ sư AI/Software Engineer để phân tích nguyên nhân và đề xuất hướng cải thiện.
- Tham gia các dự án thực tế và từng bước làm quen với quy trình phát triển sản phẩm AI tại FPT Software.

- Required skills:

Yêu cầu ứng viên

- Là sinh viên đã/sắp tốt nghiệp chuyên ngành Công nghệ thông tin, Toán tin, Khoa học máy tính, Kỹ thuật phần mềm, Điện tử viễn thông, Cơ khí, Cơ điện tử, Tự động hóa... hoặc các chuyên ngành có liên quan.
- Ứng viên có điểm trung bình đạt 3.2/4.0 hoặc 8.0/10 trở lên..
- Tư duy logic tốt, yêu thích AI và Automation.
- Có sự quan tâm hoặc mong muốn phát triển trong lĩnh vực AI Testing, AI Quality / AI Evaluation.
- Có khả năng sử dụng tiếng Anh tốt (tương đương TOEIC 750/IELTS 6.5 trở lên)
- Có thể tham gia đào tạo/làm việc Full-time từ thứ 2 - thứ 6.
- Ham học hỏi, máu lửa, nhiệt huyết, sẵn sàng chinh chiến đối đầu với thử thách khó khăn tại các dự án phần mềm lớn. Tuân thủ kỷ luật & có trách nhiệm với công việc.
- Ưu tiên ứng viên đã học hoặc có kiến thức về Python, Machine Learning, Data Science hoặc AI.

- Salary: trung bình 10 – 15 triệu đồng/ tháng

Quyền lợi được hưởng

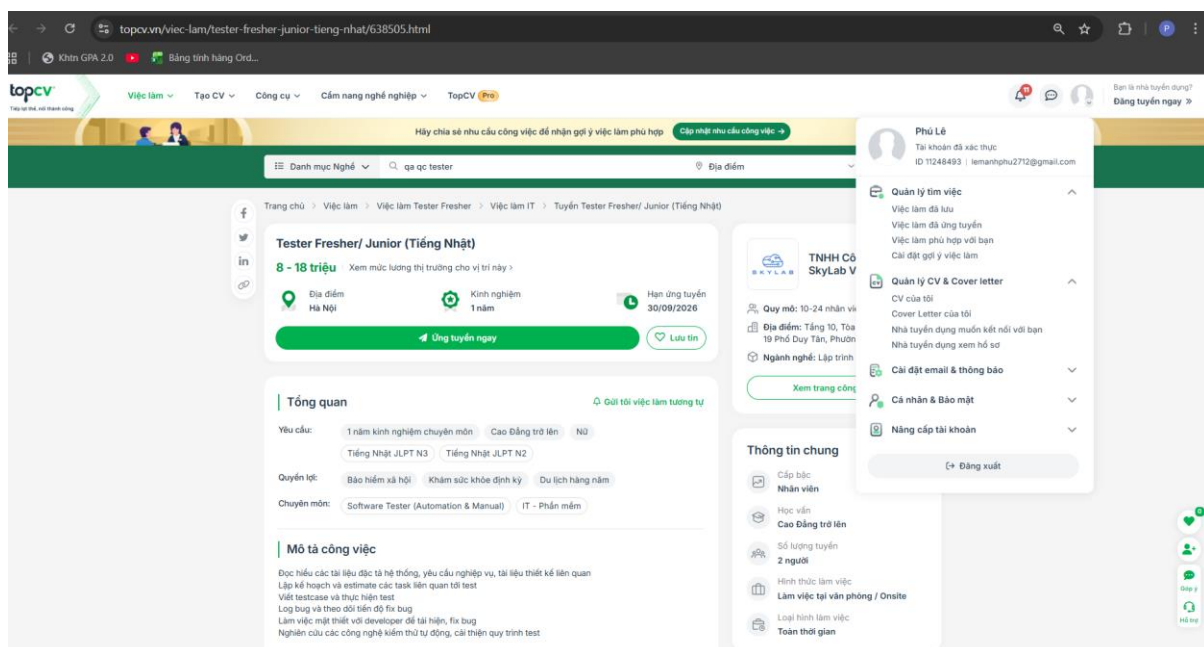
- Được đào tạo bài bản về AI & AI Quality, Được hướng dẫn về AI Testing, AI Evaluation, cách xây dựng tiêu chí đánh giá và kiểm thử chất lượng sản phẩm AI.
- Sau đào tạo: Tham gia làm việc tại các dự án với mức thu nhập hấp dẫn tương xứng với kỹ năng và kinh nghiệm của bạn (trung bình từ 10-15M/tháng), nhận thưởng tham gia dự án và lương tháng 13, tùy theo kết quả đào tạo và làm việc. Hưởng các chính sách như: hỗ trợ mua nhà, bảo hiểm FPT care...
- Cơ hội phát triển bản thân và làm việc cùng các chuyên gia giỏi nhất của FPT Software và khách hàng lớn đến từ Mỹ, Hàn Quốc, Nhật Bản...
- Tiếp cận với những công nghệ tiên tiến hàng đầu về C/C++/Embedded System và Automotive, phát triển kỹ năng mềm & định hướng nghề nghiệp, tư vấn bí quyết thành công từ các chuyên gia.
- Trải nghiệm văn hóa đặc trưng, môi trường làm việc hiện đại bậc nhất Việt Nam tại các Campus của FPT Software.

Địa điểm làm việc (đã được cập nhật theo Danh mục Hành chính mới - thêm quận/huyện cũ tương ứng để dễ dàng tra cứu)

- **Hà Nội:** 10 Phạm Văn Bạch, Phường Cầu Giấy (quận Cầu Giấy cũ)
- **Hà Nội:** KCNC Hòa Lạc, Xã Hòa Lạc (huyện Thạch Thất cũ)

- **AI Impact Analysis:** Vị trí này cho thấy AI đang mở rộng phạm vi của hoạt động QA từ kiểm thử phần mềm truyền thống sang đánh giá hành vi và chất lượng của AI Agent. Người kiểm thử phải xây dựng tiêu chí đánh giá, kiểm tra RAG, tool call, memory và context management, sau đó phân tích kết quả để xác định liệu hệ thống AI có hoạt động đúng kỳ vọng hay không.

4. Tester Fresher/ Junior (Tiếng Nhật)



Link: <https://www.topcv.vn/viec-lam/tester-fresher-junior-tieng-nhat/638505.html>

- Job description:

- + Đọc hiểu các tài liệu đặc tả hệ thống, yêu cầu nghiệp vụ, tài liệu thiết kế liên quan
- + Lập kế hoạch và estimate các task liên quan tới test
- + Viết testcase và thực hiện test
- + Log bug và theo dõi tiến độ fix bug

- + Làm việc mật thiết với developer để tái hiện, fix bug
- + Nghiên cứu các công nghệ kiểm thử tự động, cải thiện quy trình test

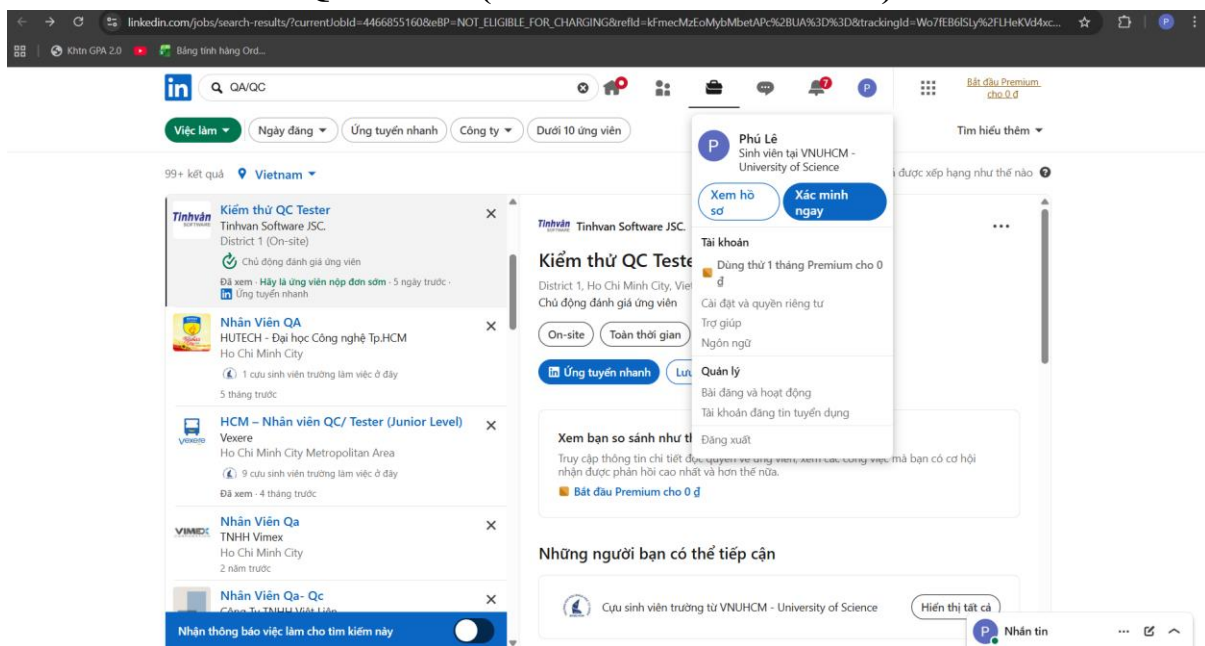
- Required skills:

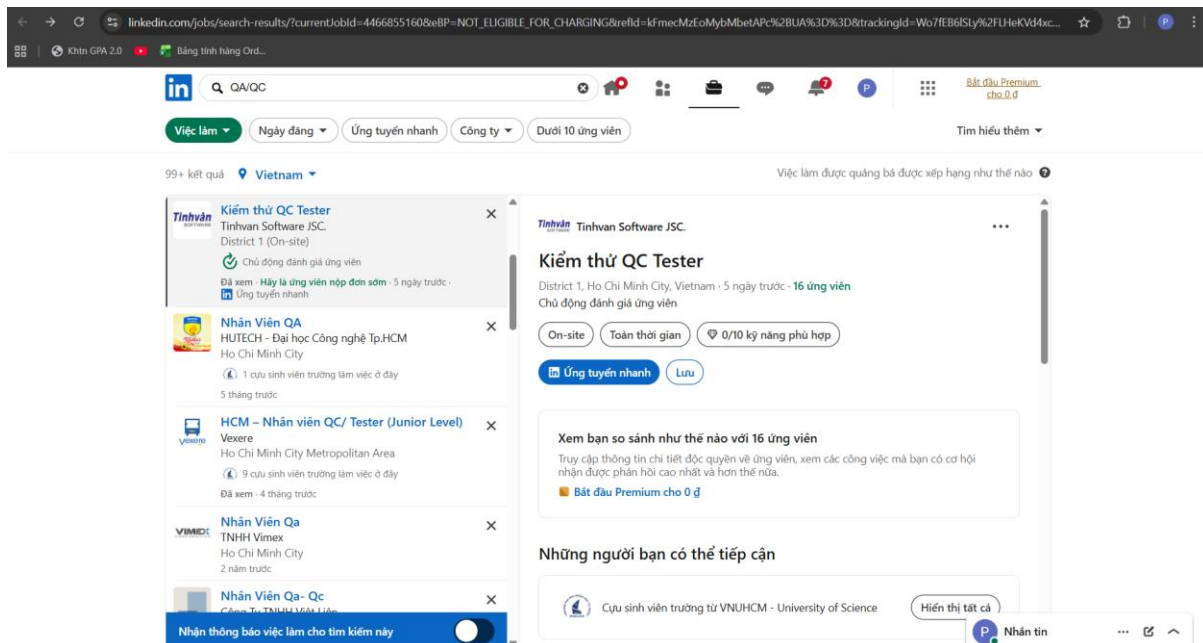
- + Có kinh nghiệm viết test case, thực hiện test
- + Kỹ năng giao tiếp tốt, hoà đồng
- + Tin học văn phòng cơ bản
- + Tiếng Nhật N3 trở lên
- + Kiến thức ngành: IT - Phần mềm
- + Kỹ năng cần có: Manual Tester

- Salary: 8 - 18 triệu đồng

- AI Impact Analysis: AI có thể hỗ trợ tester trong việc phân tích tài liệu đặc tả, đề xuất test case và hỗ trợ xác định các tình huống cần kiểm thử, giúp giảm thời gian chuẩn bị và tăng độ bao phủ của hoạt động testing.

5. Kiểm thử QC Tester (Tinhvan Software JSC.)





Link: https://www.linkedin.com/jobs/search-results/?currentJobId=4466855160&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=kFmecMzEoMybMbetAPc%2BUA%3D%3D&trackingId=Wo7fEB61SLy%2FLHeKVd4xcQ%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE

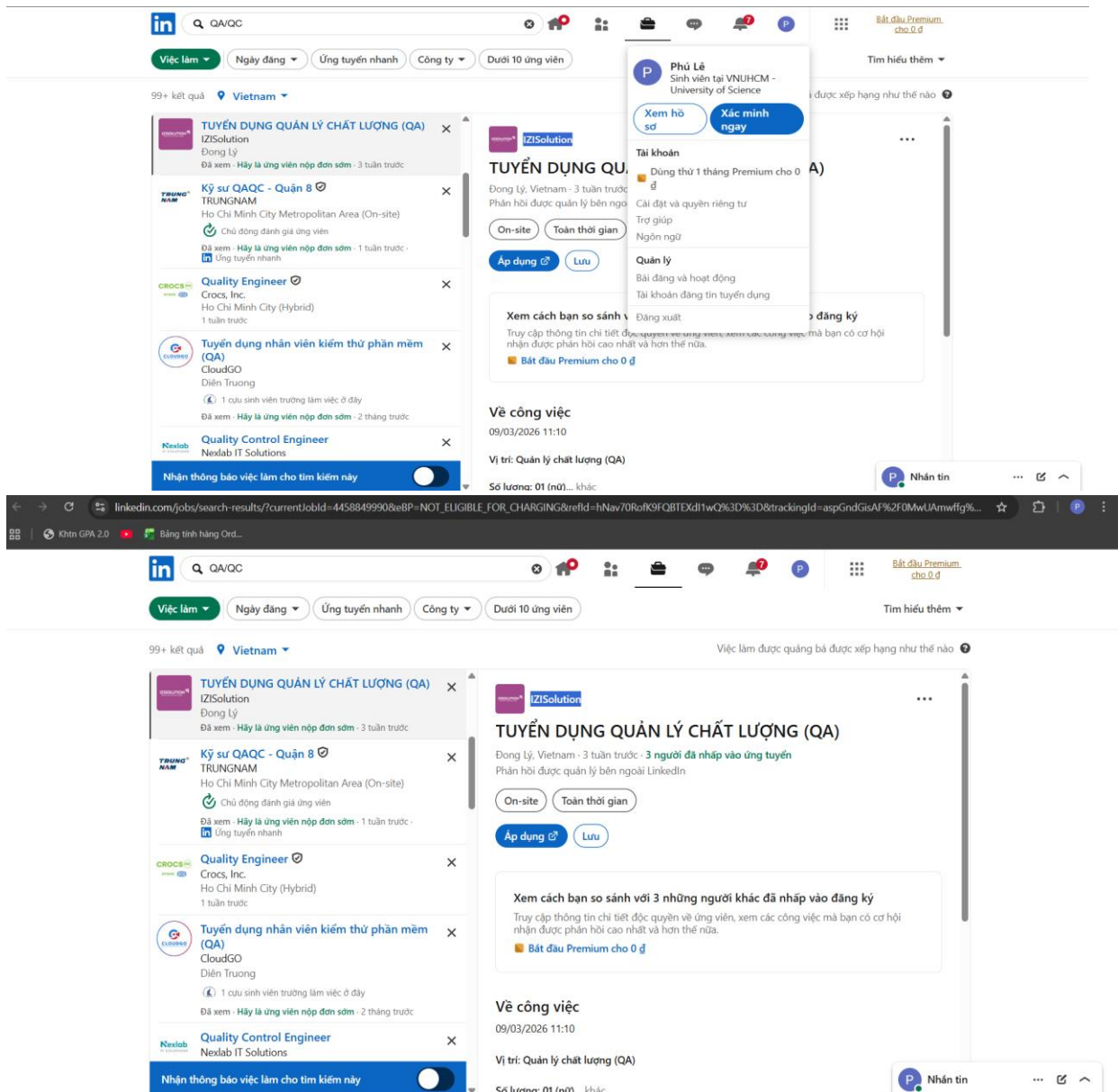
- Job description:

- + Tham gia vào dự án test các dự án về hệ thống với vai trò Tester
- + Lập kế hoạch kiểm thử, phân công công việc, giám sát tiến độ công việc của team trong dự án.
- + Chịu trách nhiệm về kiểm soát chất lượng các sản phẩm của Công ty trước khi bàn giao cho khách hàng.
- + Làm việc onsite tại văn phòng khách hàng ở quận 7 (domain Bảo Hiểm) TP. Hồ Chí Minh, Việt Nam.

- Required Skills:

- + Có ít nhất 3 năm kinh nghiệm Test Manual
- + Có kinh nghiệm Automation Test

- Salary: Mức lương theo năng lực từ 20M- 25M phụ thuộc vào level của ứng viên



Link: https://www.linkedin.com/jobs/search-results/?currentJobId=4458849990&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=hNav70RofK9FQBTEXdl1wQ%3D%3D&trackingId=aspGndGisAF%2F0MwUAmwffg%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=25

- Job description:

- Giới tính: Nữ
- Tốt nghiệp Đại học chuyên ngành Quản lý chất lượng, Công nghệ thông tin hoặc các ngành liên quan.

- Kinh nghiệm từ 2 năm trở lên, hiểu biết về quy trình quản lý chất lượng, kiểm soát chất lượng dự án
- Am hiểu quy trình & kiểm soát chất lượng dự án
- Chăm thận, trách nhiệm, làm việc nhóm tốt
- Thành thạo tin học văn phòng (Word, Excel) và các công cụ quản lý công việc

- Required Skills:

- Tham gia xây dựng, hoàn thiện và cải tiến quy trình quản lý chất lượng cho các dự án.
- Giám sát việc tuân thủ quy trình phát triển và triển khai dự án.
- Phối hợp với các bộ phận liên quan để kiểm soát chất lượng sản phẩm/dịch vụ trong quá trình thực hiện.
- Tiếp nhận, theo dõi và xử lý các phản hồi của khách hàng liên quan đến chất lượng sản phẩm.
- Thực hiện kiểm duyệt cuối (Final Inspection) trước khi bàn giao sản phẩm cho khách hàng.
- Theo dõi, đo lường và phân tích các chỉ số chất lượng (Quality Metrics).
- Đề xuất và triển khai các giải pháp cải tiến quy trình nhằm nâng cao hiệu quả hoạt động.
- Thực hiện các nhiệm vụ khác theo phân công của cấp trên.

- Salary: 10-25tr (deal theo năng lực, kinh nghiệm)

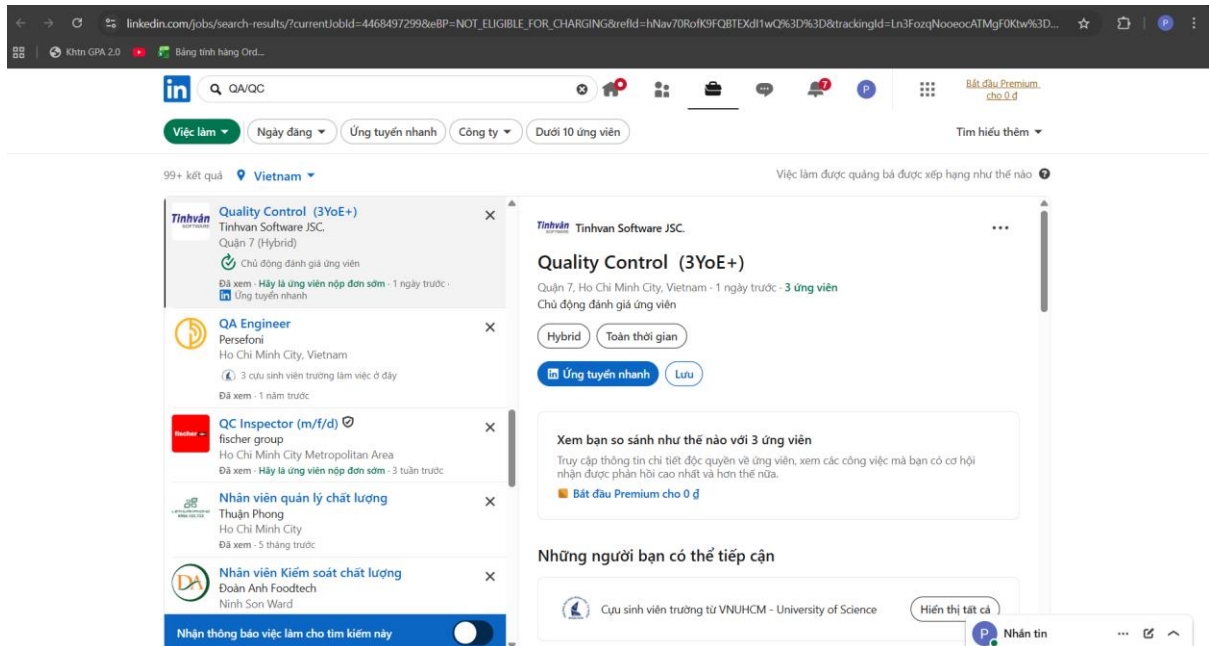
QUYỀN LỢI

- Lương: 10-25tr (deal theo năng lực, kinh nghiệm)
- Thưởng kết quả hoạt động kinh doanh, thưởng nóng;
- Review lương 1 năm 2 lần;
- Được làm việc trong môi trường công nghệ chuyên nghiệp, năng động, thử thách và nâng cao trình độ bản thân;
- Được cấp đồng phục, hỗ trợ ăn trưa, gửi xe tại công ty;
- Được đóng BHXH, BHYT, BHTN, phép năm và phép thăm niên;
- Gói khám sức khỏe định kỳ hàng năm, thưởng Lễ Tết, 30/04, 01/05, 2/9 ...
- Tham gia các hoạt động teambuilding, happy time, sinh nhật thành viên, đá bóng, du lịch hè, picnic, dã ngoại...
- Thời gian làm việc: từ Thứ 2 đến Thứ 6 và thứ 7 cách tuần, sáng từ 08h00 đến 12h00, chiều từ 13h30 đến 17h30h

- AI Impact Analysis: AI có thể hỗ trợ vị trí QC này trong việc tổng hợp phản hồi, phân tích Quality Metrics và phát hiện các xu hướng bất thường trong dữ liệu chất lượng, từ đó giúp xác định các vấn đề cần cải tiến quy trình.

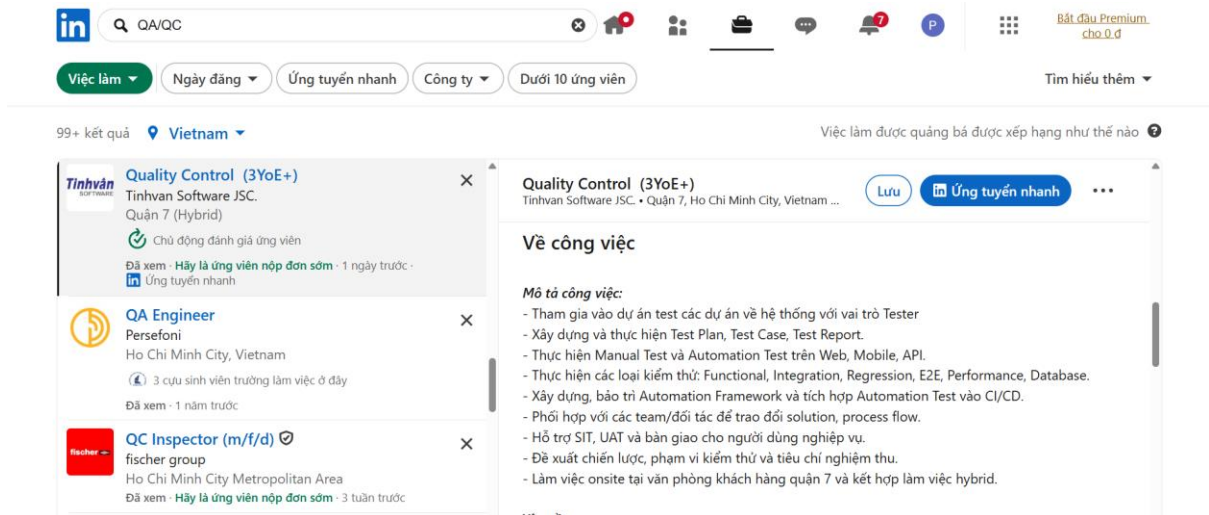
7. Quality Control (3YoE+)

The screenshot displays a LinkedIn job search interface. The search results on the left list several positions, including 'Quality Control (3YoE+)' at 'Tinhvan Software JSC.' in 'Quận 7 (Hybrid)'. The detailed view on the right shows the job listing for 'Quality Control (3YoE+)' at 'Tinhvan Software JSC.' in 'Quận 7, Ho Chi Minh City, Vietnam'. The job is categorized as 'Hybrid' and 'Toàn thời gian'. The user's profile and account settings are visible on the right side of the screen.



Link: https://www.linkedin.com/jobs/search-results/?currentJobId=4468497299&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=hNav70RofK9FQBTEXd1wQ%3D%3D&trackingId=Ln3FozqNooeocATMgF0Ktw%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=25

- Job description:



- Required Skills:

- + Có từ 3 năm kinh nghiệm Manual Testing và Automation Testing.
- +Thành thạo Java/JavaScript/TypeScript (Playwright).
- + Có kinh nghiệm với Katalon Studio, IntelliJ IDEA, VS Code.
- + Hiểu và áp dụng POM, Keyword-Driven, Data-Driven, BDD.

- + Có kinh nghiệm API Testing (Postman, JMeter) và Database (SQL Server, Oracle).
- + Có kinh nghiệm JIRA, Xray và quy trình Agile.
- + Giao tiếp tiếng Anh cơ bản có khả năng làm việc với team/đối tác nước ngoài.
- Salary: Mức lương theo năng lực từ 20M – 26M gross + phụ thuộc vào level của ứng viên

Quality Control (3YoE+)
 Tinhvan Software JSC. • Quận 7, Ho Chi Minh City, Vietnam ...

Lưu

Ứng tuyển nhanh

...

Mức lương theo năng lực từ 20M – 26M gross + phụ thuộc vào level của ứng viên

- Thu nhập: 13 tháng lương/năm + thưởng dự án lên đến 2 tháng lương/năm, thưởng Tết và các dịp lễ...
- Xét tăng lương 2 lần/năm: 1 lần theo định kỳ và 1 lần đột xuất theo năng lực và hiệu quả công việc
- Nghỉ thứ 7, Chủ nhật + Phép năm tối thiểu 12 ngày theo Quy định của Pháp luật hiện hành
- Được tham gia bảo hiểm xã hội, bảo hiểm y tế, bảo hiểm thất nghiệp theo Quy định của Pháp luật hiện hành
- Bảo hiểm chăm sóc sức khỏe
- Được tham gia các Câu lạc bộ của Công ty: CLB Bóng đá, các CLB Cầu Lông.....
- Được tham gia các hoạt động tập thể sôi động của công ty: Nghỉ mát hàng năm, Teambuilding hàng quý, Sinh nhật công ty, Gala cuối năm....
- Có chính sách thăm hỏi ốm đau, thai sản, hiếu, hỉ, sinh nhật cho bản thân và người thân

Đặc biệt

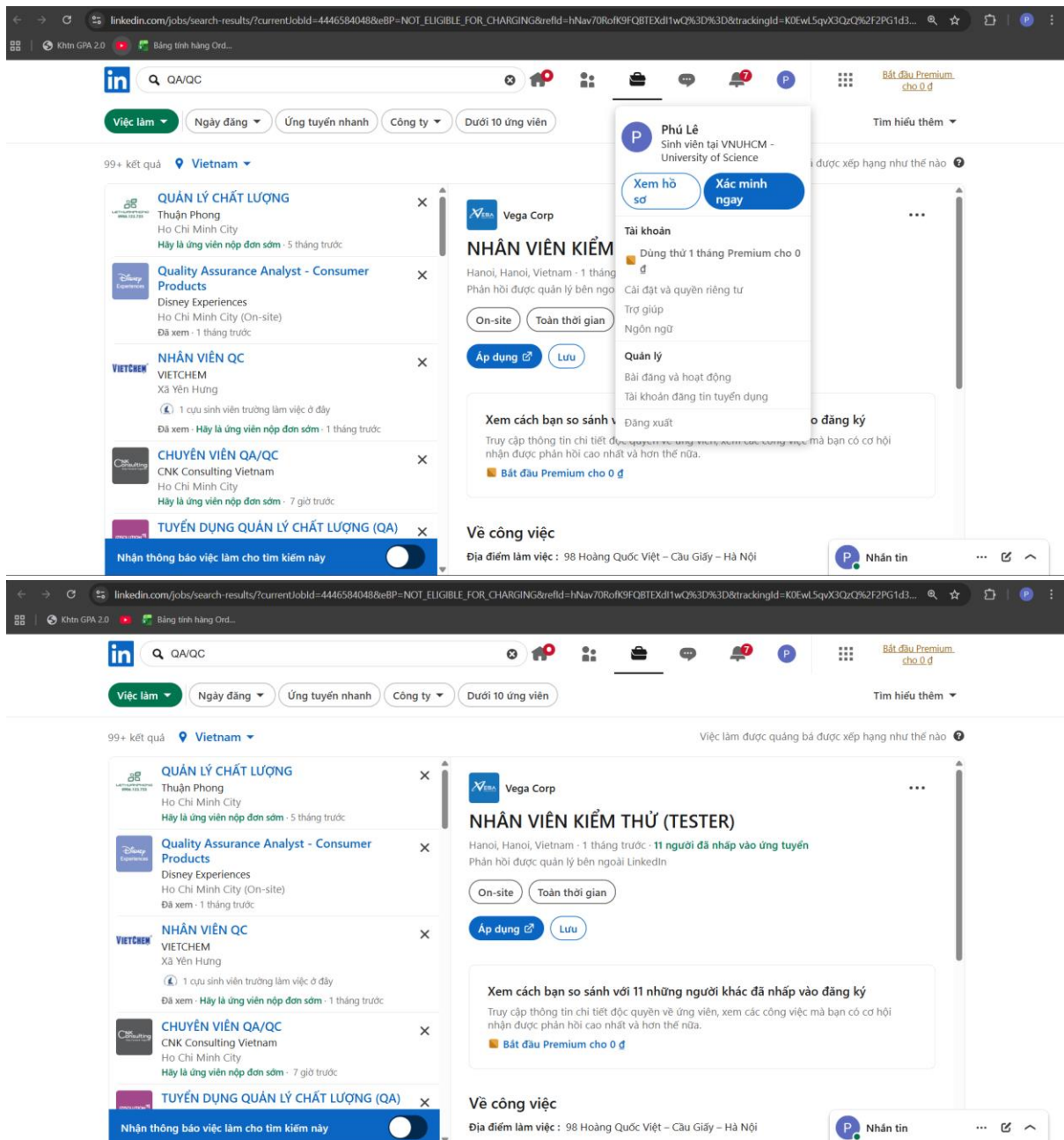
- Được hỗ trợ 50% chi phí các khóa học bên ngoài, hỗ trợ 100% chi phí thi các chứng chỉ liên quan đến IT, các khóa học nâng cao kỹ năng mềm, thưởng 3M – 10M khi hoàn thành chứng chỉ.
- Cơ hội làm việc và đào tạo tại Nhật Bản, Singapore với các ứng viên có tiếng Nhật hoặc tiếng Anh
- Làm việc trong môi trường trẻ trung, năng động, được hỗ trợ phát huy khả năng, phát triển công việc tối đa.

P

Nhắn tin

- AI Impact Analysis: AI có thể hỗ trợ vị trí Tester này trong việc sinh test case, tạo dữ liệu kiểm thử và hỗ trợ xây dựng hoặc tối ưu automation script, đặc biệt khi phạm vi testing bao gồm Web, Mobile, API và nhiều loại kiểm thử khác nhau.

8. Vega Corp: NHÂN VIÊN KIỂM THỬ (TESTER)



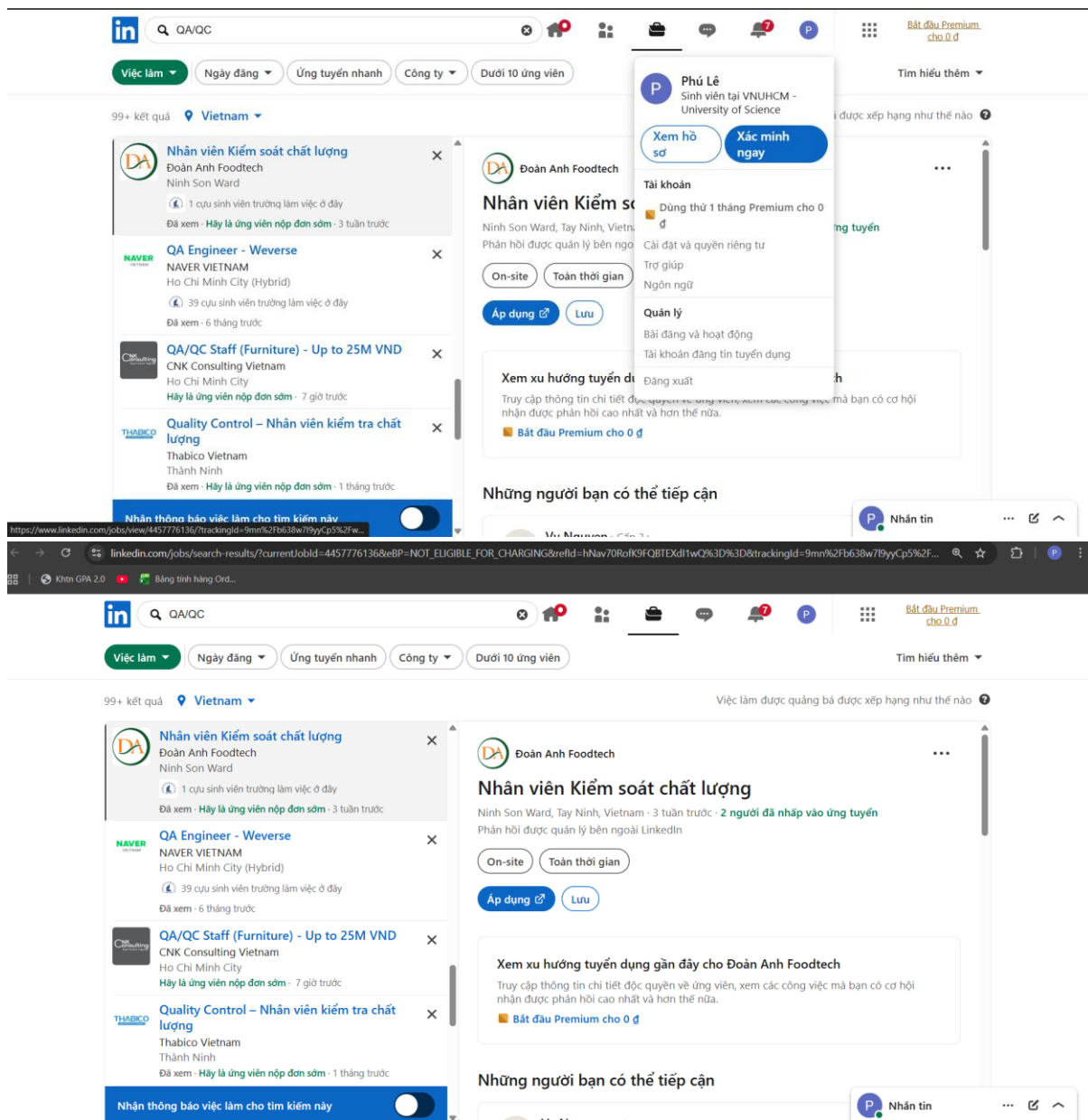
Link: https://www.linkedin.com/jobs/search-results/?currentJobId=4446584048&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=hNav70RofK9FQBTEXdI1wQ%3D%3D&trackingId=K0EwL5qvX3QzQ%2F2PG1d3Ig%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=25

- Job description:

- Phân tích và thiết kế test case dựa trên những yêu cầu của Nghiệp vụ.

- Thực hiện việc test UI trên các nền tảng khác nhau như : Web Browser , Mobile Device.
 - Thực hiện việc test tích hợp , test API , test Database nhằm mục đích đảm bảo chất lượng cho các dự án.
- Required Skills:
- Có kinh nghiệm từ 1 năm trong lĩnh vực test app, web
 - Tốt nghiệp CĐ/ĐH các chuyên ngành
 - Khả năng đọc hiểu & phân tích spec tốt
 - Có khả năng thiết kế Test Case, Test Data & tạo data để test
 - Sử dụng tốt CSDL SQL & có kinh nghiệm trong việc test API, mockup data
- Ưu Tiên
- Ứng viên đã có kinh nghiệm test các dự án về tài chính
 - Hòa đồng, giao tiếp tốt, trình bày vấn đề mạch lạc, giải thích dễ hiểu
 - Suy nghĩ cởi mở, lắng nghe, góp ý, tranh luận có tính tích cực
 - Chịu được áp lực công việc và sẵn sàng làm việc over-time khi có yêu cầu
- Salary: 10-15 Triệu + Thưởng quý
- AI Impact Analysis: AI có thể rút ngắn thời gian chuẩn bị kiểm thử cho vị trí này bằng cách hỗ trợ phân tích spec, đề xuất test case và tạo test data cho Web, Mobile, API và Database

9. Đoàn Anh Foodtech : Nhân viên Kiểm soát chất lượng



Link: https://www.linkedin.com/jobs/search-results/?currentJobId=4457776136&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=hNav70RofK9FQBTEXdI1wQ%3D%3D&trackingId=9mn%2Fb638w7l9yyCp5%2FwwDw%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=25

- Job description:

Đoàn Anh Foodtech • Ninh Son Ward, Tay Ninh, Vietnam (On-site)

Lưu

Áp dụng 

...

BẢN MÔ TẢ CÔNG VIỆC: NHÂN VIÊN KIỂM SOÁT CHẤT LƯỢNG (QC)

- Chức danh: Nhân viên Kiểm soát Chất lượng
- Bộ phận: Quản lý chất lượng (QA/QC)
- MỤC TIÊU CÔNG VIỆC
- Đảm bảo toàn bộ nguyên vật liệu đầu vào, quy trình lưu trữ – bảo quản tại kho lạnh và thành phẩm đầu ra tuân thủ nghiêm ngặt các tiêu chuẩn kỹ thuật, tiêu chuẩn an toàn vệ sinh thực phẩm (ATVSTP) và quy định pháp luật hiện hành.
- NHIỆM VỤ CHÍNH
- Thực hiện kiểm tra, đánh giá chất lượng nguyên vật liệu đầu vào và thành phẩm xuất kho theo đúng tiêu chuẩn kỹ thuật đề ra.
- Chủ động phối hợp chặt chẽ với các bộ phận liên quan (Kho vận, Sản xuất, Mua hàng...) để kịp thời phát hiện, xử lý các sự cố, lỗi sản phẩm phát sinh.
- Lập các biên bản kiểm tra, báo cáo chất lượng định kỳ (ngày/tuần/tháng) hoặc đột xuất theo yêu cầu.
- Thực hiện các nhiệm vụ chuyên môn khác theo sự phân công và điều động của Trưởng bộ phận.
- YÊU CẦU CÔNG VIỆC

- Required Skills:

Việc làm được quảng bá được xếp hạng như thế nào

Nhân viên Kiểm soát chất lượng
Đoàn Anh Foodtech • Ninh Sơn Ward, Tay Ninh, Vietnam (On-site)

Lưu

Áp dụng ↗

...

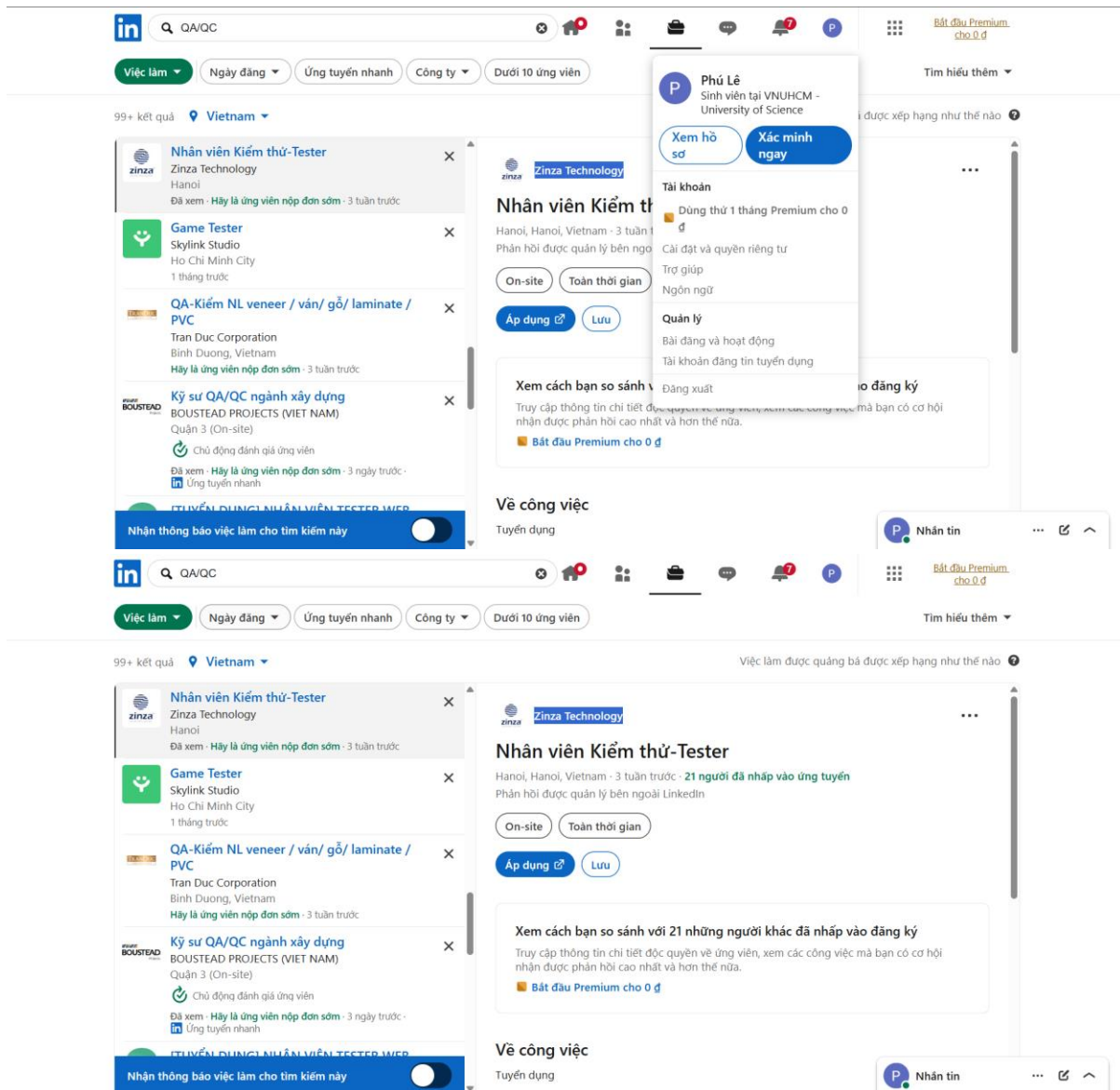
Chức năng phù hợp nhất cho các bộ phận liên quan (kitchen, sản xuất, mua hàng...) để kịp thời phát hiện, xử lý các sự cố, lỗi sản phẩm phát sinh.

- Lập các biên bản kiểm tra, báo cáo chất lượng định kỳ (ngày/tuần/tháng) hoặc đột xuất theo yêu cầu.
- Thực hiện các nhiệm vụ chuyên môn khác theo sự phân công và điều động của Trưởng bộ phận.
- **YÊU CẦU CÔNG VIỆC**
- Giới tính/Độ tuổi: Nam, từ 22 – 35 tuổi.
- Trình độ: Tốt nghiệp Cao đẳng trở lên chuyên ngành Công nghệ thực phẩm, Quản lý chất lượng, Hóa sinh thực phẩm hoặc các chuyên ngành có liên quan.
- Kinh nghiệm: Có ít nhất 01 năm kinh nghiệm trong lĩnh vực kiểm soát chất lượng thực phẩm, kho lạnh hoặc vị trí tương đương (Ưu tiên ứng viên có kinh nghiệm; ứng viên mới tốt nghiệp có nền tảng tốt sẽ được công ty đào tạo).
- Kiến thức chuyên môn:
 - Am hiểu các quy chuẩn về an toàn vệ sinh thực phẩm (ATVSTP), tiêu chuẩn HACCP, ISO 22000 và các quy định pháp luật liên quan đến lưu trữ, giao nhận hàng hóa.
 - Có kiến thức và hiểu biết về quy trình hoạt động, kiểm soát nhiệt độ/chất lượng sản phẩm phụ gia.
- Kỹ năng & Tố chất: Cẩn thận, trung thực, có tinh thần trách nhiệm cao, chịu được áp lực công việc và có kỹ năng giải quyết vấn đề tốt.

- Salary: 11.000.000 – 13.000.000 đồng/tháng (Thỏa thuận theo năng lực và kinh nghiệm thực tế).

- AI Impact Analysis: AI có thể hỗ trợ QC trong việc tổng hợp báo cáo chất lượng, theo dõi dữ liệu kiểm tra và nhận diện các dấu hiệu bất thường trong quá trình kiểm soát nguyên vật liệu và thành phẩm.

10. Zinza Technology: Nhân viên Kiểm thử-Tester



Link: https://www.linkedin.com/jobs/search-results/?currentJobId=4460215778&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=8NBOxyKtuplCPT9QqevacQ%3D%3D&trackingId=Xuhc9OtzeyOKB5O15BIzrQ%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_H_LANDING_PAGE&start=50

- Job description:

- Tham gia vào các dự án phát triển phần mềm của công ty, hoặc hệ thống nghiệp vụ của Khách hàng Mỹ-Nhật
- Tìm hiểu hệ thống nghiệp vụ, tìm hiểu requirement để hỗ trợ dev trong việc kiểm thử các chức năng
- Tham gia kiểm thử các dự án web, mobile app, và các hệ thống liên quan

- Đảm bảo chất lượng phần mềm, viết testcase, lập kế hoạch kiểm thử, thực hiện kiểm thử phần mềm
 - Báo cáo thường xuyên tình trạng kiểm thử phần mềm
- Required Skills:
- Yêu thích công việc kiểm thử hệ thống, kiểm thử phần mềm
 - Có kinh nghiệm kiểm thử 2 năm trở lên, nắm vững quy trình kiểm thử
 - Nắm vững các khái niệm unit test, integration test, system test, regression test
 - Có kinh nghiệm test web/mobile application, API test. SQL test
 - Có tư duy logic, tư duy về hệ thống, về test tốt
 - Giao tiếp tốt, có thể làm việc nhóm và phối hợp hiệu quả với dev/PM
- Salary: 10 - 15 triệu VNĐ
- AI Impact Analysis: AI có thể hỗ trợ Tester trong việc phân tích requirement, đề xuất test case và tổng hợp kết quả kiểm thử, đặc biệt khi phải kiểm thử nhiều loại hệ thống như web, mobile và API.

II. Requirement 2 – 20 Software Defects 2022–2026

1. CVE-2022-26134 – Atlassian Confluence

- Link: <https://nvd.nist.gov/vuln/detail/cve-2022-26134>?
- Description: Trong các phiên bản bị ảnh hưởng của Confluence Server và Data Center, tồn tại lỗ hổng tấn công chèn mã OGNL cho phép kẻ tấn công không cần xác thực thực thi mã tùy ý trên một phiên bản Confluence Server hoặc Data Center. Các phiên bản bị ảnh hưởng là từ 1.3.0 trước 7.4.17, từ 7.13.0 trước 7.13.7, từ 7.14.0 trước 7.14.3, từ 7.15.0 trước 7.15.2, từ 7.16.0 trước 7.16.4, từ 7.17.0 trước 7.17.4 và từ 7.18.0 trước 7.18.1.
- Severity: 9.8 Critical CVSS
- Consequences : Attacker có thể thực thi mã tùy ý trên Confluence Server/Data Center mà không cần authentication. Điều này có thể dẫn tới việc máy chủ bị compromise và attacker thực hiện các hành động trái phép trên hệ thống.
- Solution: Atlassian phát hành các phiên bản đã sửa lỗi:

- 7.4.17
- 7.13.7
- 7.14.3
- 7.15.2
- 7.16.4
- 7.17.4

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2022-26134 (Atlassian Confluence) bao gồm description, severity, consequences, solution.

+ Tool: Geimini

+ AI Output: CVE-2022-26134 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng đến các phiên bản Atlassian Confluence Server và Data Center. Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục:

1. Description (Mô tả)

- Bản chất: Đây là một lỗ hổng OGNL Injection (Object-Graph Navigation Language) hay được phân loại theo CWE-917 (Improper Neutralization of Special Elements used in an Expression Language Statement).
- Cơ chế: Lỗ hổng tồn tại do cách Confluence xử lý các tham số trong URL và tên action/namespace. Khi một kẻ tấn công gửi một HTTP request chứa các đoạn mã hoặc ký tự cú pháp OGNL đặc biệt (ví dụ: chứa chuỗi `\${...}`) trong đường dẫn URL, hệ thống sẽ tiếp nhận và đánh giá/thực thi các biểu thức này trực tiếp trên Java Runtime Environment (JRE) của máy chủ.
- Điểm đáng chú ý: Lỗ hổng này không yêu cầu xác thực (unauthenticated), nghĩa là bất kỳ ai có kết nối mạng tới ứng dụng Confluence đều có thể khai thác mà không cần tài khoản hay quyền hạn.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Độ phức tạp thấp (Low Attack Complexity), không cần tương tác người dùng (No User Interaction), và thực thi từ xa qua

mạng (Network Vector). Lỗ hổng này đã bị khai thác rộng rãi trên thực tế (In-the-wild) ngay sau khi được công bố và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog).

3. Consequences (Hậu quả)

Khi bị khai thác thành công, kẻ tấn công có thể gây ra những hậu quả nghiêm trọng sau:

- Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình chạy ứng dụng Confluence trên hệ điều hành chủ (OS Command Execution).
- Kiểm soát toàn bộ hệ thống: Kẻ tấn công có thể cài cắm web shell (ví dụ: Behinder, China Chopper) để duy trì quyền truy cập trái phép, đọc/đánh cắp dữ liệu nhạy cảm của doanh nghiệp, hoặc đánh cắp thông tin tài khoản (**credential dumping**) từ /etc/passwd hoặc cơ sở dữ liệu.
- **Tấn công lan rộng (Lateral Movement)**: Biến máy chủ Confluence bị chiếm đoạt thành bàn đạp để thâm nhập sâu hơn vào mạng nội bộ của tổ chức.
- Triển khai mã độc: Đã ghi nhận nhiều trường hợp kẻ xấu lợi dụng lỗ hổng này để cài cắm phần mềm đào tiền ảo (**cryptocurrency miners**) hoặc **ransomware**.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Nâng cấp (Upgrade) ứng dụng Confluence Server hoặc Data Center lên các phiên bản đã được vá lỗi từ hãng (phiên bản 7.4.17, 7.13.7, 7.14.3, 7.15.2, 7.16.4, 7.17.4, 7.18.1 hoặc các bản phát hành mới hơn).
- Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay):
 - Cô lập hoặc hạn chế quyền truy cập mạng từ bên ngoài vào máy chủ Confluence (chỉ cho phép truy cập từ mạng nội bộ đáng tin cậy).

- Cấu hình Web Application Firewall (WAF) với các quy tắc chặn các request có chứa cú pháp biểu thức OGNL độc hại hoặc các chuỗi như \${ trong đường dẫn URL.

- Đánh giá của sinh viên: Đây là hiện tượng "ảo giác" của AI vì chưa có nguồn thông tin xác nhận rằng các kẻ tấn công có thể credential dumping, lateral movement hay ransomware, cryptocurrency miners. Tôi không tìm thấy những thông tin này trên trang chính thức.

2. CVE-2022-1388

- Link: <https://nvd.nist.gov/vuln/detail/cve-2022-1388>

- Description: CVE-2022-1388 là lỗ hổng bỏ qua xác thực trong thành phần iControl REST của F5 BIG-IP. Một kẻ tấn công chưa được xác thực có quyền truy cập mạng vào hệ thống BIG-IP bị ảnh hưởng có thể bỏ qua bước xác thực và tương tác với giao diện iControl REST

- Severity: Critical 9.8 CVSS

- Consequences: Lỗ hổng bảo mật này cho phép đối tượng tấn công không cần xác thực có thể thực thi lệnh tùy ý, tạo hoặc xóa tệp tin, vô hiệu hóa các dịch vụ, chiếm quyền điều khiển hệ thống.

- Solution: F5 phát hành các phiên bản đã được sửa lỗi: Phiên bản không bị ảnh hưởng 17.0.0 < 17.0.x*

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2022-1388 (F5 BIG-IP iControl REST) bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2022-1388 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng đến giao diện quản trị iControl REST trên các thiết bị F5 BIG-IP. Dưới đây là thông tin chi tiết:

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Authentication Bypass (Bỏ qua cơ chế xác thực, mã định danh CWE-306) kết hợp với Remote Code Execution (RCE).
- Cơ chế: Giao diện lập trình ứng dụng iControl REST API của F5 BIG-IP gặp lỗi trong cách xử lý các HTTP request qua proxy Apache/HTTPD. Bằng cách gửi các chuỗi HTTP request được tinh chỉnh đặc biệt (thao tác trên các header như Connection và X-F5-Auth-Token), kẻ tấn công có thể lừa hệ thống để đánh lừa lớp kiểm tra xác thực.
- Điểm đáng chú ý: Lỗ hổng này hoàn toàn không cần xác thực (unauthenticated). Kẻ tấn công chỉ cần có quyền truy cập mạng vào cổng quản lý (management port) hoặc địa chỉ IP tự gán (self-IP) của thiết bị là có thể khai thác.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu tương tác người dùng, tấn công từ xa qua mạng. Ngay sau khi được công bố, lỗ hổng này đã bị khai thác hàng loạt trên thực tế và được CISA đưa vào danh mục các lỗ hổng bị khai thác biết trước (*Known Exploited Vulnerabilities Catalog*).

3. Consequences (Hậu quả)

Vì thiết bị F5 BIG-IP thường đóng vai trò là cổng biên quan trọng (như bộ cân bằng tải, thiết bị điều phối ứng dụng hoặc tường lửa), việc bị chiếm đoạt mang lại hậu quả tàn khốc:

- **Thực thi mã lệnh tùy ý (RCE) với quyền cao nhất:** Kẻ tấn công có thể chạy các lệnh hệ điều hành dưới quyền root.
- Kiểm soát toàn bộ thiết bị: Tạo/xóa tệp tin, vô hiệu hóa dịch vụ, thay đổi cấu hình hệ thống mạng.
- Bàn đạp tấn công nội bộ (Lateral Movement): Kẻ xấu có thể chiếm quyền kiểm soát thiết bị để **đánh cắp lưu lượng mạng nhạy cảm đi qua hệ thống**,

cài đặt mã độc, hoặc thâm nhập sâu hơn vào hạ tầng mạng bên trong doanh nghiệp.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Nâng cấp phần mềm BIG-IP lên các phiên bản đã được vá lỗi từ hãng (ví dụ: phiên bản 16.1.2.2, 15.1.5.1, 14.1.4.6, 13.1.5 hoặc cao hơn tùy theo nhánh phiên bản bạn đang sử dụng).
- Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay):
 - Chặn truy cập: Cấm tuyệt đối việc truy cập vào giao diện iControl REST từ các mạng không đáng tin cậy hoặc từ Internet công cộng (không phơi bày cổng quản lý management/self-IP ra ngoài mạng internet).
 - Cấu hình lại HTTPD: Áp dụng các thay đổi cấu hình tệp tin httpd trên BIG-IP theo khuyến nghị trực tiếp từ tài liệu bảo mật chính thức của F5 (K23605346).

- Đánh giá của sinh viên: Đây là ảo giác AI khi cho rằng kẻ tấn công có thể chạy lệnh điều với quyền root và thực hiện di chuyển ngang trong mạng và chặn bắt lưu lượng mạng nhạy cảm. CISA chưa cung cấp thông tin về những khả năng này.

3. CVE-2022-30190

- Link:

+ <https://nvd.nist.gov/vuln/detail/cve-2022-30190>

+ [https://www.microsoft.com/en-us/msrc/blog/2022/05/guidance-for-cve-2022-30190-microsoft-support-diagnostic-tool-vulnerability?](https://www.microsoft.com/en-us/msrc/blog/2022/05/guidance-for-cve-2022-30190-microsoft-support-diagnostic-tool-vulnerability?hpid=hp-security-alert%3Amicrosoft-support-diagnostic-tool-vulnerability%3Ahomepage%2Fen-us)

- Description: Lỗ hổng thực thi mã từ xa tồn tại khi MSDT được gọi bằng giao thức URL từ một ứng dụng gọi như Word. Kẻ tấn công khai thác thành công lỗ hổng này có thể chạy mã tùy ý với quyền hạn của ứng dụng gọi.

- Severity: High 7.8 CVSS

- Consequences: kẻ tấn công có thể cài đặt chương trình, xem, thay đổi hoặc xóa dữ liệu, hoặc tạo tài khoản mới trong ngữ cảnh được cho phép bởi quyền của người dùng.

- Solution: Install Microsoft's security updates. As a temporary workaround, disable the MSDT URL protocol by removing the ms-msdt registry key as instructed by Microsoft.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2022-30190 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2022-30190 (được biết đến rộng rãi với biệt danh "Follina") là một lỗ hổng bảo mật nổi tiếng ảnh hưởng đến công cụ chẩn đoán Microsoft Support Diagnostic Tool (MSDT) trên hệ điều hành Windows.

Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục:

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Remote Code Execution (RCE) lợi dụng cách giao thức URL tùy chỉnh ms-msdt:// hoạt động.
- Cơ chế: Lỗ hổng cho phép kẻ tấn công thực thi mã lệnh từ xa thông qua các tài liệu Microsoft Office (Word, RTF, v.v.) mà không cần kích hoạt Macros. Kẻ tấn công tạo một tệp văn bản chứa liên kết độc hại trỏ đến một tệp HTML từ xa. Khi nạn nhân mở tệp hoặc thậm chí chỉ xem trước (Preview Pane) tệp trong Windows Explorer (đối với định dạng .rtf), ứng dụng Office sẽ gọi công cụ MSDT của hệ thống để chạy mã lệnh PowerShell ngầm mà người dùng không hề hay biết.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 7.8 / 10.0 (Mức High - Cao theo thang đo tiêu chuẩn, nhưng tính nguy hiểm thực tế cực kỳ cao vì bị lợi dụng làm bàn đạp tấn công ban đầu).
- Đặc điểm tấn công: Kẻ tấn công chỉ cần lừa người dùng mở một tệp tài liệu thông qua các chiến dịch tấn công giả mạo (phishing). Lỗ hổng này đã bị khai thác diện rộng (*In-the-wild*) dưới dạng zero-day trước khi Microsoft phát hành bản vá và nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA (*Known Exploited Vulnerabilities Catalog*).

3. Consequences (Hậu quả)

Khi khai thác thành công CVE-2022-30190, kẻ tấn công có thể:

- Thực thi mã lệnh tùy ý (RCE): Chạy các lệnh hệ thống dưới quyền hạn của người dùng đang đăng nhập.
- **Cài cắm phần mềm độc hại: Tải xuống và cài đặt các payload độc hại như mã độc tống tiền (ransomware), phần mềm đánh cắp thông tin (info-stealers), hoặc trojan truy cập từ xa (RAT).**
- Thao túng dữ liệu: Tạo tài khoản mới, xem, sửa đổi hoặc xóa dữ liệu trên hệ thống của nạn nhân.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật các bản vá bảo mật chính thức từ Microsoft (các gói cập nhật từ tháng 6/2022 trở đi) để vô hiệu hóa cách thức lạm dụng giao thức MSDT.
- Giải pháp phòng ngừa bổ sung:
 - Kích hoạt các quy tắc giảm bề mặt tấn công (Attack Surface Reduction - ASR) trong Windows Defender, đặc biệt là quy tắc “*Block all Office applications from creating child processes*” để chặn các ứng dụng Office sinh tiến trình độc hại gọi MSDT.
 - Sao lưu và xóa khóa sổ đăng ký (Registry) của giao thức ms-msdt nếu chưa thể áp dụng bản vá ngay lập tức.

- Đánh giá của sinh viên: AI tuyên bố chưa có cơ sở ở chỗ tải xuống và cài đặt các payload độc hại như mã độc tống tiền (ransomware), phần mềm đánh cắp thông tin (info-stealers), hoặc trojan truy cập từ xa (RAT). Microsoft chưa có xác nhận chính thức về những khả năng trên.

4. CVE-2022-22954

- Link: <https://nvd.nist.gov/vuln/detail/cve-2022-22954>

- Description: VMware Workspace ONE Access và Identity Manager chứa lỗ hổng thực thi mã từ xa do chèn mẫu phía máy chủ

- Consequence: Kẻ tấn công có quyền truy cập mạng có thể kích hoạt việc chèn mẫu phía máy chủ, dẫn đến thực thi mã từ xa.

- Severity: Critical 9.8 CVSS

- Solution: VMware phát hành các bản patch để khắc phục CVE-2022-22954. VMware hướng dẫn người dùng áp dụng các phiên bản được liệt kê trong **Resolution Matrix** của advisory.

<https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/23639?>

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2022-22954 bao gồm description, severity, consequences, solution.

+ Tool: Geimini

+ AI Output:

CVE-2022-22954 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng đến các sản phẩm quản lý danh tính và quyền truy cập của VMware (như Workspace ONE Access và Identity Manager).

Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục:

1. Description (Mô tả)

- Bản chất: Đây là một lỗ hổng Server-Side Template Injection (SSTI).
- Cơ chế: Lỗ hổng xuất phát từ việc các ứng dụng của VMware xử lý thiếu an toàn các đầu vào của người dùng trong các biểu mẫu hoặc trang hiển thị. Kẻ tấn công có quyền truy cập mạng có thể gửi một HTTP request được thiết kế đặc biệt (chứa các đoạn mã template độc hại) để kích hoạt lỗ hổng tiêm mã mẫu phía máy chủ (SSTI), từ đó hệ thống sẽ biên dịch và thực thi chúng.
- Điểm đáng chú ý: Lỗ hổng này không yêu cầu xác thực (unauthenticated) và kẻ tấn công chỉ cần có khả năng kết nối mạng tới cổng ứng dụng là có thể khai thác.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng. Ngay sau khi công bố, lỗ hổng này đã bị các nhóm tấn công mạng khai thác diện rộng trên thực tế (*In-the-wild*) và nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA (*Known Exploited Vulnerabilities Catalog*).

3. Consequences (Hậu quả)

Khi bị khai thác thành công, kẻ tấn công có thể:

- **Remote Code Execution (RCE)**: Thực thi mã lệnh tùy ý dưới quyền của tiến trình đang chạy ứng dụng (thường có đặc quyền cao trên hệ điều hành nền tảng).
- Kiểm soát hệ thống: Tải lên các tệp tin độc hại, **cài cắm webshell để duy trì quyền truy cập lâu dài (persistence)**.
- Đánh cắp dữ liệu & Xâm nhập sâu hơn: **Đánh cắp thông tin xác thực**, dữ liệu định danh nhạy cảm của doanh nghiệp, hoặc **dùng máy chủ này làm**

bản đạp để tấn công vào các thành phần khác trong hạ tầng nội bộ (như VMware Cloud Foundation hoặc vRealize Suite).

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật/nâng cấp các sản phẩm bị ảnh hưởng lên các phiên bản đã được VMware vá lỗi chính thức theo thông báo bảo mật (VMSA-2022-0011).
- Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay):
 - Áp dụng các bản vá cấu hình thủ công hoặc kịch bản vô hiệu hóa tính năng tạm thời do VMware cung cấp trong các bài viết Hỗ trợ kỹ thuật (VMware KB articles tương ứng như KB88098).
 - Hạn chế hoặc chặn toàn bộ quyền truy cập mạng bên ngoài vào giao diện quản trị của Workspace ONE Access/Identity Manager, chỉ cho phép quản trị qua mạng nội bộ được kiểm soát nghiêm ngặt.

- Đánh giá của sinh viên: AI đang bị ảo giác vì nó đưa ra “thực thi mã lệnh tùy ý dưới quyền của tiến trình đang chạy ứng dụng (thường có đặc quyền cao trên hệ điều hành nền tảng)”, “cài cắm webshell để duy trì persistence”, “đánh cắp thông tin xác thực”,... AI đang mở rộng quá mức hậu quả. Ở trên toàn là những hậu quả nghiêm trọng xảy ra sau khi hệ thống đã bị mất quyền kiểm soát. Nó không phải là hậu quả trực tiếp của CVE đang trình bày.

5. CVE-2022-47966

- Link: <https://nvd.nist.gov/vuln/detail/cve-2022-47966?>

- Description: CVE-2022-47966 là một lỗ hổng nghiêm trọng ảnh hưởng đến nhiều sản phẩm của Zoho ManageEngine. Lỗ hổng này liên quan đến quá trình xử lý các phản hồi SAML và có thể cho phép kẻ tấn công không cần xác thực thực thi mã từ xa trên hệ thống bị ảnh hưởng.

- Severity: Critical 9.8/10. CVSS

- Consequence:

- + Attacker có thể thực hiện cuộc tấn công từ xa mà không cần authentication hoặc user interaction.
- + Attacker thực hiện các hành động trái phép với quyền của process đang chạy sản phẩm, tùy thuộc vào cấu hình và quyền của hệ thống.
- + Solution: cập nhật các sản phẩm ManageEngine bị ảnh hưởng lên phiên bản đã được Zoho phát hành bản vá.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2022-47966 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2022-47966 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng đến hơn 20 sản phẩm chạy tại chỗ (on-premise) của Zoho ManageEngine (như ServiceDesk Plus, ADSelfService Plus, Endpoint Central, Password Manager Pro, v.v.).

Dưới đây là thông tin chi tiết:

1. Description (Mô tả)

- Bản chất: Lỗ hổng Unauthenticated Remote Code Execution (RCE) (Thực thi mã lệnh từ xa không cần xác thực).
- Cơ chế: Lỗ hổng xuất phát từ việc các sản phẩm của ManageEngine sử dụng thư viện bên thứ ba đã lỗi thời là Apache Santuario xmlsec (XML Security for Java) phiên bản 1.4.1. Thư viện này thực hiện các phép biến đổi XSLT trong quá trình xử lý chữ ký số SAML trước khi xác thực. Kẻ tấn công có thể gửi một yêu cầu SAML độc hại được tinh chỉnh sẵn để lợi dụng điểm yếu này, buộc ứng dụng thực thi mã Java tùy ý.
- Điều kiện khai thác: Lỗ hổng chỉ xảy ra nếu hệ thống mục tiêu đang bật tính năng đăng nhập một lần SAML SSO, hoặc thậm chí đã từng bật tính năng này ít nhất một lần trong quá khứ (tùy thuộc vào từng sản phẩm cụ thể).

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Không cần tài khoản hay quyền hạn (Unauthenticated), độ phức tạp thấp, khai thác từ xa qua mạng. Lỗ hổng này đã bị các nhóm tấn công khai thác rộng rãi trên thực tế (*In-the-wild*) và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (*Known Exploited Vulnerabilities Catalog*).

3. Consequences (Hậu quả)

Khi bị khai thác thành công, kẻ tấn công có thể:

- Thực thi mã lệnh tùy ý (RCE): Chạy các lệnh hệ điều hành dưới quyền của tiến trình ứng dụng ManageEngine (**thường có đặc quyền cao trên hệ thống**).
- Kiểm soát toàn bộ máy chủ: Cài cắm webshell, tạo tài khoản quản trị ẩn, đánh cắp thông tin nhạy cảm.
- **Xâm nhập sâu hơn (Lateral Movement)**: Do các sản phẩm ManageEngine thường nằm sâu trong mạng nội bộ và có quyền quản lý thiết bị rộng, kẻ xấu có thể dùng máy chủ này làm bàn đạp để kiểm soát toàn bộ hạ tầng mạng của doanh nghiệp.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Nâng cấp các sản phẩm ManageEngine bị ảnh hưởng lên các phiên bản đã được vá lỗi chính thức từ nhà sản xuất (ví dụ: ServiceDesk Plus lên build 14004, ADSelfService Plus lên build 6211 trở lên).
- Giải pháp tạm thời (Nếu chưa thể cập nhật ngay):
 - Tạm thời vô hiệu hóa tính năng SAML SSO trên các sản phẩm nếu không thực sự bắt buộc phải sử dụng.
 - Giới hạn quyền truy cập mạng, chặn tuyệt đối việc phơi bày giao diện quản trị của các ứng dụng ManageEngine ra Internet công cộng (chỉ cho phép truy cập từ mạng nội bộ đáng tin cậy).

- Đánh giá của sinh viên: những hậu quả trên không phải là những ảnh hưởng trực tiếp mà ManageEngine Advisory xác nhận. Nên là AI chưa phân biệt được tác động của lỗ hổng bảo mật với các hành động sau khi đã khai thác.

6. CVE-2023-34362

- Link: <https://nvd.nist.gov/vuln/detail/cve-2023-34362>

- Description: Trên các phiên bản MOVEit Transfer trước 2021.0.6 (13.0.6), 2021.1.4 (13.1.4), 2022.0.4 (14.0.4), 2022.1.5 (14.1.5) và 2023.0.1 (15.0.1), một lỗ hổng tấn công SQL injection đã được phát hiện trong ứng dụng web MOVEit Transfer, cho phép kẻ tấn công không cần xác thực truy cập vào cơ sở dữ liệu của MOVEit Transfer.

LUU Ý: Lỗ hổng này đã bị khai thác trên thực tế vào tháng 5 và tháng 6 năm 2023; việc khai thác các hệ thống chưa được vá lỗi có thể xảy ra thông qua HTTP hoặc HTTPS. Tất cả các phiên bản (ví dụ: 2020.0 và 2019x) trước năm phiên bản được đề cập rõ ràng đều bị ảnh hưởng, bao gồm cả các phiên bản cũ hơn không được hỗ trợ.

- Severity: Critical 9.8 CVSS

- Consequence: Tùy thuộc vào công cụ cơ sở dữ liệu được sử dụng (MySQL, Microsoft SQL Server hoặc Azure SQL), kẻ tấn công có thể suy luận thông tin về cấu trúc và nội dung của cơ sở dữ liệu, và thực thi các câu lệnh SQL để thay đổi hoặc xóa các phần tử trong cơ sở dữ liệu

- Solution: Nâng cấp ngay lập tức phần mềm MOVEit Transfer lên các phiên bản đã được Progress Software phát hành bản vá chính thức (ví dụ: các phiên bản 2021.0.6, 2021.1.4, 2022.0.4, 2022.1.5, 2023.0.1 trở lên tùy thuộc vào nhánh sản phẩm đang sử dụng)

- **Kiểm chứng AI Bias / Hallucination:**

+ Prompt AI: Hãy giải thích CVE-2023-34362 bao gồm description, severity, consequences, solution.

+ Tool: Geimini

+ AI Output:

CVE-2023-34362 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng đến phần mềm quản lý truyền tải tệp tin Progress MOVEit Transfer (và MOVEit Cloud). Lỗ hổng này từng gây ra một làn sóng tấn công quy mô lớn trên toàn cầu do nhóm ransomware nổi tiếng *Clop* thực hiện.

Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục:

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng SQL Injection (SQLi) nằm trong ứng dụng web MOVEit Transfer.
- Cơ chế: Lỗ hổng cho phép kẻ tấn công gửi các HTTP/HTTPS request được thiết kế đặc biệt chứa các đoạn mã SQL độc hại tới các endpoint của MOVEit Transfer. Do thiếu cơ chế lọc và xác thực dữ liệu đầu vào đúng cách, hệ thống cho phép truy vấn trực tiếp vào cơ sở dữ liệu phía sau (hỗ trợ các engine như MySQL, Microsoft SQL Server hoặc Azure SQL).
- Điểm đáng chú ý: Lỗ hổng này hoàn toàn không cần xác thực (unauthenticated). Kẻ tấn công từ bên ngoài Internet có thể kết nối thẳng đến ứng dụng và khai thác thành công mà không cần tài khoản hay quyền hạn ban đầu.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng, khai thác từ xa qua mạng. Đây là một lỗ hổng dạng zero-day từng bị lợi dụng hàng loạt trên thực tế trước khi có bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (*Known Exploited Vulnerabilities Catalog*).

3. Consequences (Hậu quả)

Khi khai thác thành công CVE-2023-34362, kẻ tấn công có thể thực hiện một chuỗi tấn công (exploit chain) gây ra hậu quả tàn khốc:

- Truy cập và trích xuất cơ sở dữ liệu: Đọc, **đánh cắp toàn bộ thông tin nhạy cảm lưu trữ trong cơ sở dữ liệu** (thông tin người dùng, cấu hình, dữ liệu tệp tin doanh nghiệp).
- Triển khai Web Shell (Cài cắm cửa hậu): Kẻ tấn công tải lên các tệp mã độc (ví dụ: mã độc tùy chỉnh như *LEMURLOOT* hay các webshell .aspx) để duy trì quyền truy cập lâu dài và điều khiển máy chủ từ xa.
- **Ransomware & Tổng tiền doanh nghiệp (Extortion)**: Bị lợi dụng chủ yếu bởi nhóm Clop để đánh cắp lượng lớn dữ liệu nội bộ của hàng loạt cơ quan chính phủ, tập đoàn tài chính, y tế lớn trên toàn cầu nhằm tống tiền.

4. Solution (Giải pháp khắc phục)

- **Giải pháp tối ưu và triệt để nhất**: Nâng cấp ngay lập tức phần mềm MOVEit Transfer lên các phiên bản đã được Progress Software phát hành bản vá chính thức (ví dụ: các phiên bản 2021.0.6, 2021.1.4, 2022.0.4, 2022.1.5, 2023.0.1 trở lên tùy thuộc vào nhánh sản phẩm đang sử dụng).
- Giải pháp tạm thời / Phòng ngừa bổ sung:
 - Chặn lưu lượng HTTP/HTTPS: Nếu chưa thể nâng cấp ngay, tạm thời chặn toàn bộ lưu lượng HTTP và HTTPS truy cập vào cổng MOVEit Transfer (chặn port 80 và 443 ở tường lửa), chỉ cho phép sử dụng các giao thức an toàn khác nếu bắt buộc hoặc quản trị qua Remote Desktop nội bộ.
 - Kiểm tra dấu hiệu xâm nhập (IoC): Rà soát hệ thống tệp tin trong thư mục gốc (wwwroot) để tìm kiếm các webshell lạ (ví dụ các tệp .aspx bất thường hoặc tệp có tên dạng human2.aspx), kiểm tra nhật ký truy cập (logs) xem có hành vi truy vấn cơ sở dữ liệu đáng ngờ hay không.

- Đánh giá của sinh viên: AI có dấu hiệu bị ảo giác vì khả năng đánh cắp toàn bộ dữ liệu hay tống tiền doanh nghiệp đều chưa thấy các trang chính thức xác

nhận. Nhưng mà AI đã làm phần solution hoàn chỉnh và chẵn chu hơn nên tôi đã lấy phần giải pháp tối ưu của AI.

7. CVE-2023-25136

- Link: <https://nvd.nist.gov/vuln/detail/cve-2023-25136?>

- Description: Máy chủ OpenSSH (sshd) 9.1 đã đưa ra lỗi hỏng giải phóng bộ nhớ hai lần trong quá trình xử lý options.kex_algorithms. Lỗi hỏng này đã được khắc phục trong OpenSSH 9.2

- Severity: 6.5 Medium

- Consequence: Trong cấu hình mặc định, kẻ tấn công từ xa không được xác thực có thể lợi dụng lỗi giải phóng bộ nhớ hai lần này để nhảy đến bất kỳ vị trí nào trong không gian địa chỉ của sshd. Một báo cáo của bên thứ ba cho biết "về mặt lý thuyết, việc thực thi mã từ xa là có thể xảy ra".

- Solution: OpenSSH đã sửa lỗi trong OpenSSH 9.2.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2023-25136 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2023-25136 là một lỗ hổng bảo mật ảnh hưởng đến OpenSSH server (sshd), cụ thể xuất hiện trên phiên bản 9.1. Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục:

1. Description (Mô tả)

- Bản chất: Đây là một lỗi Double-Free (Giải phóng bộ nhớ hai lần) được định danh theo CWE-415, xảy ra trong quá trình xử lý các thuật toán trao đổi khóa (options.kex_algorithms) của OpenSSH.
- Cơ chế: Lỗi xuất phát từ đoạn mã lọc và xử lý tham số thuật toán trao đổi khóa (compat.c), nơi hàm xử lý không trả về con trỏ chuỗi được cấp phát động một cách nhất quán. Điều này dẫn đến việc tiến trình cố gắng giải phóng cùng một vùng nhớ hai lần.

- Điểm đáng chú ý: Kẻ tấn công từ xa không cần xác thực (unauthenticated) có thể gửi các gói tin kết nối SSH được tinh chỉnh đặc biệt để kích hoạt lỗ hổng này ngay trong giai đoạn thương lượng kết nối ban đầu (handshake/key exchange).

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: Điểm số có sự đánh giá khác nhau tùy thuộc vào tổ chức kiểm định:
 - Theo một số đánh giá ban đầu hoặc tính toán lý thuyết tối đa có thể lên tới 9.8 / 10.0 (Critical) do khả năng can thiệp vào bộ nhớ.
 - Theo NVD/NIST chuẩn hóa, mức độ phổ biến thực tế được đánh giá ở mức 6.5 (Medium) hoặc cao tùy môi trường, do việc khai thác thành công đòi hỏi phải vượt qua các cơ chế bảo vệ bộ nhớ hiện đại của hệ điều hành.
- Đặc điểm tấn công: Tiến trình sshd ban đầu xử lý kết nối chưa xác thực nằm trong một vùng sandbox bị cô lập và không có đặc quyền cao (unprivileged), khiến việc khai thác trực tiếp để chiếm quyền hoàn toàn bị hạn chế và có độ phức tạp cao.

3. Consequences (Hậu quả)

Khi bị khai thác thành công, lỗ hổng này có thể dẫn đến:

- Từ chối dịch vụ (Denial of Service - DoS): Làm hỏng cấu trúc bộ nhớ heap (*heap corruption*), khiến tiến trình sshd xử lý kết nối bị crash hoặc khởi động lại liên tục.
- Thực thi mã lệnh từ xa (Remote Code Execution - RCE): Về mặt lý thuyết, việc thao túng lỗi double-free có thể giúp kẻ tấn công điều hướng vùng nhớ thực thi của chương trình. Tuy nhiên, việc này rất khó thực hiện trên thực tế do các cơ chế bảo vệ bộ nhớ hiện đại (như ASLR, safe allocators).

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Nâng cấp phần mềm OpenSSH lên phiên bản 9.2 hoặc các phiên bản cao hơn (nơi lỗi xử lý bộ nhớ đã được vá hoàn toàn). Các hệ điều hành hoặc bản phân phối sử dụng OpenSSH 9.1 (như một số nhánh của OpenBSD 7.2, Fedora 37/38...) cần áp dụng bản cập nhật từ nhà phát triển.
- Giải pháp tạm thời / Phòng ngừa bổ sung:
 - Giới hạn quyền truy cập mạng đến cổng SSH (Port 22), chỉ cho phép các dải IP nội bộ hoặc đáng tin cậy kết nối thông qua tường lửa.
 - Sử dụng hệ thống phòng thủ biên, bastion host (máy chủ trung gian) để giảm thiểu việc phơi bày dịch vụ SSH trực tiếp ra Internet công cộng.

- Đánh giá của sinh viên: AI đang đánh giá quá mức về severity khi cho CVSS tới 9.8 Critical và mô tả là tùy thuộc vào tổ chức. Trong khi nguồn chính thức NVD chỉ đánh giá 6.5 Medium. Đây có khả năng là ảo giác AI vì đã đánh giá mức độ nghiêm trọng không phù hợp.

8. CVE-2023-4863

- Link: <https://nvd.nist.gov/vuln/detail/cve-2023-4863?>

- Description: Lỗi tràn bộ đệm heap trong thư viện libwebp của Google Chrome trước phiên bản 116.0.5845.187 và libwebp 1.3.2 cho phép kẻ tấn công từ xa thực hiện ghi dữ liệu vượt quá giới hạn bộ nhớ thông qua một trang HTML được tạo sẵn. (Mức độ nghiêm trọng bảo mật của Chromium: Nghiêm trọng)

- Severity: 8.8 High CVSS

- Sequence: Kẻ tấn công từ xa thực hiện ghi dữ liệu vượt quá giới hạn bộ nhớ thông qua một trang HTML được tạo sẵn.

- Solution: Cập nhật Google Chrome lên phiên bản 116.0.5845.187 hoặc mới hơn và cập nhật thư viện libwebp lên 1.3.2 hoặc mới hơn. Kiểm tra và cập nhật các phần mềm sử dụng libwebp vì CVE-2023-4863 đã được khai thác thực tế.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2023-4863 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2023-4863 là một lỗ hổng bảo mật rất nổi tiếng liên quan đến thư viện mã nguồn mở chuyên xử lý ảnh WebP (libwebp), ảnh hưởng trực tiếp đến trình duyệt Google Chrome và hàng loạt ứng dụng sử dụng framework Chromium hoặc các phần mềm đồ họa khác trên toàn cầu.

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Heap-Based Buffer Overflow (Tràn bộ đệm vùng nhớ heap).
- Cơ chế: Lỗi xuất hiện trong cách libwebp xử lý dữ liệu nén ảnh không mất dữ liệu (lossless compression), cụ thể là trong quá trình phân tích cú pháp bảng mã Huffman cho kênh alpha. Khi một tệp ảnh WebP độc hại được tạo ra với cấu trúc tinh chỉnh sẵn, việc giải mã sẽ ghi dữ liệu vượt quá giới hạn vùng nhớ đã cấp phát động (heap).
- Điểm đáng chú ý: Kẻ tấn công có thể khai thác lỗ hổng này từ xa bằng cách lừa người dùng truy cập vào một trang web độc hại chứa tệp ảnh WebP dàn dựng sẵn (crafted HTML/image page).

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 8.8 / 10.0 (Mức High - Cao, tuy nhiên do tính chất lan rộng và khả năng kết hợp tấn công Zero-day, nó từng được các hãng công nghệ đánh giá mức độ nguy hiểm ngang hàng mức Critical).
- Đặc điểm tấn công: Yêu cầu nạn nhân tương tác (mở trang web hoặc tệp ảnh chứa mã độc), nhưng diễn ra hoàn toàn tự động trong nền trình duyệt. Lỗ hổng này từng bị lợi dụng làm zero-day trên thực tế (*In-the-wild*) trong các chiến dịch tấn công spyware tinh vi (như chuỗi khai thác BLASTPASS nhắm vào thiết bị Apple) trước khi được vá khẩn cấp.

3. Consequences (Hậu quả)

Khi bị khai thác thành công, lỗ hổng có thể dẫn đến:

- Từ chối dịch vụ (Denial of Service - DoS): Làm sập ứng dụng/trình duyệt đang đọc tệp ảnh.
- **Thực thi mã lệnh tùy ý (Remote Code Execution - RCE):** Kẻ tấn công có thể vượt qua ranh giới bộ nhớ để chạy mã lệnh tùy ý trên hệ thống của người dùng (trong môi trường có bảo vệ sandbox, mức độ ảnh hưởng có thể bị giới hạn tùy thuộc vào ứng dụng tích hợp).

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật phiên bản mới nhất cho các phần mềm sử dụng thư viện libwebp:
 - Đối với Google Chrome: Nâng cấp lên phiên bản 116.0.5845.187 hoặc cao hơn.
 - Đối với các ứng dụng, trình duyệt dựa trên Chromium (Edge, Brave, Firefox, Opera...) hoặc các thư viện lập trình có sử dụng libwebp: Nâng cấp libwebp lên phiên bản 1.3.2 trở lên.

- Đánh giá của sinh viên: AI đang bị ảo giác vì cho rằng khi khai thác thành công sẽ dẫn đến khả năng thực thi mã lệnh tùy ý (Remote Code Execution - RCE). Đây là hậu quả mà AI nghĩ ra chứ nguồn NVD chưa xác nhận kết quả này.

9. CVE-2023-22515

- Link: <https://confluence.atlassian.com/security/data-center-and-server-1295682276.html?>

- Description: Lỗ hổng kiểm soát truy cập bị phá vỡ trong Confluence Data Center và Server

- Severity: CVSS 10 (Critical)

- Consequence:

Atlassian đã nhận được thông tin về một vấn đề được một số khách hàng báo cáo, trong đó tin tặc bên ngoài có thể đã khai thác một lỗ hổng chưa được biết đến trước đây trong các phiên bản Confluence Data Center và Server có thể truy cập công khai để tạo các tài khoản quản trị viên Confluence trái phép và truy cập vào các phiên bản Confluence.

- Solution:

+ Atlassian khuyến nghị bạn nên nâng cấp từng cài đặt bị ảnh hưởng lên một trong các phiên bản đã được sửa lỗi (hoặc bất kỳ phiên bản nào mới hơn) được liệt kê bên dưới.

Sản phẩm	Phiên bản đã sửa lỗi
Confluence Data Center và Confluence Server	• 8.3.3 trở lên
	• 8.3 trở lên
	• 8.5.2 (Phiên bản hỗ trợ dài hạn) trở lên

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2023-22515 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2023-22515 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng trực tiếp đến các phiên bản Atlassian Confluence Server và Data Center.

1. Description (Mô tả)

- Bản chất: Đây là lỗi Broken Access Control (Kiểm soát truy cập bị hỏng), cho phép vượt qua cơ chế xác thực để thao túng cấu hình ứng dụng.
- Cơ chế: Do cách Confluence xử lý các tham số yêu cầu HTTP, kẻ tấn công có thể gửi các request được tinh chỉnh đặc biệt đến endpoint công

khai (như server-info.action) để ép hệ thống hiểu nhầm rằng tiến trình cài đặt ban đầu chưa hoàn tất (setupComplete=false). Thao tác này lừa ứng dụng mở lại trang thiết lập hệ thống từ đầu, cho phép bất kỳ ai cũng có thể tự tạo một tài khoản quản trị mới.

- Điểm đáng chú ý: Lỗ hổng hoàn toàn không cần xác thực (unauthenticated) và không yêu cầu quyền hạn trước đó. Kẻ tấn công chỉ cần kết nối mạng tới máy chủ Confluence là có thể khai thác.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 10.0 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng - mức tối đa theo thang đo CVSS).
- Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng. Lỗ hổng này từng bị khai thác dạng zero-day rộng rãi trên thực tế bởi các nhóm tấn công mạng trước khi Atlassian phát hành bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA.

3. Consequences (Hậu quả)

Khi bị khai thác thành công, lỗ hổng mang lại hậu quả nặng nề:

- Leo thang đặc quyền trái phép: Kẻ tấn công tự tạo được tài khoản với quyền Administrator tối cao trên hệ thống Confluence.
- **Kiểm soát toàn bộ dữ liệu:** Dễ dàng truy cập, đánh cắp, sửa đổi toàn bộ tài liệu, thông tin nội bộ doanh nghiệp lưu trữ trong không gian làm việc của Confluence.
- **Bàn đạp tấn công sâu hơn (Lateral Movement):** Kẻ xấu có thể cài cắm mã độc, plug-in độc hại hoặc dùng quyền quản trị này để mở rộng phạm vi xâm nhập sang các hệ thống nội bộ khác kết nối với máy chủ Confluence.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Nâng cấp/cập nhật phiên bản Confluence Server và Data Center lên các phiên bản đã được vá lỗi từ hãng (từ các phiên bản 8.3.3, 8.4.3, 8.5.2 trở lên hoặc các bản LTS mới hơn).

- Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay):
 - Cô lập máy chủ, chặn hoàn toàn quyền truy cập mạng từ bên ngoài (Internet) vào ứng dụng Confluence, chỉ cho phép truy cập nội bộ.
 - Kiểm tra kỹ hệ thống (nhật ký truy cập - logs) để tìm kiếm các tài khoản quản trị lạ hoặc dấu hiệu bất thường nhằm rà soát xem hệ thống đã từng bị xâm nhập hay chưa.

- Đánh giá của sinh viên: AI đang bị ảo giác vì mô tả attacker có thể “kiểm soát toàn bộ dữ liệu”, “cài cắm mã độc, plug-in độc hại” và thực hiện “lateral movement”. Các hành động này có thể xảy ra sau khi attacker đã có quyền Administrator chứ chưa phải là tác động trực tiếp của CVE này. Và cũng chưa chắc đúng hết nếu mỗi lần khai thác đều dẫn đến kết quả mà AI đã liệt kê trên.

10. CVE-2023-6345

- Link: <https://nvd.nist.gov/vuln/detail/cve-2023-6345?>

- Description: Lỗi tràn số nguyên trong Skia trên Google Chrome phiên bản trước 119.0.6045.199 cho phép kẻ tấn công từ xa, kẻ đã xâm nhập vào tiến trình hiển thị, có khả năng thực hiện thoát khỏi môi trường sandbox thông qua một tập tin độc hại. (Mức độ nghiêm trọng bảo mật của Chromium: Cao)

- Severity: 9.6 Critical CVSS

- Sequence: kẻ đã xâm nhập vào tiến trình hiển thị, có khả năng thực hiện thoát khỏi môi trường sandbox thông qua một tập tin độc hại.

- Solution: Cập nhật Google Chrome lên phiên bản 119.0.6045.199 hoặc cao hơn

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2023-6345 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2023-6345 là một lỗ hổng bảo mật nghiêm trọng liên quan đến thư viện đồ họa mã nguồn mở Skia, được sử dụng rộng rãi làm công cụ dựng hình (graphics engine) trong Google Chrome, hệ điều hành ChromeOS, Android và nhiều ứng dụng dựa trên nền tảng Chromium khác.

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Integer Overflow (Tràn số nguyên) được định danh theo CWE-190, xảy ra trong thư viện đồ họa Skia (cụ thể tại hàm xử lý lưới MeshOp::onCombineIfPossible).
- Cơ chế: Khi trình duyệt xử lý dữ liệu hình ảnh hoặc cấu trúc đồ họa phức tạp (đặc biệt là tệp đồ họa chứa các thao tác vẽ đa giác/đỉnh), các phép tính toán kích thước bộ nhớ bị tràn số nguyên, dẫn đến việc hệ thống cấp phát một vùng nhớ heap quá nhỏ so với thực tế. Khi dữ liệu thực tế được ghi đè vào, nó gây ra hiện tượng ghi tràn bộ đệm (Heap Out-of-Bounds Write).
- Điểm đáng chú ý: Kẻ tấn công thường lợi dụng lỗ hổng này như một bước đệm Sandbox Escape (Thoát khỏi vùng cách ly sandbox của trình duyệt) sau khi đã xâm nhập thành công vào tiến trình dựng hình (renderer process) bằng một lỗ hổng khác.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.6 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Yêu cầu người dùng tương tác (như truy cập vào một trang web độc hại hoặc mở tệp đồ họa/hình ảnh được thiết kế sẵn). Lỗ hổng này từng bị khai thác dạng zero-day rộng rãi trên thực tế (*In-the-wild*) trước khi được vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (*Known Exploited Vulnerabilities Catalog*).

3. Consequences (Hậu quả)

Khi bị khai thác thành công (thường nằm trong một chuỗi tấn công phức tạp - exploit chain), kẻ tấn công có thể:

- Thoát khỏi Sandbox của trình duyệt: Vượt qua hàng rào bảo vệ cô lập tiến trình của Chrome để tiếp cận sâu hơn vào hệ thống bên dưới.
- **Thực thi mã lệnh tùy ý (RCE)**: Chạy mã lệnh độc hại trực tiếp trên hệ điều hành của người dùng dưới quyền hạn của tiến trình ứng dụng.
- **Kiểm soát thiết bị**: Tạo cơ hội cho kẻ xấu cài cắm phần mềm độc hại, phần mềm gián điệp (spyware) hoặc đánh cắp dữ liệu cá nhân nhạy cảm.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật ngay lập tức phần mềm duyệt web lên phiên bản đã được vá lỗi từ nhà phát triển:
 - Đối với Google Chrome: Nâng cấp lên phiên bản 119.0.6045.199 (hoặc các bản phát hành mới hơn trên kênh Stable).
 - Đối với các trình duyệt nhân Chromium khác (như Microsoft Edge, Brave, Opera...) hoặc các ứng dụng tích hợp sẵn thư viện Skia: Áp dụng bản cập nhật bảo mật mới nhất từ nhà cung cấp tương ứng.
- Giải pháp phòng ngừa:
 - Luôn bật tính năng tự động cập nhật (Auto-update) cho trình duyệt để đảm bảo các bản vá lỗi hỏng bảo mật quan trọng được áp dụng kịp thời.

- Đánh giá của sinh viên: AI đang có dấu hiệu ảo giác vì RCE và kiểm soát thiết bị là hậu quả có thể có trong 1 chuỗi khai thác chứ chưa phải tác động trực tiếp của nguồn CVE này.

11. CVE-2024-21762

- Link: <https://nvd.nist.gov/vuln/detail/cve-2024-21762>

- Description: Lỗi hỏng ghi dữ liệu ngoài phạm vi bộ nhớ (out-of-bounds write) trong các phiên bản Fortinet FortiOS từ 7.4.0 đến 7.4.2, 7.2.0 đến 7.2.6, 7.0.0 đến 7.0.13, 6.4.0 đến 6.4.14, 6.2.0 đến 6.2.15, 6.0.0 đến 6.0.17, và các phiên bản FortiProxy từ 7.4.0 đến 7.4.2, 7.2.0 đến 7.2.8, 7.0.0 đến 7.0.14, 2.0.0 đến 2.0.13, 1.2.0 đến 1.2.13, 1.1.0 đến 1.1.6, 1.0.0 đến 1.0.7

- Severity: 9.8 Critical CVSS

- Consequence: cho phép kẻ tấn công thực thi mã hoặc lệnh trái phép thông qua các yêu cầu được tạo ra một cách có chủ đích.

- Solution:

Giải pháp tối ưu và triệt để nhất: Nâng cấp phiên bản FortiOS lên các bản vá lỗi chính thức từ hãng:

- FortiOS 7.4: Nâng cấp lên phiên bản 7.4.3 hoặc cao hơn.
- FortiOS 7.2: Nâng cấp lên phiên bản 7.2.7 hoặc cao hơn.
- FortiOS 7.0: Nâng cấp lên phiên bản 7.0.14 hoặc cao hơn.
- FortiOS 6.4 và 6.2: Nâng cấp lên phiên bản tương ứng đã vá (6.4.15, 6.2.16 hoặc mới hơn).

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-21762 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-21762 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng trực tiếp đến hệ điều hành FortiOS được sử dụng trên các thiết bị tường lửa FortiGate của hãng Fortinet.

1. Description (Mô tả)

- Bản chất: Đây là lỗi Out-of-Bounds Write (Ghi quá giới hạn vùng nhớ) trong tiến trình ssvpnd chuyên xử lý kết nối SSL VPN.
- Cơ chế: Lỗ hổng cho phép kẻ tấn công ở bên ngoài gửi các HTTP request được thiết kế đặc biệt tới thiết bị. Do thiếu cơ chế kiểm tra kích thước bộ nhớ đệm an toàn, dữ liệu ghi đè vượt quá vùng nhớ được cấp phát, từ đó thao túng cấu trúc bộ nhớ hệ thống.
- Điểm đáng chú ý: Lỗ hổng hoàn toàn không cần xác thực (unauthenticated). Kẻ tấn công không cần tài khoản hay quyền hạn hợp lệ nào trước đó mà vẫn có thể khai thác trực tiếp qua giao diện SSL VPN.

2. Severity (Mức độ nghiêm trọng)

- **Điểm CVSS:** Lên tới 9.6 / 10.0 đến 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- **Đặc điểm tấn công:** Độ phức tạp thấp, không cần tương tác người dùng, khai thác từ xa qua mạng. Lỗ hổng này từng bị ghi nhận khai thác dạng zero-day trên thực tế bởi các nhóm tấn công có tổ chức trước khi bản vá chính thức được phát hành rộng rãi, đồng thời nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA.

3. Consequences (Hậu quả)

Vì thiết bị tường lửa FortiGate đóng vai trò là "cổng gác biên" kiểm soát toàn bộ lưu lượng ra vào mạng của doanh nghiệp, hậu quả khi bị chiếm đoạt là vô cùng tàn khốc:

- **Remote Code Execution (RCE):** Thực thi mã lệnh hoặc lệnh hệ điều hành tùy ý với đặc quyền cao nhất (root) trên thiết bị.
- **Kiểm soát hoàn toàn thiết bị:** Kẻ tấn công có thể thay đổi cấu hình, chặn hoặc chuyển hướng lưu lượng mạng, vô hiệu hóa tính năng bảo mật.
- **Bàn đạp thâm nhập nội bộ (Lateral Movement):** Từ thiết bị tường lửa bị chiếm quyền, kẻ xấu dễ dàng xâm nhập sâu vào toàn bộ hệ thống mạng nội bộ của tổ chức để triển khai mã độc tống tiền (ransomware) hoặc đánh cắp dữ liệu nhạy cảm.

4. Solution (Giải pháp khắc phục)

- **Giải pháp tối ưu và triệt để nhất:** Nâng cấp phiên bản FortiOS lên các bản vá lỗi chính thức từ hãng:
 - FortiOS 7.4: Nâng cấp lên phiên bản 7.4.3 hoặc cao hơn.
 - FortiOS 7.2: Nâng cấp lên phiên bản 7.2.7 hoặc cao hơn.
 - FortiOS 7.0: Nâng cấp lên phiên bản 7.0.14 hoặc cao hơn.
 - FortiOS 6.4 và 6.2: Nâng cấp lên phiên bản tương ứng đã vá (6.4.15, 6.2.16 hoặc mới hơn).
- **Giải pháp tạm thời (Nếu chưa thể cập nhật ngay):**

- Tạm thời vô hiệu hóa tính năng SSL VPN trên các thiết bị FortiGate để ngăn chặn hoàn toàn vectors tấn công này (dù có thể gây bất tiện cho người dùng từ xa).

- Đánh giá của sinh viên: AI đang bị ảo giác khi đánh giá chưa chính xác severity của nguồn. Ngoài ra hậu quả AI đưa ra chưa được CISA xác nhận.

12. CVE-2024-21410

- Link: <https://nvd.nist.gov/vuln/detail/cve-2024-21410>

- Description: Lỗ hổng leo thang đặc quyền trên Microsoft Exchange Server

- Severity: 9.8 Critical

- Consequence: Attacker có thể khai thác để thực hiện NTLM relay, từ đó có khả năng thực hiện các thao tác với quyền của tài khoản nạn nhân

- Solution: Cập nhật và áp dụng gói bản vá bảo mật (Security Update - SU) từ Microsoft phát hành trong chuỗi bản vá tháng 2/2024 (hoặc các Cumulative Update mới hơn) cho các phiên bản Exchange Server đang sử dụng.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-21410 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-21410 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng trực tiếp đến các hệ thống máy chủ Microsoft Exchange Server. Dưới đây là thông tin chi tiết:

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Elevation of Privilege (Leo thang đặc quyền), xuất phát từ việc xử lý không đúng cách các thông tin xác thực và thiếu cơ chế kiểm tra tính hợp lệ dữ liệu.

- Cơ chế: Lỗ hổng cho phép kẻ tấn công lợi dụng giao thức NTLM (cụ thể là thực hiện tấn công NTLM Relay) bằng cách đánh lừa máy chủ Exchange chấp nhận các thông tin xác thực bị chuyển hướng hoặc giả mạo. Thông qua việc gửi các request được tinh chỉnh đặc biệt, kẻ tấn công có thể mạo danh người dùng hợp pháp hoặc chiếm quyền hạn cao hơn trên hệ thống.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu người dùng tương tác. Lỗ hổng này từng bị ghi nhận khai thác dạng zero-day trên thực tế trước khi Microsoft phát hành bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (*Known Exploited Vulnerabilities Catalog*).

3. Consequences (Hậu quả)

Khi bị khai thác thành công, kẻ tấn công có thể:

- Leo thang đặc quyền: Đạt được quyền hạn của quản trị viên hoặc các tài khoản đặc quyền khác trên máy chủ Exchange.
- Thực thi mã lệnh từ xa (RCE) / Kiểm soát hệ thống: Kết hợp với các điểm yếu hoặc quyền hạn vừa có được để truy cập vào hộp thư người dùng, đọc dữ liệu nhạy cảm hoặc chạy mã lệnh tùy ý trên hạ tầng máy chủ.
- Bàn đạp tấn công mạng nội bộ: Chiếm quyền kiểm soát Exchange Server giúp kẻ xấu dễ dàng thực hiện các bước tấn công sâu hơn vào toàn bộ hệ thống Active Directory của doanh nghiệp.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật và áp dụng gói bản vá bảo mật (Security Update - SU) từ Microsoft phát hành trong chuỗi bản vá tháng

2/2024 (hoặc các Cumulative Update mới hơn) cho các phiên bản Exchange Server đang sử dụng.

- Giải pháp phòng ngừa bổ sung:
 - Kích hoạt Extended Protection for Authentication (EPA): Tính năng bảo vệ mở rộng này giúp ngăn chặn các cuộc tấn công NTLM Relay. EPA đã được Microsoft bật sẵn theo mặc định trên các phiên bản mới (như Exchange Server 2019 CU14), nhưng cần được cấu hình thủ công hoặc kiểm tra kỹ trên các phiên bản cũ hơn.
 - Hạn chế hoặc vô hiệu hóa việc sử dụng giao thức xác thực cũ NTLM trong mạng nội bộ, chuyển đổi sang Kerberos nếu có thể.

- Đánh giá của sinh viên: AI đang phóng đại hậu quả khi nói rằng attacker có thể trực tiếp đạt quyền Administrator, thực hiện RCE, truy cập hộp thư và kiểm soát Active Directory. Trong khi Microsoft mô tả trực tiếp là elevation of privilege thông qua NTLM relay.

13. CVE-2024-3400

- Link: <https://nvd.nist.gov/vuln/detail/cve-2024-3400?>

- Description: Lỗi hỏng chèn lệnh do tạo tập tin tùy ý trong tính năng GlobalProtect của phần mềm Palo Alto Networks PAN-OS đối với các phiên bản PAN-OS cụ thể và cấu hình tính năng khác nhau

- Severity: 10 Critical CVSS

- Consequence:

Lỗi hỏng cho phép unauthenticated attacker gửi request được tạo đặc biệt tới thiết bị PAN-OS có cấu hình GlobalProtect phù hợp, từ đó thực thi arbitrary code với quyền root trên firewall. Palo Alto Networks xác nhận lỗi hỏng đã được discovered in production use và có các cuộc tấn công khai thác lỗi hỏng.

- Lỗi hỏng áp dụng cho PAN-OS 10.2, 11.0 và 11.1 khi firewall được cấu hình GlobalProtect gateway hoặc GlobalProtect portal. Cloud NGFW, Panorama và Prisma Access không bị ảnh hưởng.

- Solution:

Các bản sửa chính gồm:

- PAN-OS 10.2 → 10.2.9-h1
- PAN-OS 11.0 → 11.0.4-h1
- PAN-OS 11.1 → 11.1.2-h3

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-3400 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-3400 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng đến hệ điều hành PAN-OS trên các thiết bị tường lửa thế hệ mới (Next-Generation Firewall) của Palo Alto Networks.

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng OS Command Injection (Tiêm mã lệnh hệ điều hành) dẫn đến khả năng tạo tệp tùy ý, được định danh theo CWE-77.
- Cơ chế: Lỗ hổng xuất hiện trong tính năng GlobalProtect (cụ thể là cấu hình GlobalProtect Gateway hoặc Portal) của PAN-OS. Kẻ tấn công từ bên ngoài có thể gửi các HTTP request được tinh chỉnh đặc biệt để đánh lừa hệ thống, cho phép thực thi các lệnh hệ điều hành tùy ý trên thiết bị.
- Điều kiện khai thác: Lỗ hổng ảnh hưởng đến các thiết bị chạy phiên bản PAN-OS 10.2, 11.0 và 11.1 có cấu hình tính năng GlobalProtect Gateway hoặc Portal.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 10.0 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng - điểm tối đa theo thang đo CVSS).

- Đặc điểm tấn công: Hoàn toàn không cần xác thực (unauthenticated), độ phức tạp thấp và không yêu cầu người dùng tương tác. Lỗi hổng này từng bị khai thác dạng zero-day trên thực tế trong các chiến dịch tấn công nhắm vào hạ tầng trọng yếu (như chiến dịch *Operation MidnightEclipse*) trước khi hãng kịp phát hành bản vá.

3. Consequences (Hậu quả)

Vì thiết bị Palo Alto Firewall đóng vai trò là "chốt chặn" bảo mật biên cốt lõi của doanh nghiệp, hậu quả khi bị chiếm đoạt là vô cùng nặng nề:

- Thực thi mã lệnh với quyền Root: Kẻ tấn công có thể chạy bất kỳ câu lệnh nào với quyền cao nhất (root) trên thiết bị.
- **Kiểm soát toàn bộ tường lửa:** Cho phép kẻ xấu thay đổi cấu hình, đánh cắp thông tin nhạy cảm, cấu hình mạng, hoặc vô hiệu hóa toàn bộ các tính năng bảo mật.
- **Bàn đạp tấn công nội bộ (Lateral Movement):** Kẻ tấn công sử dụng thiết bị tường lửa đã bị chiếm quyền làm bàn gốc để thâm nhập sâu vào toàn bộ hệ thống mạng nội bộ bên trong của tổ chức.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật ngay lập tức hệ điều hành PAN-OS lên các phiên bản đã được vá lỗi chính thức từ nhà sản xuất:
 - PAN-OS 10.2: Nâng cấp lên phiên bản 10.2.9-h1 hoặc cao hơn.
 - PAN-OS 11.0: Nâng cấp lên phiên bản 11.0.4-h1 hoặc cao hơn.
 - PAN-OS 11.1: Nâng cấp lên phiên bản 11.1.2-h3 hoặc cao hơn.
- Giải pháp phòng ngừa / Giảm thiểu tạm thời:
 - Nếu chưa thể nâng cấp ngay, khách hàng đang sử dụng gói dịch vụ Threat Prevention có thể bật các quy tắc Threat ID (như Threat ID 95187, 95189, 95191) và đảm bảo tính năng *Vulnerability Protection* đã được áp dụng trực tiếp lên giao diện GlobalProtect.
 - Rà soát hệ thống kỹ lưỡng (kiểm tra tệp hỗ trợ kỹ thuật - Tech Support File) để tìm kiếm các dấu hiệu thỏa hiệp (IoC) hoặc tệp tin

bất thường nhằm xác định thiết bị có từng bị xâm nhập trước đó hay không.

- Đánh giá của sinh viên: AI có dấu hiệu ảo giác vì AI đưa ra hậu quả trực tiếp là kiểm soát toàn bộ tường lửa và bàn đạp tấn công nội bộ (Lateral Movement). Tuy nhiên không phải mọi lần khai thác đều dẫn đến hậu quả đó. Đây nên được coi là giai đoạn hậu khai thác nên phụ thuộc vào môi trường và các bước tấn công tiếp theo

+ Link tham khảo do AI cung cấp: <https://security.paloaltonetworks.com/CVE-2024-3400?>

14. CVE-2024-4577

- Link: <https://nvd.nist.gov/vuln/detail/cve-2024-4577>

- Description: Trong các phiên bản PHP 8.1.* trước 8.1.29, 8.2.* trước 8.2.20, 8.3.* trước 8.3.8, khi sử dụng Apache và PHP-CGI trên Windows, nếu hệ thống được thiết lập để sử dụng một số bảng mã nhất định, Windows có thể sử dụng cơ chế "Best-Fit" để thay thế các ký tự trong dòng lệnh được cung cấp cho các hàm API Win32.

- Severity: 9.8 Critical CVSS

- Consequence: Mô-đun PHP CGI có thể hiểu sai các ký tự đó là các tùy chọn PHP, điều này có thể cho phép người dùng độc hại truyền các tùy chọn cho tệp nhị phân PHP đang chạy, từ đó tiết lộ mã nguồn của các tập lệnh, chạy mã PHP tùy ý trên máy chủ, v.v.

- Solution:

- Giải pháp tối ưu và triệt để nhất: Nâng cấp PHP lên các phiên bản đã được vá lỗi từ nhà phát triển:
- PHP phiên bản 8.3: Nâng cấp lên 8.3.8 hoặc mới hơn.
- PHP phiên bản 8.2: Nâng cấp lên 8.2.20 hoặc mới hơn.
- PHP phiên bản 8.1: Nâng cấp lên 8.1.29 hoặc mới hơn.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-4577 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-4577 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng trực tiếp đến ngôn ngữ lập trình PHP khi chạy trên hệ điều hành Windows (đặc biệt trong chế độ CGI hoặc khi tích hợp với máy chủ web Apache).

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Argument Injection (Tiêm tham số).
- Cơ chế: Lỗ hổng xuất phát từ một thiếu sót trong quá trình chuyển đổi bảng mã ký tự (tính năng "Best-Fit" của Windows encoding) khi PHP xử lý các tham số dòng lệnh. Trước đây, các phiên bản PHP từng có cơ chế phòng thủ để chặn các cuộc tấn công tương tự (CVE-2012-1823), nhưng kẻ tấn công có thể lợi dụng các chuỗi ký tự đặc biệt (như ký tự chuyển đổi mã hóa %AD) để vượt qua các lớp lọc này.
- Điểm đáng chú ý: Kẻ tấn công từ bên ngoài có thể gửi các HTTP request được tinh chỉnh sẵn để ép tệp thực thi php-cgi.exe nhận các đối số dòng lệnh tùy ý (ví dụ: cờ -d để cấu hình lại các tham số .ini của PHP) mà không cần xác thực (unauthenticated). Lỗ hổng này ảnh hưởng rất nặng nề đối với các gói cài đặt sẵn có cấu hình mặc định công khai thư mục CGI (như XAMPP cho Windows).

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu người dùng tương tác, thực thi từ xa qua mạng. Lỗ hổng này đã bị khai thác rộng rãi trên thực tế ngay sau khi được công bố (nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA) để phát tán mã độc tống tiền (ransomware), cài cắm web shell và botnet.

3. Consequences (Hậu quả)

Khi bị khai thác thành công, lỗ hổng mang lại những hậu quả nặng nề:

- Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình máy chủ web trên hệ thống Windows.
- **Kiểm soát hệ thống**: Kẻ tấn công có thể cài đặt web shell để duy trì quyền truy cập, đánh cắp dữ liệu nhạy cảm hoặc triển khai mã độc tổng tiền (ví dụ: nhóm ransomware *TellYouThePass*).

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Nâng cấp PHP lên các phiên bản đã được vá lỗi từ nhà phát triển:
 - PHP phiên bản 8.3: Nâng cấp lên 8.3.8 hoặc mới hơn.
 - PHP phiên bản 8.2: Nâng cấp lên 8.2.20 hoặc mới hơn.
 - PHP phiên bản 8.1: Nâng cấp lên 8.1.29 hoặc mới hơn.
 - (*Lưu ý: Các phiên bản cũ hơn như PHP 8.0, 7 và 5 đã ngừng hỗ trợ - End-of-Life, nên cần chuyển đổi sang nhánh mới hơn.*)
- Giải pháp tạm thời / Phòng ngừa bổ sung:
 - Nếu sử dụng XAMPP hoặc các môi trường phát triển trên Windows mà không cần dùng tính năng PHP-CGI, hãy cấu hình lại tệp httpd.conf của Apache để vô hiệu hóa hoặc xóa bỏ các cấu hình ánh xạ tới php-cgi.
 - Sử dụng quy tắc Rewrite của máy chủ web (như chặn các chuỗi query string độc hại chứa mã %ad) nếu chưa thể cập nhật ngay lập tức.

- Đánh giá của sinh viên: AI đang ảo giác khi trình bày web shell, đánh cắp dữ liệu và triển khai ransomware như một hậu quả trực tiếp. Không phải mỗi lần khai thác đều dẫn đến hậu quả trên. Phải dựa vào những hoạt động trong thực tế.

15. CVE-2024-3094

- Link: https://nvd.nist.gov/vuln/detail/cve-2024-3094?hss_channel=lcp-1616314

- **Description:** Mã độc đã được phát hiện trong các tập tin nén (tarball) của xz, bắt đầu từ phiên bản 5.6.0. Thông qua một loạt các thủ thuật làm xáo trộn mã phức tạp, quy trình xây dựng liblzma trích xuất một tệp đối tượng được biên dịch sẵn từ một tệp kiểm thử được ngụy trang có sẵn trong mã nguồn, sau đó được sử dụng để sửa đổi các hàm cụ thể trong mã liblzma.

- **Severity:** 10.0 Critical CVSS

- **Consequence:** Một thư viện liblzma đã được sửa đổi mà bất kỳ phần mềm nào được liên kết với thư viện này đều có thể sử dụng, chặn và sửa đổi tương tác dữ liệu với thư viện này.

- **Solution:** hạ cấp về phiên bản XZ Utils không bị ảnh hưởng, như phiên bản 5.4.6, đồng thời kiểm tra hệ thống và các gói liên quan.

- **Kiểm chứng AI Bias / Hallucination:**

+ Prompt AI: Hãy giải thích CVE-2024-3094 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-3094 là một lỗ hổng bảo mật dạng **supply-chain (cung ứng phần mềm)** cực kỳ nổi tiếng, được phát hiện có chủ ý cài cắm mã độc backdoor vào các bản phát hành của thư viện **XZ Utils** (cụ thể trên các phiên bản 5.6.0 và 5.6.1).

1. Description (Mô tả)

- **Bản chất:** Đây là lỗi **Malicious Backdoor (Cài cắm mã độc có chủ ý)** vào quá trình đóng gói và xây dựng mã nguồn (build/packaging process) của thư viện nén dữ liệu xz (liblzma).
- **Cơ chế:** Kẻ tấn công (đóng vai trò là nhà phát triển cốt lõi qua một quá trình dài tạo lòng tin) đã âm thầm đưa các tệp cấu hình bản dựng bị nhiễm mã độc vào gói mã nguồn phân phối (tarball release). Khi các nhà phân phối bản Linux build gói này, tập lệnh độc hại sẽ can thiệp vào quá trình liên kết (linking) của trình biên dịch với OpenSSH (thông qua

libsystemd), qua đó lồng ghép một đoạn mã độc chặn bắt các tiến trình xác thực SSH trước khi chúng hoàn tất.

- **Điểm đáng chú ý:** Đây là một trong những cuộc tấn công tinh vi nhất vào chuỗi cung ứng mã nguồn mở từng được phát hiện, được ví như "bom nổ chậm" suýt tàn phá hệ sinh thái Linux nếu không nhờ kỹ sư Andres Freund phát hiện ra tình cờ do lỗi tiêu thụ tài nguyên CPU.

2. Severity (Mức độ nghiêm trọng)

- **Điểm CVSS: 10.0 / 10.0** (Mức **Critical** - **Cực kỳ nghiêm trọng** - điểm tối đa theo thang đo).
- **Đặc điểm tấn công:** Kẻ tấn công có thể qua mặt toàn bộ các cơ chế xác thực thông thường bằng một khóa công khai (public key) được lồng sẵn trong backdoor. Nó cho phép thực thi mã lệnh từ xa trước khi tiến trình xác thực SSH diễn ra.

3. Consequences (Hậu quả)

Nếu hệ thống sử dụng phiên bản bị ảnh hưởng và phơi bày dịch vụ SSH trực tiếp ra ngoài:

- **Bypass xác thực (Authentication Bypass):** Kẻ tấn công có thể xâm nhập trái phép vào hệ thống từ xa mà không cần mật khẩu hay khóa SSH hợp lệ nếu biết khóa bí mật tương ứng được gài trong mã độc.
- **Kiểm soát toàn bộ hệ thống:** Do tiến trình SSH chạy với đặc quyền cao hoặc liên kết chặt chẽ với hệ thống Linux, việc chiếm được phiên đăng nhập giúp kẻ xấu nắm toàn bộ quyền kiểm soát máy chủ.

4. Solution (Giải pháp khắc phục)

- **Giải pháp tối ưu và triệt để nhất:**
 - **Hạ cấp (Downgrade) hoặc vá lỗi:** Chuyển ngay lập tức về các phiên bản XZ Utils ổn định và an toàn (như phiên bản 5.4.x trở xuống, ví dụ 5.4.6) hoặc nâng cấp lên các bản vá sau khi sự cố được khắc phục hoàn toàn.
- **Kiểm tra và phòng ngừa:**

- Kiểm tra xem hệ thống Linux của bạn có đang dùng phiên bản 5.6.0 hoặc 5.6.1 hay không (thường xuất hiện trên một số bản phân phối *rolling release* hoặc bản thử nghiệm cập nhật nhanh như Debian testing/unstable, Fedora Rawhide, openSUSE Tumbleweed).
- Các bản phân phối Linux truyền thống (như Ubuntu LTS, RHEL ổn định) thường không bị ảnh hưởng do chưa nâng cấp lên nhánh 5.6.x chứa mã độc.

- Đánh giá của sinh viên: AI có dấu hiệu ảo giác khi khẳng định kẻ tấn công có thể sử dụng một “khóa bí mật tương ứng được gài trong mã độc” để bypass xác thực SSH và trình bày việc chiếm toàn bộ hệ thống như một kết quả trực tiếp. Các nguồn kiểm tra xác nhận nguy cơ remote compromise nhưng không hề hỗ trợ cách diễn giải cụ thể về “public key/private key” như AI đã trình bày.

16. CVE-2024-48145

- Link: <https://nvd.nist.gov/vuln/detail/cve-2024-48145>

- Description: Lỗ hổng tấn công chèn mã độc vào hộp thoại trò chuyện của Netangular Technologies ChatNet AI phiên bản 1.0

- Severity: 9.1 Critical

- Consequence: Kẻ tấn công truy cập và đánh cắp tất cả dữ liệu trò chuyện trước và sau đó giữa người dùng và trợ lý AI thông qua một tin nhắn được soạn thảo sẵn.

- Solution: chưa thấy thông tin về bản vá mới nhất

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-48145 bao gồm description, severity, consequences, solution.

+ Tool: Geimini

+ AI Output:

CVE-2024-48145 là một lỗ hổng bảo mật liên quan đến ứng dụng trợ lý AI, cụ thể ảnh hưởng đến hộp thoại chat (chatbox) của Netangular Technologies ChatNet AI (phiên bản v1.0). Dưới đây là thông tin chi tiết:

1. Description (Mô tả)

- Bản chất: Đây là một lỗ hổng Prompt Injection (Tiêm câu lệnh nhắc lệnh AI).
- Cơ chế: Lỗ hổng xuất hiện trong phân xử lý giao diện chatbox của ChatNet AI phiên bản v1.0. Do thiếu cơ chế kiểm soát và phân định rõ ràng giữa lệnh hệ thống/chỉ thị của nhà phát triển với dữ liệu đầu vào do người dùng (hoặc kẻ tấn công) cung cấp, ứng dụng bị lừa thực thi các đoạn mã lệnh hướng dẫn độc hại được ngụy trang trong tin nhắn.
- Điểm đáng chú ý: Kẻ tấn công có thể gửi một thông điệp được tinh chỉnh khéo léo (crafted message) thông qua khung chat để ép trợ lý AI thực hiện các hành vi ngoài ý muốn mà không cần có quyền quản trị hay xác thực trước.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 9.1 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Khai thác từ xa qua mạng (Network Vector), độ phức tạp thấp và không đòi hỏi người dùng phải tương tác phức tạp ngoài việc tiếp nhận nội dung độc hại do kẻ tấn công điều hướng.

3. Consequences (Hậu quả)

Khi khai thác thành công lỗ hổng này, kẻ tấn công có thể:

- Rò rỉ dữ liệu người dùng (Data Exfiltration): Kẻ xấu có thể lợi dụng trợ lý AI để truy cập, đọc và trích xuất toàn bộ lịch sử trò chuyện trước đó cũng như các đoạn chat phát sinh sau đó giữa người dùng thực tế và trợ lý AI.
- Lộ lọt thông tin nhạy cảm: Nếu người dùng từng cung cấp các dữ liệu cá nhân, thông tin bí mật hoặc tài liệu nội bộ trong các phiên chat với AI, toàn bộ dữ liệu này có nguy cơ bị kẻ tấn công thu thập thông qua các lệnh chuyển hướng dữ liệu tự động.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Liên hệ với nhà cung cấp (Netangular Technologies) để cập nhật lên các phiên bản vá lỗi mới hơn của ChatNet AI (nếu có) hoặc vô hiệu hóa ứng dụng cho đến khi bản vá được phát hành.
- Giải pháp phòng ngừa:
 - Thiết lập các lớp lọc đầu vào và đầu ra (Input/Output Guardrails) cho các hệ thống chat tích hợp AI nhằm ngăn chặn các hành vi ép AI tuân theo các câu lệnh trái phép (Prompt Injection).
 - Tránh trao đổi hoặc đưa các thông tin, dữ liệu nhạy cảm của cá nhân/doanh nghiệp vào các ứng dụng chat AI bên thứ ba chưa được kiểm định mức độ bảo mật kỹ càng.

- Đánh giá của sinh viên: AI đang có những định kiến riêng mà chưa được CVE hay NVD xác nhận cụ thể vì AI cho rằng attacker có thể “ép trợ lý AI thực hiện các hành vi ngoài ý muốn”. Tuy nhiên nó cũng là 1 diễn giải hợp lý trong trường hợp xảy ra như trên.

17. CVE-2024-42478

- Link: <https://nvd.nist.gov/vuln/detail/cve-2024-42478>

- Description: llama.cpp cung cấp tính năng suy luận LLM trong C/C++. Thành viên con trỏ `data` không an toàn trong cấu trúc `rpc\_tensor` có thể gây ra việc đọc địa chỉ tùy ý.

- Severity:

+ 9.8 Critical CVSS

+ GitHub CNA đánh giá 5.3 – Medium.

- Consequence: Attacker có thể lợi dụng dữ liệu được xử lý bởi RPC server để khiến chương trình đọc dữ liệu ngoài vùng bộ nhớ dự kiến.

- Solution: Lỗi hổng này đã được khắc phục trong bản vá b3561.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-42478 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-42478 là một lỗ hổng bảo mật ảnh hưởng đến llama.cpp (thư viện chạy suy luận Large Language Model - LLM bằng C/C++).

Dưới đây là thông tin chính xác về CVE-2024-42478:

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Out-of-Bounds Read (Đọc quá giới hạn vùng nhớ) được định danh theo CWE-125.
- Cơ chế: Lỗ hổng xuất hiện trong thành phần RPC Server của llama.cpp (dùng để phân tán tác vụ suy luận LLM qua mạng). Cụ thể, con trỏ data không được kiểm soát an toàn trong cấu trúc dữ liệu rpc_tensor. Kẻ tấn công có thể tinh chỉnh các gói tin gửi đến RPC server để thao túng con trỏ này, ép hệ thống đọc dữ liệu từ các địa chỉ bộ nhớ bất kỳ mà không bị giới hạn phạm vi.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: Lên tới 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng theo đánh giá của NVD do khả năng cho phép truy cập đọc bộ nhớ từ xa không cần xác thực).
- Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng thông qua các cổng dịch vụ RPC của llama.cpp nếu dịch vụ này mở phơi bày ra ngoài mà không có cơ chế kiểm soát mạng an toàn.

3. Consequences (Hậu quả)

- Khi bị khai thác thành công, lỗ hổng có thể dẫn đến:
- Rò rỉ thông tin bộ nhớ (Arbitrary Memory Read): Kẻ tấn công có thể đọc các vùng nhớ tùy ý trên tiến trình đang chạy máy chủ RPC, qua đó có thể

trích xuất các dữ liệu nhạy cảm đang lưu trữ trong RAM (như thông tin cấu hình, dữ liệu mô hình đang xử lý, hoặc các khóa bí mật).

- Kết hợp tấn công (Chaining): Lỗi hỏng đọc bộ nhớ này có thể được kẻ xấu lợi dụng kết hợp với các lỗi khác (như lỗi ghi bộ nhớ CVE-2024-42479 đi kèm) để đạt mục tiêu thực thi mã lệnh từ xa (RCE).

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật/nâng cấp llama.cpp lên phiên bản b3561 hoặc các phiên bản mới hơn (nơi bản vá lỗi đã được tích hợp sẵn trong mã nguồn).
- Giải pháp phòng ngừa:
 - Nếu bạn đang chạy llama.cpp ở chế độ RPC Server (rpc-server), tuyệt đối không phơi bày cổng dịch vụ này trực tiếp ra Internet công cộng.
 - Sử dụng tường lửa hoặc mạng riêng ảo (VPN) để giới hạn quyền truy cập vào các node RPC nội bộ, chỉ cho phép các máy chủ tin cậy giao tiếp với nhau.

- Đánh giá của sinh viên: AI đang có dấu hiệu ảo giác khi mở rộng hậu quả sang việc đọc trực tiếp các khóa bí mật, dữ liệu mô hình và khả năng kết hợp với để đạt RCE. Ngoài ra, AI còn cung cấp thiếu thông tin đánh giá lỗi hỏng ở mức 5.3 Medium từ Github.

18. CVE-2024-5565

- Link:

+ <https://nvd.nist.gov/vuln/detail/cve-2024-5565>

+ <https://github.com/advisories/GHSA-7735-w2jp-gvg6>

- Description: Thư viện Vanna sử dụng hàm nhắc nhở để hiển thị kết quả trực quan cho người dùng. Có thể thay đổi hàm nhắc nhở bằng cách chèn hàm nhắc nhở và chạy mã Python tùy ý thay vì mã trực quan hóa dự định. Cụ thể, việc cho

phép nhập dữ liệu bên ngoài vào phương thức “ask” của thư viện với thuộc tính “visualize” được đặt thành True (hành vi mặc định) sẽ dẫn đến thực thi mã từ xa.

- Severity:

+ 8.1 High CVSS

+ GitHub đánh giá 9.2 Critical

- Consequence:

Hậu quả trực tiếp được xác nhận là:

- Attacker có thể thực hiện arbitrary Python code execution.
- Có thể dẫn tới Remote Code Execution (RCE) trên hệ thống chạy ứng dụng Vanna.
- Code độc hại có thể được thực thi thay cho code visualization dự kiến

- Solution: Hiện GitHub Advisory hiện ghi Patched versions: None tức chưa có bản vá chính thức nào cả.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-5565 bao gồm description, severity, consequences, solution.

+ Tool: Geimini

+ AI Output:

CVE-2024-5565 là một lỗ hổng bảo mật liên quan đến ứng dụng AI/Machine Learning, cụ thể ảnh hưởng đến thư viện mã nguồn mở Python Vanna.AI (một công cụ phổ biến giúp chuyển đổi ngôn ngữ tự nhiên thành câu lệnh SQL).

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Prompt Injection dẫn đến Remote Code Execution (RCE).
- Cơ chế: Trong thư viện Vanna, phương thức mặc định ask() cho phép người dùng nhập câu hỏi bằng văn bản để LLM vừa tạo mã SQL truy vấn

cơ sở dữ liệu, vừa tự động sinh mã Python (sử dụng thư viện Plotly) để trực quan hóa dữ liệu. Quá trình này sử dụng hàm `exec()` trong Python để chạy đoạn mã do AI tạo ra. Kẻ tấn công có thể chèn các câu lệnh độc hại (Prompt Injection) vào dữ liệu đầu vào hoặc cơ sở dữ liệu, lừa LLM sinh ra mã Python chứa mã độc thay vì mã vẽ biểu đồ thông thường.

- Điểm đáng chú ý: Tính năng trực quan hóa (`visualize=True`) được bật sẵn theo mặc định trong thư viện, tạo ra điểm yếu trực tiếp cho phép biến các cuộc tấn công tiêm nhiễm câu lệnh ngôn ngữ tự nhiên thành các hành vi thực thi mã lệnh trên máy chủ.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: Đạt mức 8.1 đến 9.2 / 10.0 (Thuộc nhóm High đến Critical — Cao đến Cực kỳ nghiêm trọng) tùy theo hệ thống đánh giá.
- Đặc điểm tấn công: Kẻ tấn công từ bên ngoài có thể khai thác thông qua các luồng dữ liệu đầu vào không được kiểm soát mà không cần đặc quyền phức tạp, biến lỗi logic của AI thành nguy cơ kiểm soát hệ thống.

3. Consequences (Hậu quả)

Khi khai thác thành công lỗ hổng này, kẻ tấn công có thể:

- Thực thi mã lệnh từ xa (RCE): Chạy bất kỳ đoạn mã Python hoặc lệnh hệ điều hành nào dưới quyền hạn của tiến trình đang vận hành ứng dụng Vanna (thường là quyền của máy chủ backend).
- Chiếm đoạt hệ thống: Đánh cắp dữ liệu nhạy cảm từ cơ sở dữ liệu, chỉnh sửa hệ thống, hoặc làm tê liệt toàn bộ hoạt động của ứng dụng tích hợp AI.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: **Cập nhật thư viện vanna lên các phiên bản mới hơn đã được vá lỗi từ nhà phát triển** (vô hiệu hóa việc thực thi trực tiếp mã không an toàn hoặc áp dụng các cơ chế kiểm duyệt đầu ra của LLM).
- Giải pháp phòng ngừa tạm thời:

- Vô hiệu hóa tham số trực quan hóa (visualize=False) trong phương thức ask() nếu không thực sự bắt buộc phải sử dụng tính năng sinh mã Plotly tự động.
- Triển khai các lớp lọc đầu vào/đầu ra (Guardrails) nghiêm ngặt để kiểm tra mã Python trước khi chuyển vào hàm exec(), hoặc chạy ứng dụng trong môi trường cô lập (Sandbox/Container) để giới hạn thiệt hại nếu xảy ra sự cố thực thi mã độc.

- Đánh giá của sinh viên: AI đang ảo giác khi cho rằng Vanna đã có phiên bản mới hơn đã được vá lỗi. Trong khi hiện tại chưa xác định được có bản vá chính thức nào cả.

19. CVE-2024-5131

- Link: <https://nvd.nist.gov/vuln/detail/cve-2024-5131>

- Description:

Lỗi hồng Kiểm soát truy cập không đúng cách tồn tại trong kho lưu trữ lunary-ai/lunary, ảnh hưởng đến các phiên bản đến và bao gồm 1.2.2.

- Severity: 6.5 Medium CVSS

- Consequence:

Lỗi hồng này cho phép người dùng trái phép xem bất kỳ lời nhắc nào trong bất kỳ dự án nào bằng cách cung cấp ID lời nhắc cụ thể cho một điểm cuối không xác minh đầy đủ quyền sở hữu ID lời nhắc đó.

- Solution: Vấn đề này đã được khắc phục trong phiên bản 1.2.25.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-5131 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-5131 là một lỗ hổng bảo mật ảnh hưởng đến Lunary (lunary-ai/lunary), một nền tảng mã nguồn mở chuyên quản lý và giám sát các ứng dụng LLM/AI.

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng Improper Access Control / Authorization Bypass Through User-Controlled Key (Lỗi kiểm soát truy cập không đúng cách / Bỏ qua phân quyền thông qua khóa do người dùng kiểm soát), được định danh theo CWE-639.
- Cơ chế: Lỗ hổng tồn tại trong cách các endpoint của Lunary xử lý việc truy xuất dữ liệu prompt. Khi người dùng gửi một yêu cầu HTTP kèm theo một prompt ID cụ thể, hệ thống đã thiếu cơ chế kiểm tra quyền sở hữu (ownership validation) xem tài khoản hiện tại có thực sự thuộc về dự án chứa prompt đó hay không.
- Điểm đáng chú ý: Bất kỳ người dùng nào có tài khoản thông thường (thậm chí có quyền hạn thấp) đều có thể lợi dụng điểm yếu này để đọc dữ liệu chéo giữa các dự án khác nhau.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: 6.5 / 10.0 (Mức Medium - Trung bình theo đánh giá chuẩn, tác động bảo mật tập trung vào tính bảo mật dữ liệu).
- Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng (Network Vector) với độ phức tạp thấp, không cần tương tác phức tạp từ người dùng khác ngoài việc có một tài khoản hợp lệ để gọi API hoặc truy cập endpoint bị lỗi.

3. Consequences (Hậu quả)

Khi bị khai thác thành công, lỗ hổng có thể gây ra:

- Rò rỉ dữ liệu nhạy cảm (Data Exposure): Kẻ tấn công có thể xem trái phép toàn bộ các câu lệnh nhắc lệnh (prompts) của bất kỳ dự án nào khác trên hệ thống mà họ không có quyền quản lý hay tham gia.

- **Lộ lọt thông tin chiến lược AI:** Các prompt template có thể chứa logic nghiệp vụ độc quyền, system instructions quan trọng hoặc dữ liệu cấu hình ứng dụng AI của các tổ chức khác dùng chung hệ thống, gây ảnh hưởng nghiêm trọng đến tính bảo mật thông tin.

4. Solution (Giải pháp khắc phục)

- Giải pháp tối ưu và triệt để nhất: Cập nhật/nâng cấp nền tảng Lunary lên phiên bản 1.2.25 hoặc các phiên bản cao hơn (nơi nhà phát triển đã vá lỗi kiểm tra quyền sở hữu đối với các endpoint prompt).
- Giải pháp phòng ngừa tạm thời:
 - Hạn chế quyền truy cập mạng công khai vào các instance Lunary tự triển khai (self-hosted) nếu chưa được cập nhật bản vá.
 - Giám sát chặt chẽ nhật ký truy cập API (Access Logs) để phát hiện các hành vi dò quét ID bất thường nhằm truy vấn dữ liệu trái phép.

- Đánh giá của sinh viên: AI đang mở rộng hậu quả vì chưa chắc prompt nào cũng chứa các logic nghiệp vụ hoặc dữ liệu nhạy cảm.

20. CVE-2024-8309

- Link:

+ <https://nvd.nist.gov/vuln/detail/cve-2024-8309>

+ <https://github.com/advisories/GHSA-45pg-36p6-83v9>

- Description: Lỗi hỏng trong lớp GraphCypherQACChain của langchain-ai/langchain phiên bản 0.2.5 cho phép tấn công SQL injection thông qua prompt injection. Lỗi hỏng này có thể dẫn đến thao tác dữ liệu trái phép, đánh cắp dữ liệu, tấn công từ chối dịch vụ (DoS) bằng cách xóa toàn bộ dữ liệu, vi phạm an ninh môi trường đa người dùng và các vấn đề về tính toàn vẹn dữ liệu. Kẻ tấn công có thể tạo, cập nhật hoặc xóa các nút và mối quan hệ mà không cần ủy quyền thích hợp, trích xuất dữ liệu nhạy cảm, làm gián đoạn dịch vụ, truy cập dữ liệu trên các người dùng khác nhau và làm tổn hại tính toàn vẹn của cơ sở dữ liệu.

- Severity:

+ 9.8 Critical CVSS

+ Hiện tại Github đánh giá 2.1 /10

- Consequence:

Lỗ hổng này cho phép người dùng trái phép xem bất kỳ lời nhắc nào trong bất kỳ dự án nào bằng cách cung cấp ID lời nhắc cụ thể cho một điểm cuối không xác minh đầy đủ quyền sở hữu ID lời nhắc đó.

- Solution: Đã có bản vá chính thức trong Github bao gồm: 0.2.0 và 0.2.

- Kiểm chứng AI Bias / Hallucination:

+ Prompt AI: Hãy giải thích CVE-2024-8309 bao gồm description, severity, consequences, solution.

+ Tool: Gemini

+ AI Output:

CVE-2024-8309 thực tế là một lỗ hổng bảo mật liên quan đến khung phát triển ứng dụng AI LangChain (cụ thể là gói langchain-community).

Dưới đây là thông tin chính xác về CVE-2024-8309:

1. Description (Mô tả)

- Bản chất: Đây là lỗ hổng SQL Injection (hoặc Cypher Injection) thông qua Prompt Injection.
- Cơ chế: Lỗ hổng xuất hiện trong thành phần GraphCypherQACHain của LangChain (dùng để kết nối LLM với các cơ sở dữ liệu đồ thị như Neo4j). Do thiếu cơ chế kiểm soát đầu vào và lọc dữ liệu đầu ra từ mô hình, kẻ tấn công có thể chèn các câu lệnh nhắc lệnh độc hại (Prompt Injection) vào luồng chat. LLM sẽ bị lừa tạo ra các câu lệnh truy vấn cơ sở dữ liệu (ví dụ: Cypher queries) mang tính phá hoại hoặc độc hại, và hệ thống sẽ thực thi trực tiếp các câu lệnh này ở backend mà không qua kiểm duyệt.

2. Severity (Mức độ nghiêm trọng)

- Điểm CVSS: Lên tới 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng).
- Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng thông qua giao diện ứng dụng AI mà không cần có đặc quyền hay xác thực từ trước.

3. Consequences (Hậu quả)

Khi bị khai thác thành công, lỗ hổng có thể dẫn đến:

- Thao túng hoặc xóa dữ liệu (Data Deletion/Manipulation): Kẻ tấn công có thể ép LLM tạo ra các câu lệnh xóa toàn bộ các node, mối quan hệ hoặc dữ liệu trong cơ sở dữ liệu (gây từ chối dịch vụ - DoS).
- Trích xuất dữ liệu trái phép (Data Exfiltration): Đọc lên các thông tin nhạy cảm lưu trữ trong cơ sở dữ liệu thông qua các truy vấn chéo.
- Vi phạm bảo mật đa đối tượng (Multi-tenant Breaches): Cho phép truy cập trái phép vào dữ liệu của các tenant/người dùng khác trong cùng một hệ thống kết nối.

4. Solution (Giải pháp khắc phục)

Giải pháp tối ưu và triệt để nhất: Cập nhật thư viện langchain-community lên phiên bản 0.2.19, 0.3.0 hoặc các phiên bản mới hơn.

- *Lưu ý về bản vá:* Từ phiên bản vá lỗi, LangChain đã bổ sung tham số bắt buộc `allow_dangerous_requests=True` khi khởi tạo `GraphCypherQAChain` nhằm buộc các nhà phát triển phải ý thức rõ rủi ro khi cho phép LLM tự động sinh câu lệnh chạy trực tiếp xuống cơ sở dữ liệu.

Giải pháp phòng ngừa:

- Thực hiện kiểm tra, xác thực và làm sạch nghiêm ngặt mọi dữ liệu đầu vào từ người dùng cũng như các câu lệnh do LLM sinh ra trước khi truyền xuống tầng cơ sở dữ liệu thực thi.

- Đánh giá của sinh viên: AI khẳng định bản vá bổ sung tham số `allow_dangerous_requests=True`, nhưng thông tin này không được thể hiện trong mô tả CVE/GitHub Advisory. Điều này chưa được xác thực nên rất có thể AI đã đưa thông tin sai lệch.

III. Requirement 3 – Test cases for ONE physical product

- Device: Quạt điện
- + Brand: Công ty TNHH Tân Tiến Senko
- + Model: B1216
- + Year: 2015
- + Serial number: TCVN xxxx : 2015



- Ảnh chụp màn hình AI tạo ra 15 test case, trong đó không có 3 Edge case:

Tổng hợp 15 test case		
TC	Nội dung kiểm thử	Video
TC01	Bật quạt	★
TC02	Tắt quạt	
TC03	Các mức tốc độ	★
TC04	Quay trái/phải	★
TC05	Tắt chế độ quay	
TC06	Điều chỉnh góc nghiêng	
TC07	Độ ổn định chân đế	★
TC08	Tiếng ồn	★
TC09	Lồng quạt	
TC10	Cánh quạt	
TC11	Dây nguồn	
TC12	Nút điều khiển	
TC13	Bật/tắt liên tục	
TC14	Hoạt động liên tục	★
TC15	Kết hợp nhiều chức năng	

- Em đã bỏ 3 TC của AI để thay thế 3 Edge Case bao gồm:

+ TC10 - Cánh quạt

+ TC11 - Dây nguồn

+ TC12- Nút điều khiển

- Lý do AI đã bỏ sót 3 Edge Case 13, 14, 15:

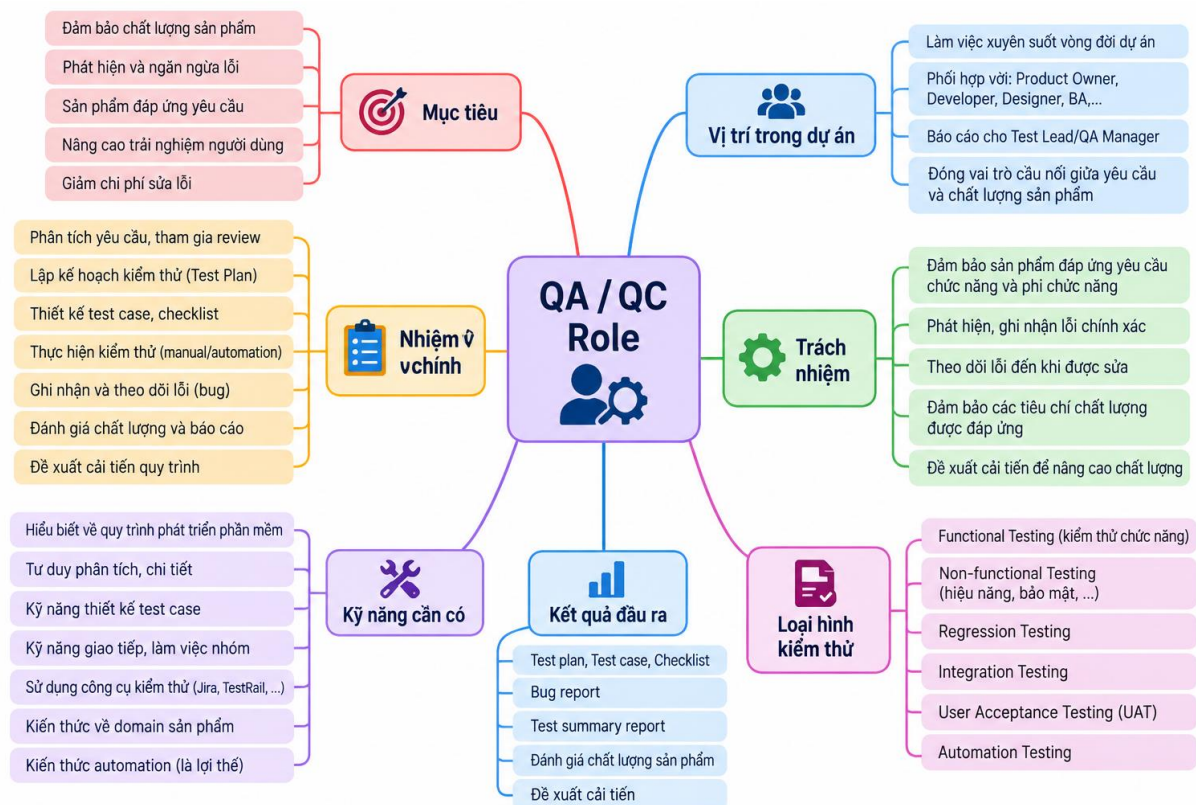
+ AI bỏ sót TC13 - Cố định đầu quạt khi quạt đang quay bởi vì AI chỉ tập trung đưa ra những TC kiểm tra chức năng cơ bản của quạt. Do đó mà AI đã bỏ qua những trường hợp thực tế khi người dùng tác động vào quạt.

+ AI bỏ sót TC 14 - Nhấn cả 3 nút mức tốc độ cùng một lúc vì AI chưa có những trải nghiệm thực tế của người dùng nên là không nghĩ ra được trường hợp người dùng có thể nhấn một lúc nhiều nút, AI chỉ tập trung vào những TC chức năng chính của quạt.

+ AI bỏ sót TC 15 - Quạt đang hoạt động thì bị mất điện vì AI thường làm theo tuần tự là tắt quạt sẽ tắt bằng nút chứ không trải nghiệm thực tế như người dùng khi mất điện hay rút dây cắm điện thì quạt cũng sẽ tự tắt.

IV. QA/ QC Role Mindmap

- Prompt: AI Tool draws a QA/QC role mindmap
- Tool: ChatGPT Pro
- AI output:



- Ba lỗi AI vẽ chưa đúng:

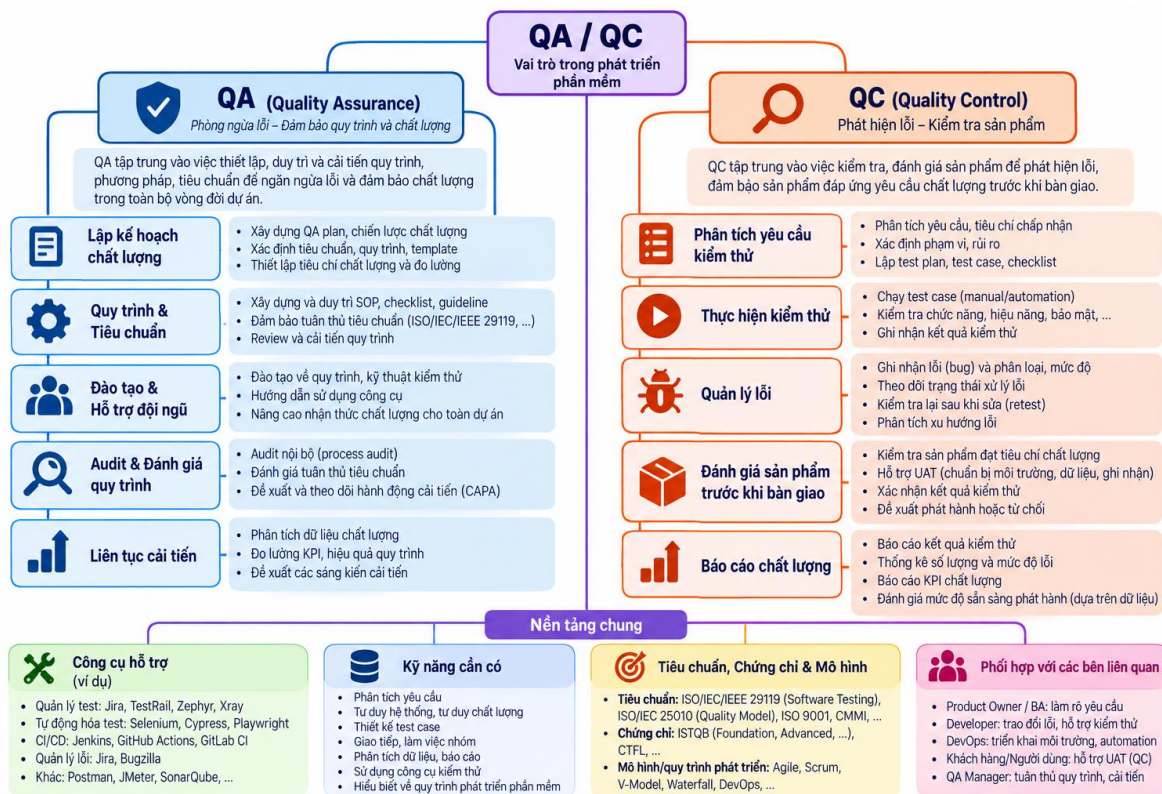
1. AI đang không phân biệt rõ 2 role, những nhiệm vụ như ghi nhận và theo dõi bug ,test plan,... chủ yếu là hoạt động của QC nhưng nó là ở bên nhánh nhiệm vụ chính QA. AI đang trộn cả 2 vai trò thành 1.

2. Phần Loại hình kiểm thử đang bị trộn lẫn nhiều cấp độ như:

- Functional và Non-functional là test type
- Regression là mục đích kiểm thử
- Integration là **test level**

3. UAT thường được thực hiện ở mức acceptance nhưng nó lại bị xếp như 1 loại testing ngang với Functional Testing.

- Sửa lại:



IV. AI Audit Report

(1) Prompt + Tool	(2) AI Output	(3) Verdict	(4) Reasoning (ISTQB)	(5) Student Fix
Tool: ChatGPT Time: 20:50 21/09/2026 Prompt: Find 10 QA/QC job postings PUBLISHED WITHIN 60 DAYS of the submission date. Mandatory: ≥ 3 positions REQUIRING AI/LLM/automation-AI skills. Each posting: link, dated screenshot, job description, required skills, salary.		INCOMPLETE	AI đã tạo ra danh sách 10 vị	Yêu cầu AI xử lý lại và cung cấp đầy đủ thôn

		trí nh ưn g kh ôn g cu ng cấ p đầ y đủ Sa lar y và lin k we b th eo yê u cầ u củ a pr o m pt. IS T Q B có tiê u chí Co m ple te ne ss. Vì th ế, ou tp	g tin tôi cần
--	--	---	---------------------

			ut nà y ch ư a c u n g c ấ p đ ủ y ê u c ầ u	
Artifact #2 Prompt: Mở rộng tìm thêm trong topcv, indeed,... lọc ra những bài phải có đầy đủ dated, job description, required skills, salary. Tool: ChatGPT Timestamp: 21:05 PM 21/09/2026		IN C O M P L E T E	AI đ ã t ạ o đ a n h s á ch 1 0 v ị tr í đ ã c u n g c ấ p đ ủ y ê u c ầ u c ủ a p r o m p t. T u y n h i ên , l ại t h i ê u	Kiểm tra l ại t ừ n g j o b p o s t i n g g o c q u a l i n k w e b A I đ ã c u n g c ấ p. N g o à i r a , b ổ s u n g t h ê m 1 v ị tr í m à A I c u n g c ấ p t h i ê u .

			đi 1 vị trí AI/ LL M/ au to m a. IS T Q B có tiê u chí Co m ple te ne ss. Vi th ế, ou tp ut nà y vẫ n ch ưa ho àn chỉ nh	
Artifact #3 Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.linkedin.com/jobs/view/senior-qa-engineer-ai-augmented-quality-engineering-4466589603/ Tool: ChatGPT Timestamp: 21:45 PM 21/09/2026	Bạn có thể ghi phần AI Impact Analysis cho job này như sau: AI Impact Analysis: AI can significantly assist this QA role by generating test cases, edge cases, and test data, analyzing failure logs, and automating	V A LI D	AI đã cu ng cấ p AI Im pa ct An	Kiểm tra các mô tả công việc, yêu cầu công việc

	API tests through tools such as GPT, Claude, and Postbot. However, human QA engineers are still needed to validate AI-generated results, define appropriate test strategies, assess risks, and make final quality decisions. Job này đặc biệt phù hợp với yêu cầu AI của bài vì JD ghi rõ GPT/Claude, AI-driven testing tools (Mabl, Testim), visual AI testing (Applitools/Percy), và Postbot là các kỹ năng AI liên quan; mức lương được công bố là 30–40 triệu VND gross/tháng. Nếu muốn đúng kiểu 1–2 câu ngắn gọn để bỏ thẳng vào report, dùng đoạn đầu là được.		aly sis đủ ng th eo yê u cầ u củ a pr o m pt. IS TQ B đề cậ p để n việ c lự a ch ọn và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi	ở trang web gốc. Dựa vào nhữn g ý mà AI đưa ra tính chổn h rồi đưa vào báo cáo:
--	--	--	--	---

			ện hi ệu qu ả và hi ệu su ất.	
Artifact #4 Promp: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.topcv.vn/viec-lam/test-engineer-product-ai-native/2284179.html Tool: ChatGPT Timestamp: 21:52 PM 21/09/2026	AI Impact Analysis: AI có thể hỗ trợ đáng kể cho vị trí QA này bằng cách phân tích yêu cầu, sinh test case/kịch bản kiểm thử và dữ liệu test, đồng thời giúp tăng năng suất thông qua các skill/template có sẵn của nhóm. Tuy nhiên, QA vẫn cần sử dụng tư duy kiểm thử, đánh giá rủi ro, kiểm tra tính chính xác của đầu ra AI và chủ động phát hiện các lỗi hoặc trường hợp bất thường mà AI có thể bỏ sót.	V A LI D	AI đã cung cấp AI Impact analysis đủ thông tin để đưa ra tính chính xác rồi đưa vào báo cáo	Kiểm tra các mô tả công việc, yêu cầu công việc ở trang web gốc. Dựa vào những ý mà AI đưa ra tính chính xác rồi đưa vào báo cáo

			on và sử dụng các công cụ hỗ trợ kiểm thử để cải thiện hiệu quả và hiệu suất.	
Artifact #5 Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.topcv.vn/brand/fptsoftwareacademy/tuyen-dung/ai-quality-evaluation-engineer-j2272394.html Tool: ChatGPT Timestamp: 21:58 PM 21/09/2026	AI Impact Analysis: AI đóng vai trò trực tiếp trong công việc QA của vị trí này, từ xây dựng test case, dữ liệu và tiêu chí đánh giá đến kiểm thử chất lượng đầu ra của AI Agent và Agentic AI. Tuy nhiên, kỹ sư vẫn cần phân tích kết quả, phát hiện các bất thường như lỗi RAG retrieval, tool call hoặc context management, xác định nguyên nhân và phối hợp với đội	V A LI D	AI đã cung cấp AI Impact Analysis đủ thông tin để	Kiểm tra các mô tả công việc, yêu cầu công việc ở trang web gốc. Dựa vào nhữn

	AI/Software Engineer để cải thiện hệ thống.		u cầ u củ a pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch ọn và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ế m th ử để cải thi ệ n hi ệu qu ả và hi	g ý mà AI đưa ra tính chỉ nh rồi đưa vào báo cáo
--	---	--	--	---

			êu su ất.	
Artifact #6 Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.topcv.vn/viec-lam/tester-fresher-junior-tieng-nhat/638505.html Tool: ChatGPT Pro Timestamp: 22:10 PM 21/09/2026	Với bài Tester Fresher/Junior (Tiếng Nhật) – SkyLab, JD không đề cập trực tiếp đến việc sử dụng AI. Vì vậy phần AI Impact Analysis nên viết theo hướng AI có thể hỗ trợ quy trình testing, không nói rằng công ty yêu cầu AI. AI Impact Analysis: AI có thể hỗ trợ tester trong việc phân tích tài liệu đặc tả, đề xuất test case và hỗ trợ xác định các tình huống cần kiểm thử, giúp giảm thời gian chuẩn bị và tăng độ bao phủ của hoạt động testing. Tuy nhiên, tester vẫn phải trực tiếp thực hiện kiểm thử, xác minh lỗi và phối hợp với developer để tái hiện và xử lý bug, đặc biệt đối với các yêu cầu nghiệp vụ cụ thể của hệ thống.	V A LI D	AI đã cung cấp AI Impact Analysis đủ thông tin để nghiên cứu và sử dụng cá	Kiểm tra các mô tả công việc, yêu cầu công việc ở trang web gốc. Dựa vào những ý mà AI đưa ra tinh chỉnh rồi đưa vào báo cáo

			c cô ng cụ hỗ tr ợ ki ể m th ử đề cải thi ện hi ệu qu ả và hi ệu su ất.	
Artifact #7 Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.linkedin.com/jobs/search-results/?currentJobId=4466855160&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=kFmecMzEoMybMbetAPc%2BUA%3D%3D&trackingId=Wo7fEB6ISLy%2FLHeKVd4xcQ%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE Tool: ChatGPT Pro Timestamp: 22:24 PM 21/09/2026	AI Impact Analysis: AI có thể hỗ trợ Tester trong việc tạo test case, phân tích kết quả kiểm thử và hỗ trợ viết hoặc tối ưu automation script, qua đó giảm thời gian thực hiện các công việc kiểm thử lặp lại. Tuy nhiên, với vai trò kiểm soát chất lượng và quản lý tiến độ của cả team, các quyết định về phạm vi kiểm thử, mức độ rủi ro và chất lượng sản phẩm vẫn cần dựa trên đánh giá của Tester có kinh nghiệm, đặc biệt trong domain bảo hiểm.	V A LI D	AI đã cung cấp AI Impa ct An aly sis đủ ng th eo yê u cầ u củ a pr	Kiểm tra các mô tả công việc, yêu cầu công việc ở trang web gốc. Dựa vào những ý mà AI đưa ra tinh

			o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử đề cải thi ện hi ệu qu ả và hi ệu su ất.	chỉn h rồi đưa vào báo cáo
Artifact #8	AI Impact Analysis: AI có thể hỗ trợ vị trí QC	V A	AI đã	Kiểm tra

Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.linkedin.com/jobs/search-results/?currentJobId=4458849990&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=hNav70RofK9FQBTEXdI1wQ%3D%3D&trackingId=aspGndGisAF%2F0MwUAmwffg%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=25 - Tool: ChatGPT Pro - Timestamp: 22:31 PM 21/09/2026	này trong việc tổng hợp phản hồi, phân tích Quality Metrics và phát hiện các xu hướng bất thường trong dữ liệu chất lượng, từ đó giúp xác định các vấn đề cần cải tiến quy trình. Tuy nhiên, công việc vẫn phụ thuộc nhiều vào việc giám sát quy trình, Final Inspection và phối hợp với các bộ phận để đưa ra quyết định kiểm soát chất lượng.	LI D	cu ng cấ p AI Im pa ct An aly sis đủ ng th eo yê u cầ u củ a pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch ọn và sử dụ ng cá c cô ng cụ hỗ tr	các mô tả công việc, yêu cầu công việc ở trang web gốc. Dựa vào nhữn g ý mà AI đưa ra tình chỉn h rồi đưa vào báo cáo
---	--	-----------------	--	--

			ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất.	
Artifact #9 Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.linkedin.com/jobs/search-results/?currentJobId=4468497299&eBP=N OT_ELIGIBLE_FOR_CHARGING&refId=hN av70RofK9FQBTEXdI1wQ%3D%3D&trackin gId=Ln3FozqNooeocATMgF0Ktw%3D%3D& keywords=QA%2FQC&origin=SEMANTIC_ SEARCH_LANDING_PAGE&start=25 - Tool: ChatGPT Pro - Timestamp: 22:40 PM 21/09/2026	AI Impact Analysis: AI có thể hỗ trợ vị trí Tester này trong việc sinh test case, tạo dữ liệu kiểm thử và hỗ trợ xây dựng hoặc tối ưu automation script, đặc biệt khi phạm vi testing bao gồm Web, Mobile, API và nhiều loại kiểm thử khác nhau. Tuy nhiên, việc xác định phạm vi, chiến lược kiểm thử và tiêu chí nghiệm thu vẫn cần dựa trên phân tích của Tester để bảo đảm hệ thống đáp ứng đúng yêu cầu nghiệp vụ.	V A LI D	AI đã cu ng cấ p AI Im pa ct An aly sis đủ ng th eo yê u cầ u củ a pr o m pt. IS TQ B	Kiểm tra các mô tả công việc, yêu cầu công việc ở trang web gốc. Dựa vào nhữn g ý mà AI đưa ra tính chỉn h rồi đưa vào báo cáo

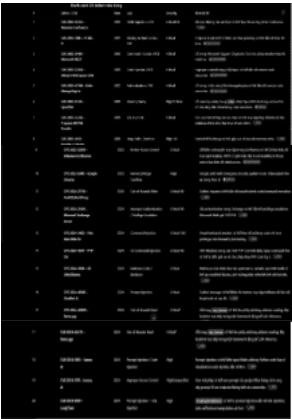
			đề cập đến việc lựa chọn và sử dụng các công cụ hỗ trợ kiểm thử để cải thiện hiệu quả và hiệu suất.	
Artifact #10 Prompt: Write 1-2 sentences of "AI Impact Analysis" per posting. https://www.linkedin.com/jobs/search-results/?currentJobId=4446584048&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=hN	AI có thể rút ngắn thời gian chuẩn bị kiểm thử cho vị trí này bằng cách hỗ trợ phân tích spec, đề xuất test case và tạo test data cho Web, Mobile, API và	V A LI D	AI đã cung cấp AI	Kiểm tra các mô tả công việc,

av70RofK9FQBTEXdl1wQ%3D%3D&trackingId=K0EwL5qvX3QzQ%2F2PG1d3lg%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=25 - Tool: ChatGPT Pro - Timestamp: 22:46 PM 21/09/2026	Database. Dù vậy, Tester vẫn phải tự kiểm tra kết quả thực tế và đối chiếu với yêu cầu nghiệp vụ để bảo đảm các lỗi về logic, dữ liệu và tích hợp không bị bỏ sót.	Implement Analysis đúng theo yêu cầu của người sử dụng và sử dụng các công cụ hỗ trợ kiểm tra	yêu cầu công việc ở trang web gốc. Dựa vào những ý mà AI đưa ra tính chỉnh rồi đưa vào báo cáo
--	---	--	---

			ử để cải thi ện hi ệu qu ả và hi ệu su ất.	
Artifact #11 Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.linkedin.com/jobs/search-results/?currentJobId=4457776136&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=hN-av70RofK9FQBTEXdI1wQ%3D%3D&trackingId=9mn%2Fb638w7I9yyCp5%2FwwDw%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=25 - Tool: ChatGPT Pro - Timestamp: 22:46 PM 21/09/2026	AI Impact Analysis: AI có thể hỗ trợ QC trong việc tổng hợp báo cáo chất lượng, theo dõi dữ liệu kiểm tra và nhận diện các dấu hiệu bất thường trong quá trình kiểm soát nguyên vật liệu và thành phẩm. Tuy nhiên, việc đánh giá trực tiếp chất lượng thực phẩm, điều kiện kho lạnh và mức độ tuân thủ HACCP/ISO 22000 vẫn cần được thực hiện và xác nhận bởi nhân viên QC dựa trên các tiêu chuẩn thực tế.	V A LI D	AI đã cung cấp AI Impa pa ct An aly sis đủ ng th eo yê u cầ u củ a pr o m pt. IS TQ B đề cậ p đế n	Kiểm tra các mô tả công việc, yêu cầu công việc ở trang web gốc. Dựa vào nhữn g ý mà AI đưa ra tình chĩn h rồi đưa vào báo cáo

			việc lựa chọn và sử dụng các công cụ hỗ trợ kiểm thử để cải thiện hiệu quả và hiệu suất.	
Artifact #12 - Prompt: Write 1–2 sentences of "AI Impact Analysis" per posting. https://www.linkedin.com/jobs/search-results/?currentJobId=4460215778&eBP=NOT_ELIGIBLE_FOR_CHARGING&refId=8NBOxyKtupICPT9QqevacQ%3D%3D&trackingId=Xuhc9OtzeyOKB5OI5BlzrQ%3D%3D&keywords=QA%2FQC&origin=SEMANTIC_SEARCH_LANDING_PAGE&start=50 - Tool: ChatGPT Pro - Timestamp: 22:59 PM 21/09/2026	AI Impact Analysis: AI có thể hỗ trợ Tester trong việc phân tích requirement, đề xuất test case và tổng hợp kết quả kiểm thử, đặc biệt khi phải kiểm thử nhiều loại hệ thống như web, mobile và API. Tuy nhiên, việc hiểu nghiệp vụ, xác định phạm vi kiểm thử	V A LI D	AI đã cung cấp AI Impa ct An aly sis	Kiểm tra các mô tả công việc, yêu cầu công việc ở trang

	và đánh giá các rủi ro của từng hệ thống vẫn cần sự phân tích của Tester để bảo đảm chất lượng phần mềm.		đúng theo yêu cầu của chương trình. IS TQB đề cập đến việc lựa chọn và sử dụng các công cụ hỗ trợ kiểm thử để cải thiện	web gốc. Dựa vào những ý mà AI đưa ra chỉnh rồi đưa vào báo cáo
--	--	--	---	---

			ệu qu ả và hi ệu su ất.	
Artifact #13 Prompt: Find 20 software defects publicized between 2022 and 2026. Mandatory: ≥ 5 defects related to AI/LLM (hallucination, prompt injection,bias).Each defect: source link, description, severity, consequences, solution. - Tool: ChatGPT Pro - Timestamp: 20:03 PM 22/09/2026		IN C O M P L E T E	AI đã cu ng cấ p ch ư a đủ th ôn g tin về nh ữn g ea ch de fec t nh ư de sc rip tio n, sol uti on . Vì th ế nó đã vi ph ạ	Tiếp tục prom pt AI để tìm đầy đủ thôn g tin về 20 defec t

			m tiê u chí IS T Q B Co m ple te ne ss. Do đó , ou tp ut nà y vẫ n ch ưa ho àn chỉ nh	
Artifact #14 Prompt: Hãy giải thích CVE-2022-26134 (Atlassian Confluence) bao gồm description, severity, consequences, solution. - Tool: Geimini - Timestamp: 20:14 PM 22/09/2026	CVE-2022-26134 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng đến các phiên bản Atlassian Confluence Server và Data Center. Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục: 1. Description (Mô tả) Bản chất: Đây là một lỗ hổng OGNL Injection (Object-Graph Navigation Language) hay được phân loại theo CWE-917 (Improper Neutralization of Special Elements used	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính thức của lỗi và

	in an Expression Language Statement). Cơ chế: Lỗ hổng tồn tại do cách Confluence xử lý các tham số trong URL và tên action/namespace. Khi một kẻ tấn công gửi một HTTP request chứa các đoạn mã hoặc ký tự cú pháp OGNL đặc biệt (ví dụ: chứa chuỗi \${...}) trong đường dẫn URL, hệ thống sẽ tiếp nhận và đánh giá/thực thi các biểu thức này trực tiếp trên Java Runtime Environment (JRE) của máy chủ. Điểm đáng chú ý: Lỗ hổng này không yêu cầu xác thực (unauthenticated), nghĩa là bất kỳ ai có kết nối mạng tới ứng dụng Confluence đều có thể khai thác mà không cần tài khoản hay quyền hạn. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp (Low Attack Complexity), không cần tương tác người dùng (No User Interaction), và thực thi từ xa qua mạng (Network Vector). Lỗ hổng này đã bị khai thác rộng rãi trên thực tế (In-the-wild) ngay sau khi được công bố và nằm trong danh mục các lỗ hổng bị khai thác biết trước	đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu	các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	--	--	--

	của CISA (Known Exploited Vulnerabilities Catalog). 3. Consequences (Hậu quả) Khi bị khai thác thành công, kẻ tấn công có thể gây ra những hậu quả nghiêm trọng sau: Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình chạy ứng dụng Confluence trên hệ điều hành chủ (OS Command Execution). Kiểm soát toàn bộ hệ thống: Kẻ tấn công có thể cài cắm web shell (ví dụ: Behinder, China Chopper) để duy trì quyền truy cập trái phép, đọc/đánh cắp dữ liệu nhạy cảm của doanh nghiệp, hoặc đánh cắp thông tin tài khoản (credential dumping) từ /etc/passwd hoặc cơ sở dữ liệu. Tấn công lan rộng (Lateral Movement): Biến máy chủ Confluence bị chiếm đoạt thành bàn đạp để thâm nhập sâu hơn vào mạng nội bộ của tổ chức. Triển khai mã độc: Đã ghi nhận nhiều trường hợp kẻ xấu lợi dụng lỗ hổng này để cài cắm phần mềm đào tiền ảo (cryptocurrency miners) hoặc ransomware.		su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì cá c hệ u qu ả	
--	--	--	---	--

	4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng cấp (Upgrade) ứng dụng Confluence Server hoặc Data Center lên các phiên bản đã được vá lỗi từ hãng (phiên bản 7.4.17, 7.13.7, 7.14.3, 7.15.2, 7.16.4, 7.17.4, 7.18.1 hoặc các bản phát hành mới hơn). - Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay): + Cô lập hoặc hạn chế quyền truy cập mạng từ bên ngoài vào máy chủ Confluence (chỉ cho phép truy cập từ mạng nội bộ đáng tin cậy). + Cấu hình Web Application Firewall (WAF) với các quy tắc chặn các request có chứa cú pháp biểu thức OGNL độc hại hoặc các chuỗi như \${ trong đường dẫn URL.		Ge mi ni đư a ra kh ôn g hề có bả ng ch ứn g ha y lin k dẫ n ch ứn g cụ th ể nà o.	
Artifact #15 - Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2022-26134 Khi bị khai thác thành công, kẻ tấn công có thể gây ra những hậu quả nghiêm trọng sau: Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình chạy ứng dụng Confluence trên hệ điều hành chủ (OS Command Execution). Kiểm soát toàn bộ hệ thống: Kẻ tấn công có thể cài cắm web shell (ví dụ: Behinder, China Chopper) để duy trì quyền truy cập trái phép, đọc/đánh cắp dữ liệu nhạy cảm của doanh nghiệp, hoặc đánh cắp thông tin tài khoản (credential dumping) từ /etc/passwd hoặc cơ sở dữ liệu.	Với prompt và output bạn vừa đưa, có thể xác định một hallucination/unsupported claim khá rõ: “cài cắm web shell (ví dụ: Behinder, China Chopper) ... credential dumping từ /etc/passwd hoặc cơ sở dữ liệu.” Lý do: nguồn chính thức của Atlassian xác nhận CVE-2022-26134 là unauthenticated OGNL injection dẫn	V A LI D	IS TQ B đề cậ p để n việ c lự a ch ọn và sử	Đọc lại nhữn g dẫn chứn g, chứn g cứ trong link AI đưa ra, cũng như trang

Tấn công lan rộng (Lateral Movement): Biến máy chủ Confluence bị chiếm đoạt thành bàn đạp để thâm nhập sâu hơn vào mạng nội bộ của tổ chức.

Triển khai mã độc: Đã ghi nhận nhiều trường hợp kẻ xấu lợi dụng lỗ hổng này để cài cắm phần mềm đào tiền ảo (cryptocurrency miners) hoặc ransomware.

- Tool: ChatGPT Pro

- Timestamp: 20:25 PM 22/09/2026

đến arbitrary code execution, và Atlassian có cảnh báo rằng sau khi bị compromise, attacker có thể thay đổi file/log và cần điều tra forensic. Nhưng advisory của Atlassian không xác nhận cụ thể việc CVE này trực tiếp dẫn đến việc cài Behinder/China Chopper, credential dumping từ /etc/passwd hoặc database.

Còn câu:

“Đã ghi nhận nhiều trường hợp kẻ xấu lợi dụng lỗ hổng này để cài cắm ...

cryptocurrency miners hoặc ransomware.”

thì không nên đánh dấu hallucination hoàn toàn. CISA xác nhận CVE-2022-26134 đã được khai thác và đánh dấu “Known To Be Used in Ransomware Campaigns: Known”. advice about adding a WAF rule.

https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html?utm_source=chatgpt.com

Do đó, nếu report của bạn lấy final Atlassian advisory làm nguồn chính, không nên trình bày WAF như giải pháp chính hiện tại. Giải pháp chính là

dụ
ng
cá
c
cô
ng
cụ
hỗ
tr
ợ
ki
ể
m
th
ủ
để
cải
thi
ện
hi
ệu
qu
ả
và
hi
ệu
su
ất.
Do
đó
,
tôi
nh
ờ
tr
ợ
gi
úp
AI
xá
c
đị
nh
đú
ng
bá
n
ch
ất
lỗi
lỗi
chín
h
thức
để so
sánh
với
outp
ut rồi
đưa
vào
báo
cáo.
Chín
h sửa
đưa
vào
báo
cáo:
**Đây
là
hiện
tượn
g "ảo
giác"
của
AI vì
chưa
có
nguồn
thôn
g tin
xác
nhận
rằng
các
kẻ
tấn
công
có
thể
cred
ential
dum
ping,
later
al
move
ment
hay
rans**

	upgrade lên fixed version. Atlassian cũng cung cấp mitigation tạm thời cho trường hợp chưa thể upgrade Nếu chỉ cần “1 lỗi ảo giác AI” để đưa vào bảng Bạn có thể ghi cực ngắn: AI hallucination: AI khẳng định CVE-2022-26134 có thể dẫn đến việc cài các webshell cụ thể như Behinder/China Chopper và credential dumping từ /etc/passwd hoặc database, nhưng các nguồn chính thức của Atlassian không xác nhận các chi tiết này. Đây là thông tin AI mở rộng ngoài bằng chứng nguồn và cần được loại bỏ/xác minh thêm. Cách này an toàn hơn so với nói “toàn bộ phần webshell là sai”, vì bản thân Atlassian xác nhận attacker có thể thực thi code và có thể thay đổi các file/log sau compromise; vấn đề nằm ở việc AI gán những kỹ thuật cụ thể đó trực tiếp với CVE mà không có nguồn chứng minh.		và đư a ra nh ữn g bả ng ch ứn g cũ ng nh ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng	omw are, crypt ocurr ency mine rs. Tôi khôn g tìm thấy nhữn g thôn g tin này trên trang chính thức.
--	---	--	---	--

			cấ p đầ y đủ th ôn g tin cầ n thi ết.	
Artifact #16 Prompt: Hãy giải thích CVE-2022-1388 (F5 BIG-IP iControl REST) bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 20:36 PM 22/09/2026	CVE-2022-1388 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng đến giao diện quản trị iControl REST trên các thiết bị F5 BIG-IP. Dưới đây là thông tin chi tiết: 1. Description (Mô tả) Bản chất: Đây là lỗ hổng Authentication Bypass (Bỏ qua cơ chế xác thực, mã định danh CWE-306) kết hợp với Remote Code Execution (RCE). Cơ chế: Giao diện lập trình ứng dụng iControl REST API của F5 BIG-IP gặp lỗi trong cách xử lý các HTTP request qua proxy Apache/HTTPD. Bằng cách gửi các chuỗi HTTP request được tinh chỉnh đặc biệt (thao tác trên các header như Connection và X-F5-Auth-Token), kẻ tấn công có thể lừa hệ thống để đánh lừa lớp kiểm tra xác thực. Điểm đáng chú ý: Lỗ hổng này hoàn toàn không cần xác thực (unauthenticated). Kẻ tấn công chỉ cần có quyền truy cập mạng	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đủ ng vớ i pr o m pt. IS TQ B đề cậ p để n	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thông tin chưa được xác

	vào cổng quản lý (management port) hoặc địa chỉ IP tự gán (self-IP) của thiết bị là có thể khai thác. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu tương tác người dùng, tấn công từ xa qua mạng. Ngay sau khi được công bố, lỗ hổng này đã bị khai thác hàng loạt trên thực tế và được CISA đưa vào danh mục các lỗ hổng bị khai thác biết trước (Known Exploited Vulnerabilities Catalog). 3. Consequences (Hậu quả) Vi thiết bị F5 BIG-IP thường đóng vai trò là cổng biên quan trọng (như bộ cân bằng tải, thiết bị điều phối ứng dụng hoặc tường lửa), việc bị chiếm đoạt mang lại hậu quả tàn khốc: Thực thi mã lệnh tùy ý (RCE) với quyền cao nhất: Kẻ tấn công có thể chạy các lệnh hệ điều hành dưới quyền root. Kiểm soát toàn bộ thiết bị: Tạo/xóa tệp tin, vô hiệu hóa dịch vụ, thay đổi cấu hình hệ thống mạng. Bàn đạp tấn công nội bộ (Lateral Movement): Kẻ xấu có thể chiếm quyền kiểm soát thiết bị để đánh cắp lưu lượng mạng		việc cần được loại bỏ khỏi báo cáo.
--	---	--	--

	nhạy cảm đi qua hệ thống, cài đặt mã độc, hoặc thâm nhập sâu hơn vào hạ tầng mạng bên trong doanh nghiệp. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng cấp phần mềm BIG-IP lên các phiên bản đã được vá lỗi từ hãng (ví dụ: phiên bản 16.1.2.2, 15.1.5.1, 14.1.4.6, 13.1.5 hoặc cao hơn tùy theo nhánh phiên bản bạn đang sử dụng). Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay): Chặn truy cập: Cấm tuyệt đối việc truy cập vào giao diện iControl REST từ các mạng không đáng tin cậy hoặc từ Internet công cộng (không phơi bày cổng quản lý management/self-IP ra ngoài mạng internet). Cấu hình lại HTTPD: Áp dụng các thay đổi cấu hình tệp tin httpd trên BIG-IP theo khuyến nghị trực tiếp từ tài liệu bảo mật chính thức của F5 (K23605346).		t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì cá c hệ u qu ả Ge mi ni đư a ra kh ôn g hề có bả ng ch ứn g	
--	---	--	---	--

			hay lin k dẫ n ch ứn g cụ th ể nà o.	
Artifact #17 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2022-1388 Bản chất: Đây là lỗi hồng Authentication Bypass (Bỏ qua cơ chế xác thực, mã định danh CWE-306) kết hợp với Remote Code Execution (RCE). Cơ chế: Giao diện lập trình ứng dụng iControl REST API của F5 BIG-IP gặp lỗi trong cách xử lý các HTTP request qua proxy Apache/HTTPD. Bằng cách gửi các chuỗi HTTP request được tinh chỉnh đặc biệt (thao tác trên các header như Connection và X-F5-Auth-Token), kẻ tấn công có thể lừa hệ thống để đánh lừa lớp kiểm tra xác thực. Điểm đáng chú ý: Lỗi hồng này hoàn toàn không cần xác thực (unauthenticated). Kẻ tấn công chỉ cần có quyền truy cập mạng vào cổng quản lý (management port) hoặc địa chỉ IP tự gán (self-IP) của thiết bị là có thể khai thác. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu tương tác người dùng, tấn công từ xa qua mạng. Ngay sau khi được công bố, lỗi hồng này đã bị khai thác hàng loạt trên thực tế và được CISA đưa vào danh mục các lỗi hồng bị khai thác biết trước (Known Exploited Vulnerabilities Catalog). Consequences (Hậu quả) Vì thiết bị F5 BIG-IP thường đóng vai trò là cổng biên quan trọng (như bộ cân bằng tải, thiết bị điều phối ứng dụng hoặc tường lửa), việc bị chiếm đoạt mang lại hậu quả tàn khốc: Thực thi mã lệnh tùy ý (RCE) với quyền cao nhất: Kẻ tấn công có thể chạy các lệnh hệ điều hành dưới quyền root.	Defect #2 — Đánh giá output AI Phần lớn output là đúng, đặc biệt: CVE-2022-1388 là F5 BIG-IP Missing Authentication vulnerability, CWE-306. Attacker không cần authentication nhưng phải có network access tới management port hoặc self-IP. Có thể thực thi arbitrary system commands, tạo/xóa file hoặc disable services. CISA xác nhận PoC đã được công khai và CVE được đưa vào KEV do có bằng chứng active exploitation. Các fixed versions 16.1.2.2, 15.1.5.1, 14.1.4.6, 13.1.5 phù hợp với thông tin của CISA. 12.1.x và 11.6.x là EOL và F5 không phát hành patch cho hai nhánh này.	V A L I D	IS TQ B đề cậ p để n việ c lự a ch ọn và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện	Đọc lại những hướng dẫn chứng, chứng cứ trong link AI đưa ra, cũng như trang lỗi chín h thức để so sánh với output rồi đưa vào báo cáo. Chín h sửa và đưa vào

Kiểm soát toàn bộ thiết bị: Tạo/xóa tệp tin, vô hiệu hóa dịch vụ, thay đổi cấu hình hệ thống mạng. Bàn đạp tấn công nội bộ (Lateral Movement): Kẻ xấu có thể chiếm quyền kiểm soát thiết bị để đánh cắp lưu lượng mạng nhạy cảm đi qua hệ thống, cài đặt mã độc, hoặc thâm nhập sâu hơn vào hạ tầng mạng bên trong doanh nghiệp. Tool: ChatGPT Timestamp: 20:45 PM 22/09/2026	Tuy nhiên, có một số điểm cần chỉnh. 1. AI nói "RCE với quyền root" Output: "Kẻ tấn công có thể chạy các lệnh hệ điều hành dưới quyền root." Đây là điểm không nên ghi nguyên trạng. Nguồn CISA mình kiểm tra xác nhận attacker có thể execute arbitrary system commands, create/delete files và disable services, nhưng đoạn nguồn này không nói trực tiếp rằng mọi command đều được thực thi với quyền root. → Đây là unsupported claim nếu chỉ dựa trên source hiện tại. 2. AI nói về "lateral movement" Output: "Bàn đạp tấn công nội bộ (Lateral Movement)..." Đây là một hậu quả có thể xảy ra sau khi thiết bị bị compromise, nhưng không phải consequence trực tiếp được CISA nêu trong mô tả CVE. CISA tập trung vào arbitrary command execution, file manipulation và disabling services. → Nên bỏ khỏi phần Consequences chính hoặc ghi rõ là potential follow-on impact, không phải tác động trực tiếp đã được nguồn chứng minh.	hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đủ ng bả n ch ất lỗi và đư a ra nh ữn g bà ng ch ứn g cũ ng nh ư lin k rõ	báo cáo: Đây là ảo giác AI khi cho rằng kẻ tấn công có thể chạy lệnh điều hành với quyền root và thực hiện di chuyển ngăn g trong mạng và chặn bất lưu lượng mạng nhạy cảm. CISA chưa cung cấp thông tin về những khả năng này.
---	--	---	--

	3. AI nói “đánh cắp lưu lượng mạng” Output: “đánh cắp lưu lượng mạng nhạy cảm đi qua hệ thống” Đây cũng là một suy luận về hậu quả tiềm năng của việc compromise một thiết bị BIG-IP. Nguồn CISA đang sử dụng không trực tiếp xác nhận CVE-2022-1388 cho phép attacker thực hiện việc này. → Không nên đưa vào report như một fact. 4. AI nói “Cấu hình lại HTTPD” Phần này đáng chú ý: “Áp dụng các thay đổi cấu hình tệp tin httpd ... K23605346.” Mã tài liệu K23605346 thực sự là tài liệu F5 được CISA dẫn tới để kiểm tra indicators of compromise. CISA không trình bày nó trong đoạn mitigation chính mà mình đang sử dụng. Vì vậy nên không coi câu này là solution chính nếu chưa kiểm tra trực tiếp tài liệu F5. Nguồn tham khảo: https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html?utm_source=chatgpt.com		rá ng mì nh bạ ch. AI giả i thí ch cụ th ể chỉ tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	
--	--	--	--	--

Artifact #18 - Prompt: Hãy giải thích CVE-2022-30190 bao gồm description, severity, consequences, solution. - Tool: Geimini - Timestamp: 20:52 PM 22/09/2026	CVE-2022-30190 (được biết đến rộng rãi với biệt danh "Follina") là một lỗ hổng bảo mật nổi tiếng ảnh hưởng đến công cụ chẩn đoán Microsoft Support Diagnostic Tool (MSDT) trên hệ điều hành Windows. Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục: 1. Description (Mô tả) Bản chất: Đây là lỗ hổng Remote Code Execution (RCE) lợi dụng cách giao thức URL tùy chỉnh ms-msdt:// hoạt động. Cơ chế: Lỗ hổng cho phép kẻ tấn công thực thi mã lệnh từ xa thông qua các tài liệu Microsoft Office (Word, RTF, v.v.) mà không cần kích hoạt Macros. Kẻ tấn công tạo một tệp văn bản chứa liên kết độc hại trỏ đến một tệp HTML từ xa. Khi nạn nhân mở tệp hoặc thậm chí chỉ xem trước (Preview Pane) tệp trong Windows Explorer (đối với định dạng .rtf), ứng dụng Office sẽ gọi công cụ MSDT của hệ thống để chạy mã lệnh PowerShell ngầm mà người dùng không hề hay biết.	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thông tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	--	---

	2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 7.8 / 10.0 (Mức High - Cao theo thang đo tiêu chuẩn, nhưng tính nguy hiểm thực tế cực kỳ cao vì bị lợi dụng làm bàn đạp tấn công ban đầu). Đặc điểm tấn công: Kẻ tấn công chỉ cần lừa người dùng mở một tệp tài liệu thông qua các chiến dịch tấn công giả mạo (phishing). Lỗ hổng này đã bị khai thác diện rộng (In-the-wild) dưới dạng zero-day trước khi Microsoft phát hành bản vá và nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA (Known Exploited Vulnerabilities Catalog). 3. Consequences (Hậu quả) Khi khai thác thành công CVE-2022-30190, kẻ tấn công có thể: Thực thi mã lệnh tùy ý (RCE): Chạy các lệnh hệ thống dưới quyền hạn của người dùng đang đăng nhập. Cài cắm phần mềm độc hại: Tải xuống và cài đặt các payload độc hại như mã độc tống tiền (ransomware), phần mềm đánh cắp thông tin (info-stealers), hoặc trojan truy cập từ xa (RAT). Thao túng dữ liệu: Tạo tài khoản mới, xem, sửa đổi hoặc xóa dữ		ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ	
--	--	--	---	--

	liệu trên hệ thống của nạn nhân. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật các bản vá bảo mật chính thức từ Microsoft (các gói cập nhật từ tháng 6/2022 trở đi) để vô hiệu hóa cách thức lạm dụng giao thức MSDT. Giải pháp phòng ngừa bổ sung: Kích hoạt các quy tắc giảm bề mặt tấn công (Attack Surface Reduction - ASR) trong Windows Defender, đặc biệt là quy tắc “Block all Office applications from creating child processes” để chặn các ứng dụng Office sinh tiến trình độc hại gọi MSDT. Sao lưu và xóa khóa sổ đăng ký (Registry) của giao thức ms-msdt nếu chưa thể áp dụng bản vá ngay lập tức.		B (thôn g tin ch ưa xá c nh ận) bở i vì m ột số hậ u qu ả Ge mi ni đư a ra kh ôn g hề có bả ng ch ứn g ha y lin k đẫ n ch ứn g cụ th ể	
--	---	--	--	--

			nà o.	
Artifact #19 - Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2022-30190 Severity (Mức độ nghiêm trọng) Điểm CVSS: 7.8 / 10.0 (Mức High - Cao theo thang đo tiêu chuẩn, nhưng tính nguy hiểm thực tế cực kỳ cao vì bị lợi dụng làm bàn đạp tấn công ban đầu). Đặc điểm tấn công: Kẻ tấn công chỉ cần lừa người dùng mở một tệp tài liệu thông qua các chiến dịch tấn công giả mạo (phishing). Lỗi hổng này đã bị khai thác diện rộng (In-the-wild) dưới dạng zero-day trước khi Microsoft phát hành bản vá và nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA (Known Exploited Vulnerabilities Catalog). Consequences (Hậu quả) Khi khai thác thành công CVE-2022-30190, kẻ tấn công có thể: Thực thi mã lệnh tùy ý (RCE): Chạy các lệnh hệ thống dưới quyền hạn của người dùng đang đăng nhập. Cài cắm phần mềm độc hại: Tải xuống và cài đặt các payload độc hại như mã độc tống tiền (ransomware), phần mềm đánh cắp thông tin (info-stealers), hoặc trojan truy cập từ xa (RAT). Thao túng dữ liệu: Tạo tài khoản mới, xem, sửa đổi hoặc xóa dữ liệu trên hệ thống của nạn nhân. - Tool: ChatGPT - Timestamp: 21:08 PM 22/09/2026	Đánh giá output AI — CVE-2022-30190 Microsoft xác nhận CVE-2022-30190 là một Remote Code Execution vulnerability xảy ra khi MSDT được gọi bằng URL protocol từ một ứng dụng gọi nó như Word. Attacker thành công có thể chạy arbitrary code với quyền của calling application, sau đó có thể install programs, xem/thay đổi/xóa dữ liệu hoặc tạo account trong phạm vi quyền của user. Microsoft công bố CVE ngày 30/05/2022 và phát hành Windows updates để xử lý vào 14/06/2022. 1. Phần AI nói đúng Các điểm sau có thể giữ: CVE-2022-30190 / Follina. Ảnh hưởng Microsoft Support Diagnostic Tool (MSDT). Là RCE. Khai thác thông qua MSDT URL protocol. Có thể được kích hoạt từ application như Microsoft Word. Attacker có thể thực thi arbitrary code với quyền của calling application. Có thể install programs, view/change/delete	V A LI D	IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử đề cải thi ện hi ệu qu ả và hi ệu su ất. Do đó	Đọc lại nhữn g dẫn chứn g, chứn g cứ trong link AI đưa ra, cũng như trang lỗi chín h thức đề so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI tuyê n bố chưa có cơ sở ở

	data và create accounts trong phạm vi quyền user. Microsoft phát hành fix vào 14/06/2022. Đây là vulnerability đã bị khai thác thực tế; CISA liệt kê CVE-2022-30190 trong các vulnerability được routinely exploited trong năm 2022. 2. AI sai ở Severity AI ghi: "CVSS: 7.8 / 10.0 (High)" Điểm này đúng về CVSS, nhưng phần giải thích của AI cần cẩn thận. 7.8 là High, không phải Critical. Vì vậy nếu bảng của bạn ghi severity thì có thể ghi: Severity: High (CVSS 7.8) Không nên tự đổi thành Critical chỉ vì vulnerability có impact lớn. 3. AI nói quá cụ thể về Preview Pane AI viết: "hoặc thậm chí chỉ xem trước (Preview Pane) tệp trong Windows Explorer (đối với định dạng .rtf)" Đây là điểm cần đánh dấu. Microsoft advisory chính thức mô tả vulnerability ở mức: MSDT được gọi bằng URL protocol từ một calling application như Word. Microsoft không dùng câu trên để xác nhận rằng mọi trường hợp		, tôi nhớ trình bày đúng giúp AI xác định như đúng bảng nhận xét lỗi và đưa ra những bình luận chi tiết và ứng dụng cũ như sử dụng link rõ ràng minh bạch. AI giả i thi ch	chỗ tải xuống và cài đặt các payload độc hại như mã độc tổng tiền (ransomware), phần mềm đánh cắp thông tin (info-stealers), hoặc trojan truy cập từ xa (RAT). Microsoft chưa có xác nhận chính thức về những khả
--	---	--	---	--

	Preview Pane của RTF đều dẫn tới exploitation. Vì vậy, nếu source chính của bạn là Microsoft, nên đánh dấu: Unsupported / Over-specific claim Chứ không nhất thiết gọi đây là hallucination hoàn toàn. 4. AI nói “không cần kích hoạt Macros” AI viết: “không cần kích hoạt Macros” Thông tin này phù hợp với cách Follina được khai thác và là một đặc điểm thường được nhắc đến, nhưng Microsoft advisory bạn đang dùng không cần câu này để chứng minh bản chất CVE. Trong report, nếu muốn tối giản và bám source, mình khuyên bỏ câu này. 5. AI nói “tạo file HTML từ xa → PowerShell ngầm” Phần này mô tả một exploitation chain cụ thể, chứ không phải toàn bộ định nghĩa của CVE. Vấn đề ở đây là AI đang trộn: vulnerability mechanism với một exploitation technique cụ thể. Đối với bài Software Testing, nên viết ở mức:		cụ th ể chỉ tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	năng trên.
--	--	--	---	-----------------------

	The vulnerability occurs when MSDT is invoked through the URL protocol from a calling application. Như vậy chính xác và ít phụ thuộc vào một exploit implementation cụ thể. Microsoft xác nhận mô tả này trực tiếp. 6. AI nói ransomware/info-stealer/RAT AI viết: “Tải xuống và cài đặt các payload độc hại như ransomware, info-stealers hoặc RAT.” Đây là phần không nên giữ nguyên trong defect table nếu không có nguồn riêng cho từng claim. Microsoft chỉ xác nhận hậu quả trực tiếp là: install programs; view/change/delete data; create new accounts; với quyền mà user có. CISA xác nhận CVE này đã bị khai thác thực tế và nằm trong danh sách vulnerability được routinely exploited. Nhưng để nói cụ thể “CVE này được dùng để cài ransomware, info-stealer và RAT”, bạn cần source riêng. → Đây là unsupported claim. Nguồn tham khảo: https://www.microsoft.com/en-us/msrc/blog/2022/0			
--	---	--	--	--

	độc hại) để kích hoạt lỗ hổng tiêm mã mẫu phía máy chủ (SSTI), từ đó hệ thống sẽ biên dịch và thực thi chúng. Điểm đáng chú ý: Lỗ hổng này không yêu cầu xác thực (unauthenticated) và kẻ tấn công chỉ cần có khả năng kết nối mạng tới cổng ứng dụng là có thể khai thác. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng. Ngay sau khi công bố, lỗ hổng này đã bị các nhóm tấn công mạng khai thác diện rộng trên thực tế (In-the-wild) và nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA (Known Exploited Vulnerabilities Catalog). 3. Consequences (Hậu quả) Khi bị khai thác thành công, kẻ tấn công có thể: Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình đang chạy ứng dụng (thường có đặc quyền cao trên hệ điều hành nền tảng).		cập đến việc c lự a ch on và sử d ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vì ph ạ m ng	g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	--	--

	Kiểm soát hệ thống: Tải lên các tệp tin độc hại, cài cắm webshell để duy trì quyền truy cập lâu dài (persistence). Đánh cắp dữ liệu & Xâm nhập sâu hơn: Đánh cắp thông tin xác thực, dữ liệu định danh nhạy cảm của doanh nghiệp, hoặc dùng máy chủ này làm bàn đạp để tấn công vào các thành phần khác trong hạ tầng nội bộ (như VMware Cloud Foundation hoặc vRealize Suite). 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật/nâng cấp các sản phẩm bị ảnh hưởng lên các phiên bản đã được VMware vá lỗi chính thức theo thông báo bảo mật (VMSA-2022-0011). Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay): Áp dụng các bản vá cấu hình thủ công hoặc kịch bản vô hiệu hóa tính năng tạm thời do VMware cung cấp trong các bài viết Hỗ trợ kỹ thuật (VMware KB articles tương ứng như KB88098). Hạn chế hoặc chặn toàn bộ quyền truy cập mạng bên ngoài vào giao diện quản trị của Workspace ONE Access/Identity Manager, chỉ cho		uy ên tác tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hậ u qu ả Ge mi ni đư a ra kh ôn g hề có	
--	--	--	--	--

	phép quản trị qua mạng nội bộ được kiểm soát nghiêm ngặt.		bằng chứng hay link dẫn chứng cụ thể nào.	
Artifact #21 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2022-22954 Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng. Ngay sau khi công bố, lỗ hổng này đã bị các nhóm tấn công mạng khai thác diện rộng trên thực tế (In-the-wild) và nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA (Known Exploited Vulnerabilities Catalog). Consequences (Hậu quả) Khi bị khai thác thành công, kẻ tấn công có thể: Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình đang chạy ứng dụng (thường có đặc quyền cao trên hệ điều hành nền tảng). Kiểm soát hệ thống: Tải lên các tệp tin độc hại, cài cắm webshell để duy trì quyền truy cập lâu dài (persistence). Đánh cắp dữ liệu & xâm nhập sâu hơn: Đánh cắp thông tin xác thực, dữ liệu định danh nhạy cảm của doanh nghiệp, hoặc dùng máy chủ này làm bàn đạp để tấn công vào các thành phần khác trong hạ tầng nội bộ (như VMware Cloud Foundation hoặc vRealize Suite). Tool: ChatGPT Timestamp: 21:25 PM 22/09/2026	Với output Gemini của #4, mình đánh giá như sau. Đánh giá của sinh viên: AI đã xác định đúng các thông tin chính về CVE-2022-22954, bao gồm sản phẩm bị ảnh hưởng, loại lỗ hổng Server-Side Template Injection (SSTI), khả năng dẫn đến Remote Code Execution (RCE), mức độ Critical với CVSS 9.8 và việc lỗ hổng đã được khai thác trong thực tế. Các thông tin này phù hợp với VMware Security Advisory VMSA-2022-0011. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi đưa ra một số hậu quả cụ thể như	V A L I D	IS TQ B đề cập để n việ c lự a ch ọn và sử d ng cá c cô ng cụ hỗ tr ợ ki ể m	Đọc lại những dẫn chứng, chứng cứ trong link AI đưa ra, cũng như trang lỗi chính thức để so sánh với output rồi đưa vào báo

	“thường có đặc quyền cao trên hệ điều hành”, “cài cắm webshell để duy trì persistence”, “đánh cắp thông tin xác thực” và “dùng máy chủ làm bàn đạp để tấn công VMware Cloud Foundation hoặc vRealize Suite” mà không phân biệt rõ đây là hậu quả trực tiếp của CVE hay các hành động có thể xảy ra sau khi hệ thống đã bị xâm nhập. VMware chỉ xác nhận rằng attacker có network access có thể trigger SSTI và dẫn đến RCE. Tuy nhiên, một số thông tin mà AI đưa ra về webshell và lateral movement có thể được chứng minh trong các vụ khai thác thực tế, chứ không phải hoàn toàn bịa đặt. CISA ghi nhận một trường hợp attacker khai thác CVE-2022-22954 để thực thi shell command, tải malicious shell script và triển khai Dingo J-spy webshell; CISA cũng ghi nhận việc attacker sử dụng hệ thống bị compromise để thu thập và exfiltrate dữ liệu. Vì vậy, lỗi của AI ở đây chủ yếu là không phân biệt giữa impact trực tiếp của vulnerability và các hành vi post-exploitation đã được	th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả n ch ất lỗi và đư a ra nh ữn g bà ng ch ứn g cũ	cáo. Chín h sửa và đưa vào báo cáo: AI đang bị ảo giác vì nó đưa ra “thực thi mã lệnh tùy ý dưới quyề n của tiền trình đang chạy ứng dụng (thườ ng có đặc quyề n cao trên hệ điều hành nền tảng) ” , “cài cắm webs hell để duy trì persis tence
--	--	---	---

	quan sát trong một số incident cụ thể. Ngoài ra, AI đề cập đến KB88098 như một workaround cụ thể. VMware advisory thực sự xác nhận có workaround được cung cấp trong Knowledge Base và bảng Resolution Matrix liên kết CVE-2022-22954 với KB88098; do đó phần này có cơ sở. Kết luận: AI cung cấp đúng phần lớn thông tin cốt lõi nhưng cần được kiểm chứng và chỉnh sửa để phân biệt rõ thông tin chính thức về vulnerability với các hậu quả được quan sát trong quá trình khai thác thực tế. Nguồn tham khảo: https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/23639?utm_source=chatgpt.com	ng nh ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	”, “đán h cấp thông tin xác thực” ,... AI đang mở rộng quá mức hậu quả. Ở trên toàn là nhữn g hậu quả nghiê m trọng xây ra sau khi hệ thống đã bị mất quyề n kiểm soát. Nó khôn g phải là hậu quả trực tiếp của CVE đang trình bày.
--	--	---	--

Artifact #22 Prompt: Hãy giải thích CVE-2022-47966 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 21:32 PM 22/09/2026	CVE-2022-47966 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng đến hơn 20 sản phẩm chạy tại chỗ (on-premise) của Zoho ManageEngine (như ServiceDesk Plus, ADSelfService Plus, Endpoint Central, Password Manager Pro, v.v.). Dưới đây là thông tin chi tiết: 1. Description (Mô tả) Bản chất: Lỗ hổng Unauthenticated Remote Code Execution (RCE) (Thực thi mã lệnh từ xa không cần xác thực). Cơ chế: Lỗ hổng xuất phát từ việc các sản phẩm của ManageEngine sử dụng thư viện bên thứ ba đã lỗi thời là Apache Santuario xmlsec (XML Security for Java) phiên bản 1.4.1. Thư viện này thực hiện các phép biến đổi XSLT trong quá trình xử lý chữ ký số SAML trước khi xác thực. Kẻ tấn công có thể gửi một yêu cầu SAML độc hại được tinh chỉnh sẵn để lợi dụng điểm yếu này, buộc ứng dụng thực thi mã Java tùy ý. Điều kiện khai thác: Lỗ hổng chỉ xảy ra nếu hệ thống mục tiêu đang bật tính năng đăng nhập một lần SAML	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đú ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính thức của lỗi và các bài báo liên quan đến lỗi. Các thông tin chưa được xác thực cần được loại bỏ khỏi báo cáo.

	SSO, hoặc thậm chí đã từng bật tính năng này ít nhất một lần trong quá khứ (tùy thuộc vào từng sản phẩm cụ thể). 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Không cần tài khoản hay quyền hạn (Unauthenticated), độ phức tạp thấp, khai thác từ xa qua mạng. Lỗ hổng này đã bị các nhóm tấn công khai thác rộng rãi trên thực tế (In-the-wild) và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog). 3. Consequences (Hậu quả) Khi bị khai thác thành công, kẻ tấn công có thể: Thực thi mã lệnh tùy ý (RCE): Chạy các lệnh hệ điều hành dưới quyền của tiến trình ứng dụng ManageEngine (thường có đặc quyền cao trên hệ thống). Kiểm soát toàn bộ máy chủ: Cài cắm webshell, tạo tài khoản quản trị ẩn, đánh cắp thông tin nhạy cảm. Xâm nhập sâu hơn (Lateral Movement): Do các sản phẩm ManageEngine thường		cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ	
--	--	--	---	--

	nằm sâu trong mạng nội bộ và có quyền quản lý thiết bị rộng, kẻ xấu có thể dùng máy chủ này làm bàn đạp để kiểm soát toàn bộ hạ tầng mạng của doanh nghiệp. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng cấp các sản phẩm ManageEngine bị ảnh hưởng lên các phiên bản đã được vá lỗi chính thức từ nhà sản xuất (ví dụ: ServiceDesk Plus lên build 14004, ADSelfService Plus lên build 6211 trở lên). Giải pháp tạm thời (Nếu chưa thể cập nhật ngay): Tạm thời vô hiệu hóa tính năng SAML SSO trên các sản phẩm nếu không thực sự bắt buộc phải sử dụng. Giới hạn quyền truy cập mạng, chặn tuyệt đối việc phơi bày giao diện quản trị của các ứng dụng ManageEngine ra Internet công cộng (chỉ cho phép truy cập từ mạng nội bộ đáng tin cậy).		a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hệ u qu ả Ge mi ni đư a ra kh ôn g hề có bả ng ch ứn g hà y lin k dẫ n ch ứn g	
--	---	--	--	--

			cụ th ể nà o.	
Artifact #23 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2022-47966 Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Không cần tài khoản hay quyền hạn (Unauthenticated), độ phức tạp thấp, khai thác từ xa qua mạng. Lỗ hổng này đã bị các nhóm tấn công khai thác rộng rãi trên thực tế (In-the-wild) và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog). Consequences (Hậu quả) Khi bị khai thác thành công, kẻ tấn công có thể: Thực thi mã lệnh tùy ý (RCE): Chạy các lệnh hệ điều hành dưới quyền của tiến trình ứng dụng ManageEngine (thường có đặc quyền cao trên hệ thống). Kiểm soát toàn bộ máy chủ: Cài cắm webshell, tạo tài khoản quản trị ẩn, đánh cắp thông tin nhạy cảm. Xâm nhập sâu hơn (Lateral Movement): Do các sản phẩm ManageEngine thường nằm sâu trong mạng nội bộ và có quyền quản lý thiết bị rộng, kẻ xấu có thể dùng máy chủ này làm bàn đạp để kiểm soát toàn bộ hạ tầng mạng của doanh nghiệp. Tool: ChatGPT Timestamp: 21:50 PM 22/09/2026	Mình đã kiểm chứng output Gemini của bạn với ManageEngine Advisory và CISA. Với #5 này, output Gemini thực ra có một số điểm rất đáng chú ý vì có cả phần đúng, suy diễn quá mức, và một số chi tiết mà CISA thực tế xác nhận trong incident. Đánh giá của sinh viên Đánh giá của sinh viên: AI đã xác định đúng các thông tin chính về CVE-2022-47966, bao gồm việc đây là lỗ hổng Remote Code Execution không cần xác thực trong nhiều sản phẩm ManageEngine On-Premise, có liên quan đến thư viện Apache Santuario và chỉ áp dụng khi SAML SSO được cấu hình/đã được bật tùy theo sản phẩm. ManageEngine xác nhận lỗ hổng cho phép unauthenticated adversary thực thi arbitrary code và đã được khắc phục bằng cách cập nhật third-party module.	V A L I D	IS TQ B đề cậ p để n việ c lự a ch ọn và sử d n g cá c cô n g cụ hỗ tr ợ ki ế m th ử để cải th i ệ n h i ệ u qu á và h i ệ u s u	Đọc lại những dẫn chứng, chứng cứ trong link AI đưa ra, cũng như trang lỗi chính thức để so sánh với output rồi đưa vào báo cáo. Chỉnh sửa và đưa vào báo cáo: những hậu quả

	Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi trình bày một số hậu quả như “thường có đặc quyền cao trên hệ điều hành”, “cài cắm webshell”, “tạo tài khoản quản trị ẩn” và “dùng máy chủ làm bàn đạp để kiểm soát toàn bộ hạ tầng” như những hậu quả tất yếu của lỗ hổng. Các hành động này không phải đều là impact trực tiếp được ManageEngine Advisory xác nhận. Tuy nhiên, khi đối chiếu với báo cáo CISA, một số hành động mà AI đề cập thực tế đã được quan sát trong một vụ khai thác CVE-2022-47966. CISA ghi nhận attacker đạt root-level access, tạo tài khoản local có quyền administrator, tải malware, thu thập credential và thực hiện lateral movement sau khi khai thác ServiceDesk Plus. Vì vậy, các nội dung này không nên được gọi hoàn toàn là hallucination; vấn đề chính là AI không phân biệt rõ impact của vulnerability với các hành động post-exploitation được quan sát trong một incident cụ thể. AI cũng đưa ra các phiên bản cụ thể như	ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả n ch ất lỗi và đư a ra nh ữn g bả n g ch ứn g cũ ng nh ư lĩn k rõ rà ng mi nh bạ ch. AI giả	trên không phải là những ảnh hưởng trực tiếp mà ManageEngine Advisory xác nhận . Nên là AI chưa phân biệt được tác động của lỗ hổng bảo mật với các hành động sau khi đã khai thác.
--	---	---	--

	ServiceDesk Plus build 14004 và ADSelfService Plus build 6211. Các phiên bản này thực tế phù hợp với advisory của ManageEngine, nên phần này không phải hallucination. ManageEngine xác nhận ServiceDesk Plus 14003 trở xuống được sửa ở 14004 và ADSelfService Plus 6210 trở xuống được sửa ở 6211. Kết luận: Output của AI được đánh giá là INCOMPLETE. AI cung cấp phần lớn thông tin chính xác nhưng cần chỉnh sửa cách trình bày hậu quả để phân biệt giữa khả năng trực tiếp của CVE và các hoạt động được quan sát sau khi hệ thống bị compromise. Bản ngắn để đưa vào bảng 20 defects Đánh giá của sinh viên: AI xác định đúng CVE-2022-47966 là lỗ hổng unauthenticated RCE trong các sản phẩm ManageEngine sử dụng Apache Santuario và thông tin về SAML SSO, CVSS 9.8 và bản vá nhìn chung chính xác. Tuy nhiên, AI trình bày các hành động như webshell, credential theft và lateral movement như	i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	
--	--	--	--

	hậu quả trực tiếp của CVE mà không phân biệt với các hoạt động post-exploitation. CISA thực tế đã ghi nhận các hoạt động này trong một incident cụ thể, nên đây là overstatement/incomplete context hơn là hallucination hoàn toàn. Nguồn tham khảo: https://www.manaengine.com/security/advisory/CVE/cve-2022-47966.html?utm_source=chatgpt.com			
Artifact #24 Prompt: Hãy giải thích CVE-2023-34362 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 22:03 PM 22/09/2026	CVE-2023-34362 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng đến phần mềm quản lý truyền tải tệp tin Progress MOVEit Transfer (và MOVEit Cloud). Lỗ hổng này từng gây ra một làn sóng tấn công quy mô lớn trên toàn cầu do nhóm ransomware nổi tiếng Clonp thực hiện. Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục: 1. Description (Mô tả) Bản chất: Đây là lỗ hổng SQL Injection (SQLi) nằm trong ứng dụng web MOVEit Transfer.	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tín về ea ch de fec t đủ ng vớ i	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính thức của lỗi và các

	Cơ chế: Lỗ hổng cho phép kẻ tấn công gửi các HTTP/HTTPS request được thiết kế đặc biệt chứa các đoạn mã SQL độc hại tới các endpoint của MOVEit Transfer. Do thiếu cơ chế lọc và xác thực dữ liệu đầu vào đúng cách, hệ thống cho phép truy vấn trực tiếp vào cơ sở dữ liệu phía sau (hỗ trợ các engine như MySQL, Microsoft SQL Server hoặc Azure SQL). Điểm đáng chú ý: Lỗ hổng này hoàn toàn không cần xác thực (unauthenticated). Kẻ tấn công từ bên ngoài Internet có thể kết nối thẳng đến ứng dụng và khai thác thành công mà không cần tài khoản hay quyền hạn ban đầu. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng, khai thác từ xa qua mạng. Đây là một lỗ hổng dạng zero-day từng bị lợi dụng hàng loạt trên thực tế trước khi có bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog).	pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ế m th ử đề cải thi ện hi ệu qu ả và hi ệu su ất. Tu y	bài báo liên quan đến lỗi. Các thông tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	---	---

	3. Consequences (Hậu quả) Khi khai thác thành công CVE-2023-34362, kẻ tấn công có thể thực hiện một chuỗi tấn công (exploit chain) gây ra hậu quả tàn khốc: Truy cập và trích xuất cơ sở dữ liệu: Đọc, đánh cắp toàn bộ thông tin nhạy cảm lưu trữ trong cơ sở dữ liệu (thông tin người dùng, cấu hình, dữ liệu tệp tin doanh nghiệp). Triển khai Web Shell (Cài cắm cửa hậu): Kẻ tấn công tải lên các tệp mã độc (ví dụ: mã độc tùy chỉnh như LEMURLOOT hay các webshell .aspx) để duy trì quyền truy cập lâu dài và điều khiển máy chủ từ xa. Ransomware & Tổng tiền doanh nghiệp (Extortion): Bị lợi dụng chủ yếu bởi nhóm Clop để đánh cắp lượng lớn dữ liệu nội bộ của hàng loạt cơ quan chính phủ, tập đoàn tài chính, y tế lớn trên toàn cầu nhằm tống tiền. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng cấp ngay lập tức phần mềm MOVEit Transfer lên các phiên bản đã được Progress Software phát hành bản vá chính thức (ví dụ: các phiên bản 2021.0.6, 2021.1.4,		nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hạ u qu ả Ge mi ni
--	--	--	---

	2022.0.4, 2022.1.5, 2023.0.1 trở lên tùy thuộc vào nhánh sản phẩm đang sử dụng). Giải pháp tạm thời / Phòng ngừa bổ sung: Chặn lưu lượng HTTP/HTTPS: Nếu chưa thể nâng cấp ngay, tạm thời chặn toàn bộ lưu lượng HTTP và HTTPS truy cập vào cổng MOVEit Transfer (chặn port 80 và 443 ở tường lửa), chỉ cho phép sử dụng các giao thức an toàn khác nếu bắt buộc hoặc quản trị qua Remote Desktop nội bộ. Kiểm tra dấu hiệu xâm nhập (IoC): Rà soát hệ thống tệp tin trong thư mục gốc (wwwroot) để tìm kiếm các webshell lạ (ví dụ các tệp .aspx bất thường hoặc tệp có tên dạng human2.aspx), kiểm tra nhật ký truy cập (logs) xem có hành vi truy vấn cơ sở dữ liệu đáng ngờ hay không.		đư a ra kh ôn g hề có bằ ng ch ứn g ha y lin k dẫ n ch ứn g cụ th ể nà o.	
Artifact #25 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2023-34362 Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng, khai thác từ xa qua mạng. Đây là một lỗ hổng dạng zero-day từng bị lợi dụng hàng loạt trên thực tế trước khi có bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog). Consequences (Hậu quả)	Đánh giá output Gemini này thì không nên đánh giá là INVALID. Phần lớn thông tin cốt lõi đúng, nhưng có một số chỗ AI diễn đạt quá mức hoặc đưa chi tiết chưa được nguồn chính thức xác nhận đầy đủ. Đánh giá của sinh viên:	V A LI D	IS TQ B đề cậ p để n việ c lự a ch on và	Đọc lại nhữn g dẫn chứn g, chứn g cứ trong link AI đưa ra, cũng như

Khi khai thác thành công CVE-2023-34362, kẻ tấn công có thể thực hiện một chuỗi tấn công (exploit chain) gây ra hậu quả tàn khốc: Truy cập và trích xuất cơ sở dữ liệu: Đọc, đánh cắp toàn bộ thông tin nhạy cảm lưu trữ trong cơ sở dữ liệu (thông tin người dùng, cấu hình, dữ liệu tệp tin doanh nghiệp). Triển khai Web Shell (Cài cắm cửa hậu): Kẻ tấn công tải lên các tệp mã độc (ví dụ: mã độc tùy chỉnh như LEMURLOOT hay các webshell.aspx) để duy trì quyền truy cập lâu dài và điều khiển máy chủ từ xa. Ransomware & Tổng tiền doanh nghiệp (Extortion): Bị lợi dụng chủ yếu bởi nhóm Clop để đánh cắp lượng lớn dữ liệu nội bộ của hàng loạt cơ quan chính phủ, tập đoàn tài chính, y tế lớn trên toàn cầu nhằm tống tiền. Tool: ChatGPT Timestamp: 22:15 PM 22/09/2026	AI đã xác định đúng loại lỗ hổng SQL Injection, tính chất unauthenticated, khả năng truy cập trái phép vào cơ sở dữ liệu và việc CVE-2023-34362 được khai thác thực tế. CISA xác nhận lỗ hổng có thể cho phép truy cập trái phép vào database và thực hiện các SQL statement để thay đổi hoặc xóa thành phần dữ liệu. CISA cũng xác nhận lỗ hổng đã được sử dụng trong ransomware campaign và ghi nhận webshell LEMURLOOT được triển khai trong các cuộc tấn công MOVEit. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi trình bày một số hậu quả như “đánh cắp toàn bộ thông tin”, “tống tiền hàng loạt cơ quan, tập đoàn trên toàn cầu” như hậu quả trực tiếp và tất yếu của CVE. Các nguồn chính thức chỉ xác nhận khả năng truy cập và thao tác database; việc đánh cắp dữ liệu, triển khai LEMURLOOT và ransomware là các hoạt động được quan sát trong chiến dịch khai thác thực tế, không nên mô tả tất cả là hậu quả trực tiếp mà mọi lần khai thác CVE đều tạo ra.	sử dụng cá c công cụ hỗ trợ kỹ thuật để cải thiện hiệu suất. Do đó, tôi ở trình độ chuyên gia AI xác định được những điểm chính xác nhất	trang lỗi chính thức để so sánh với output đưa vào báo cáo. Chỉnh sửa và đưa vào báo cáo: AI có dấu hiệu bị ảo giác vì khả năng đánh cắp toàn bộ dữ liệu hay tống tiền doanh nghiệp đều chưa thấy các trang chính thức xác nhận.
---	--	---	--

	Ngoài ra, AI đưa ra một số chi tiết về phiên bản và như 2021.0.6, 2021.1.4 nhưng nguồn Progress mà tôi đối chiếu xác nhận các nhánh phiên bản trước bản và ngày 16/06/2023 là vulnerable và xác nhận các bản sửa như 2022.0.4, 2022.1.5, 2023.0.1. Vì vậy cần kiểm tra lại danh sách phiên bản cụ thể trước khi đưa vào báo cáo. Điểm quan trọng nhất của case này là: Gemini không “bịa hoàn toàn” về LEMURLOOT hay Clop. CISA thực sự xác nhận các thông tin đó. Lỗi của Gemini nằm chủ yếu ở cách khái quát hóa và trộn vulnerability impact với post-exploitation impact. Đây chính là một ví dụ khá tốt để ghi nhận AI hallucination/overstatement trong bài của bạn. Nguồn tham khảo: https://www.progress.com/docs/default-source/moveit-docs/moveit-transfer_moveit-cloud-vulnerabilities-customer-faq_posted.pdf?sfvrsn=16a47a99_13&u	lỗi và đưa ra những bằng chứng cũ hơn nên tôi đã lấy phần giải pháp tối ưu của AI.
--	---	---

	tm_source=chatgpt.com https://www.cisa.gov/sites/default/files/2023-06/aa23-158a-stopransomware-cl0p-ransomware-gang-exploits-moveit-vulnerability_2.pdf?utm_source=chatgpt.com		ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	
--	--	--	---	--

Artifact #26 Prompt: Hãy giải thích CVE-2023-25136 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 22:18 PM 22/09/2026	CVE-2023-25136 là một lỗ hổng bảo mật ảnh hưởng đến OpenSSH server (sshd), cụ thể xuất hiện trên phiên bản 9.1. Dưới đây là thông tin chi tiết về mô tả, mức độ nghiêm trọng, hậu quả và giải pháp khắc phục: 1. Description (Mô tả) Bản chất: Đây là một lỗi Double-Free (Giải phóng bộ nhớ hai lần) được định danh theo CWE-415, xảy ra trong quá trình xử lý các thuật toán trao đổi khóa (options.kex_algorithms) của OpenSSH. Cơ chế: Lỗi xuất phát từ đoạn mã lọc và xử lý tham số thuật toán trao đổi khóa (compat.c), nơi hàm xử lý không trả về con trỏ chuỗi được cấp phát động một cách nhất quán. Điều này dẫn đến việc tiến trình cố gắng giải phóng cùng một vùng nhớ hai lần. Điểm đáng chú ý: Kẻ tấn công từ xa không cần xác thực (unauthenticated) có thể gửi các gói tin kết nối SSH được tinh chỉnh đặc biệt để kích hoạt lỗ hổng này ngay trong giai đoạn thương lượng kết nối ban đầu (handshake/key exchange).	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thôn g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	--	---

	2. Severity (Mức độ nghiêm trọng) Điểm CVSS: Điểm số có sự đánh giá khác nhau tùy thuộc vào tổ chức kiểm định: Theo một số đánh giá ban đầu hoặc tính toán lý thuyết tối đa có thể lên tới 9.8 / 10.0 (Critical) do khả năng can thiệp vào bộ nhớ. Theo NVD/NIST chuẩn hóa, mức độ phổ biến thực tế được đánh giá ở mức 6.5 (Medium) hoặc cao tùy môi trường, do việc khai thác thành công đòi hỏi phải vượt qua các cơ chế bảo vệ bộ nhớ hiện đại của hệ điều hành. Đặc điểm tấn công: Tiến trình sshd ban đầu xử lý kết nối chưa xác thực nằm trong một vùng sandbox bị cô lập và không có đặc quyền cao (unprivileged), khiến việc khai thác trực tiếp để chiếm quyền hoàn toàn bị hạn chế và có độ phức tạp cao. 3. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng này có thể dẫn đến: Từ chối dịch vụ (Denial of Service - DoS): Làm hỏng cấu trúc bộ nhớ heap (heap corruption), khiến tiến trình sshd xử lý kết nối bị crash hoặc khởi động lại liên tục.		ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ	
--	--	--	---	--

	Thực thi mã lệnh từ xa (Remote Code Execution - RCE): Về mặt lý thuyết, việc thao túng lỗi double-free có thể giúp kẻ tấn công điều hướng vùng nhớ thực thi của chương trình. Tuy nhiên, việc này rất khó thực hiện trên thực tế do các cơ chế bảo vệ bộ nhớ hiện đại (như ASLR, safe allocators). 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng cấp phần mềm OpenSSH lên phiên bản 9.2 hoặc các phiên bản cao hơn (nơi lỗi xử lý bộ nhớ đã được vá hoàn toàn). Các hệ điều hành hoặc bản phân phối sử dụng OpenSSH 9.1 (như một số nhánh của OpenBSD 7.2, Fedora 37/38...) cần áp dụng bản cập nhật từ nhà phát triển. Giải pháp tạm thời / Phòng ngừa bổ sung: Giới hạn quyền truy cập mạng đến cổng SSH (Port 22), chỉ cho phép các dải IP nội bộ hoặc đáng tin cậy kết nối thông qua tường lửa. Sử dụng hệ thống phòng thủ biên, bastion host (máy chủ trung gian) để giảm thiểu việc phơi bày dịch vụ SSH trực tiếp ra Internet công cộng.		B (thôn g tin ch ưa xá c nh ận) bở i vì m ột số hậ u qu ả Ge mi ni đư a ra kh ôn g hê có bằ ng ch ứn g ha y lin k đẫ n ch ứn g cụ th ể	
--	--	--	--	--

			na o.	
Artifact #27 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2023-25136 Severity (Mức độ nghiêm trọng) Điểm CVSS: Điểm số có sự đánh giá khác nhau tùy thuộc vào tổ chức kiểm định: Theo một số đánh giá ban đầu hoặc tính toán lý thuyết tối đa có thể lên tới 9.8 / 10.0 (Critical) do khả năng can thiệp vào bộ nhớ. Theo NVD/NIST chuẩn hóa, mức độ phổ biến thực tế được đánh giá ở mức 6.5 (Medium) hoặc cao tùy	Output Gemini này khá sát nguồn, nhưng có một lỗi quan trọng ở phần Severity. Đánh giá của sinh viên: AI đã xác định đúng CVE-2023-25136 là lỗi double-free (CWE-415) trong OpenSSH	V A LI D	IS TQ B đề cậ p để n việ c lự a	Đọc lại nhữn g dẫn chứn g, chứn g cứ trong link AI đưa

môi trường, do việc khai thác thành công đòi hỏi phải vượt qua các cơ chế bảo vệ bộ nhớ hiện đại của hệ điều hành. Đặc điểm tấn công: Tiến trình sshd ban đầu xử lý kết nối chưa xác thực nằm trong một vùng sandbox bị cô lập và không có đặc quyền cao (unprivileged), khiến việc khai thác trực tiếp để chiếm quyền hoàn toàn bị hạn chế và có độ phức tạp cao. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng này có thể dẫn đến: Từ chối dịch vụ (Denial of Service - DoS): Làm hỏng cấu trúc bộ nhớ heap (heap corruption), khiến tiến trình sshd xử lý kết nối bị crash hoặc khởi động lại liên tục. Thực thi mã lệnh từ xa (Remote Code Execution - RCE): Về mặt lý thuyết, việc thao túng lỗi double-free có thể giúp kẻ tấn công điều hướng vùng nhớ thực thi của chương trình. Tuy nhiên, việc này rất khó thực hiện trên thực tế do các cơ chế bảo vệ bộ nhớ hiện đại (như ASLR, safe allocators). Tool: ChatGPT Timestamp: 22:36 PM 22/09/2026	sshd 9.1, xảy ra ở giai đoạn pre-authentication và có thể bị kích hoạt từ xa mà không cần authentication. AI cũng xác định đúng rằng lỗi được sửa trong OpenSSH 9.2 và việc khai thác RCE chỉ được mô tả ở mức lý thuyết. NVD hiện đánh giá CVSS 3.1 là 6.5 - Medium, với vector AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:H. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi nói rằng CVSS “có thể lên tới 9.8/Critical” và mô tả đây là một khả năng đánh giá “tùy tổ chức”. Trong các nguồn chính được kiểm tra, NVD ghi nhận 6.5 Medium, còn OpenSSH cho biết lỗ hổng không được tin là có thể khai thác do tiến trình pre-auth chạy không đặc quyền và được sandbox. Ngoài ra, AI mô tả DoS và RCE như những hậu quả có thể xảy ra nếu khai thác thành công; phần RCE cần được nhấn mạnh là theoretical, còn OpenSSH không xác nhận khả năng khai thác thực tế. Case này là một ví dụ khá rõ cho AI overstatement: Gemini không sai ở	ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả	ra, cũng như trang lỗi chín h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI đang đánh giá quá mức về sever ity khi cho CVS S tới 9.8 Critic al và mô tả là tùy thuộc vào tổ chức. Tron g khi nguồn n
--	--	--	--

	bản chất lỗ hổng, nhưng đã đưa thêm một mức độ nghiêm trọng không phù hợp với đánh giá NVD hiện tại. Nguồn tham khảo: https://www.openssh.org/security.html?utm_source=chatgpt.com https://nvd.nist.gov/vuln/detail/cve-2023-25136?utm_source=chatgpt.com	n ch ất lỗi và đư a ra nh ữn g bả ng ch ứn g cũ ng nh ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut.	chính thức NVD chỉ đánh giá 6.5 Medium. Đây có khả năng là ảo giác AI vì đã đánh giá mức độ nghiê m trọng khôn g phù hợp.
--	---	---	--

			AI đã cung cấp đầy đủ thông tin cần thiết.	
Artifact #28 Prompt: Hãy giải thích CVE-2023-4863 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 22:40 PM 22/09/2026	CVE-2023-4863 là một lỗ hổng bảo mật rất nổi tiếng liên quan đến thư viện mã nguồn mở chuyên xử lý ảnh WebP (libwebp), ảnh hưởng trực tiếp đến trình duyệt Google Chrome và hàng loạt ứng dụng sử dụng framework Chromium hoặc các phần mềm đồ họa khác trên toàn cầu. 1. Description (Mô tả) Bản chất: Đây là lỗ hổng Heap-Based Buffer Overflow (Tràn bộ đệm vùng nhớ heap). Cơ chế: Lỗi xuất hiện trong cách libwebp xử lý dữ liệu nén ảnh không mất dữ liệu (lossless compression), cụ thể là trong quá trình phân tích cú pháp bảng mã Huffman cho kênh alpha. Khi một tệp ảnh WebP độc hại được tạo ra với cấu trúc tinh chỉnh sẵn,	INCOPELITE	AI cung cấp đầy đủ những thông tin về cách thức hoạt động của lỗ hổng và các bài báo liên quan đến lỗi. Các	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo khẩn cấp của lỗi và các bài báo liên quan đến lỗi. Các thôn

	việc giải mã sẽ ghi dữ liệu vượt quá giới hạn vùng nhớ đã cấp phát động (heap). Điểm đáng chú ý: Kẻ tấn công có thể khai thác lỗ hổng này từ xa bằng cách lừa người dùng truy cập vào một trang web độc hại chứa tệp ảnh WebP dàn dựng sẵn (crafted HTML/image page). 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 8.8 / 10.0 (Mức High - Cao, tuy nhiên do tính chất lan rộng và khả năng kết hợp tấn công Zero-day, nó từng được các hãng công nghệ đánh giá mức độ nguy hiểm ngang hàng mức Critical). Đặc điểm tấn công: Yêu cầu nạn nhân tương tác (mở trang web hoặc tệp ảnh chứa mã độc), nhưng diễn ra hoàn toàn tự động trong nền trình duyệt. Lỗ hổng này từng bị lợi dụng làm zero-day trên thực tế (In-the-wild) trong các chiến dịch tấn công spyware tình vi (như chuỗi khai thác BLASTPASS nhắm vào thiết bị Apple) trước khi được vá khẩn cấp. 3. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng có thể dẫn đến: Từ chối dịch vụ (Denial of Service - DoS): Làm sập ứng		cập p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ế m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng	g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	--	--	---	--

	dụng/trình duyệt đang đọc tệp ảnh. Thực thi mã lệnh tùy ý (Remote Code Execution - RCE): Kẻ tấn công có thể vượt qua ranh giới bộ nhớ để chạy mã lệnh tùy ý trên hệ thống của người dùng (trong môi trường có bảo vệ sandbox, mức độ ảnh hưởng có thể bị giới hạn tùy thuộc vào ứng dụng tích hợp). 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật phiên bản mới nhất cho các phần mềm sử dụng thư viện libwebp: Đối với Google Chrome: Nâng cấp lên phiên bản 116.0.5845.187 hoặc cao hơn. Đối với các ứng dụng, trình duyệt dựa trên Chromium (Edge, Brave, Firefox, Opera...) hoặc các thư viện lập trình có sử dụng libwebp: Nâng cấp libwebp lên phiên bản 1.3.2 trở lên.		uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hệ u qu ả Ge mi ni đư a ra kh ôn g hề có	
--	---	--	--	--

			bằng chứng hay link dẫn chứng cụ thể nào.	
Artifact #29 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2023-4863 Điểm CVSS: 8.8 / 10.0 (Mức High - Cao, tuy nhiên do tính chất lan rộng và khả năng kết hợp tấn công Zero-day, nó từng được các hãng công nghệ đánh giá mức độ nguy hiểm ngang hàng mức Critical). Đặc điểm tấn công: Yêu cầu nạn nhân tương tác (mở trang web hoặc tệp ảnh chứa mã độc), nhưng diễn ra hoàn toàn tự động trong nền trình duyệt. Lỗ hổng này từng bị lợi dụng làm zero-day trên thực tế (In-the-wild) trong các chiến dịch tấn công spyware tinh vi (như chuỗi khai thác BLASTPASS nhắm vào thiết bị Apple) trước khi được vá khẩn cấp. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng có thể dẫn đến: Từ chối dịch vụ (Denial of Service - DoS): Làm sập ứng dụng/trình duyệt đang đọc tệp ảnh. Thực thi mã lệnh tùy ý (Remote Code Execution - RCE): Kẻ tấn công có thể vượt qua ranh giới bộ nhớ để chạy mã lệnh tùy ý trên hệ thống của người dùng (trong môi trường có bảo vệ sandbox, mức độ ảnh hưởng có thể bị giới hạn tùy thuộc vào ứng dụng tích hợp). Tool: ChatGPT Timestamp: 22:53 PM 22/09/2026	Output này nhìn chung đúng phần cốt lõi, nhưng có một số chỗ Gemini đã trộn thông tin được xác nhận với suy luận kỹ thuật. Đánh giá của sinh viên: AI đã xác định đúng CVE-2023-4863 là lỗi heap buffer overflow trong WebP/libwebp, có thể gây out-of-bounds memory write thông qua nội dung WebP được tạo đặc biệt. AI cũng xác định đúng mức CVSS 8.8 - High theo NVD, Chrome trước 116.0.5845.187 và libwebp trước 1.3.2 bị ảnh hưởng. Google đánh giá lỗ hổng ở mức Critical và xác nhận exploit đã tồn tại in the wild.	V A L I D	IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ế m th ử	Đọc lại những dẫn chứng, chứng cứ trong link AI đưa ra, cũng như trang lỗi chính thức để so sánh với output rồi đưa vào báo cáo. Chỉnh sửa

	Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi khẳng định việc khai thác thành công có thể trực tiếp dẫn đến Remote Code Execution (RCE). NVD mô tả tác động được xác nhận là attacker có thể thực hiện out-of-bounds memory write, nhưng không trực tiếp xác nhận rằng CVE này tự nó đảm bảo khả năng RCE. Vì vậy, RCE nên được trình bày là một hậu quả tiềm năng của memory corruption chứ không phải kết quả đã được nguồn NVD xác nhận cho mọi trường hợp khai thác. Ngoài ra, AI liên hệ trực tiếp CVE-2023-4863 với chiến dịch BLASTPASS nhưng không cung cấp nguồn để phân biệt rõ giữa CVE này và exploit chain ban đầu được nghiên cứu trên hệ sinh thái Apple. Đây là thông tin cần được kiểm chứng riêng thay vì trình bày như một đặc tính trực tiếp của CVE-2023-4863. Một chi tiết đáng chú ý cho bài của bạn: 8.8 High và Critical không mâu thuẫn. 8.8 High là đánh giá CVSS của NVD, còn Critical là		để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả n ch ất lỗi và đư a ra nh ữn g bằ ng ch ứn g cũ ng nh	và đưa vào báo cáo: AI đang bị ảo giác vì cho rằng khi khai thác thành công sẽ dẫn đến khả năng thực thi mã lệnh tùy ý (Remote Code Execution - RCE). Đây là hậu quả mà AI nghĩ ra chứ nguồn NVD chưa xác nhận kết
--	---	--	--	--

	Chromium security severity. Nguồn tham khảo: https://nvd.nist.gov/vuln/detail/cve-2023-4863?utm_source=chatgpt.com		ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	quả này.
--	--	--	---	-------------

Artifact #30 Prompt: Hãy giải thích CVE-2023-22515 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 23:11 PM 22/09/2026	CVE-2023-22515 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng trực tiếp đến các phiên bản Atlassian Confluence Server và Data Center. 1. Description (Mô tả) Bản chất: Đây là lỗi Broken Access Control (Kiểm soát truy cập bị hỏng), cho phép vượt qua cơ chế xác thực để thao túng cấu hình ứng dụng. Cơ chế: Do cách Confluence xử lý các tham số yêu cầu HTTP, kẻ tấn công có thể gửi các request được tinh chỉnh đặc biệt đến endpoint công khai (như server-info.action) để ép hệ thống hiểu nhầm rằng tiến trình cài đặt ban đầu chưa hoàn tất (setupComplete=false). . Thao tác này lừa ứng dụng mở lại trang thiết lập hệ thống từ đầu, cho phép bất kỳ ai cũng có thể tự tạo một tài khoản quản trị mới. Điểm đáng chú ý: Lỗ hổng hoàn toàn không cần xác thực (unauthenticated) và không yêu cầu quyền hạn trước đó. Kẻ tấn công chỉ cần kết nối mạng tới máy chủ Confluence là có thể khai thác. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 10.0 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng - mức tối	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch ef ect đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thông tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
---	---	---	---	--

	đa theo thang đo CVSS). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng. Lỗ hổng này từng bị khai thác dạng zero-day rộng rãi trên thực tế bởi các nhóm tấn công mạng trước khi Atlassian phát hành bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA. 3. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng mang lại hậu quả nặng nề: Leo thang đặc quyền trái phép: Kẻ tấn công tự tạo được tài khoản với quyền Administrator tối cao trên hệ thống Confluence. Kiểm soát toàn bộ dữ liệu: Dễ dàng truy cập, đánh cắp, sửa đổi toàn bộ tài liệu, thông tin nội bộ doanh nghiệp lưu trữ trong không gian làm việc của Confluence. Bàn đạp tấn công sâu hơn (Lateral Movement): Kẻ xấu có thể cài cắm mã độc, plug-in độc hại hoặc dùng quyền quản trị này để mở rộng phạm vi xâm nhập sang các hệ thống nội bộ khác kết nối với máy chủ Confluence. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng		cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (	
--	--	--	--	--

	cấp/cập nhật phiên bản Confluence Server và Data Center lên các phiên bản đã được vá lỗi từ hãng (từ các phiên bản 8.3.3, 8.4.3, 8.5.2 trở lên hoặc các bản LTS mới hơn). Giải pháp tạm thời (Nếu chưa thể nâng cấp ngay): Cô lập máy chủ, chặn hoàn toàn quyền truy cập mạng từ bên ngoài (Internet) vào ứng dụng Confluence, chỉ cho phép truy cập nội bộ. Kiểm tra kỹ hệ thống (nhật ký truy cập - logs) để tìm kiếm các tài khoản quản trị lạ hoặc dấu hiệu bất thường nhằm rà soát xem hệ thống đã từng bị xâm nhập hay chưa.		th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hạ u qu ả Ge mi ni đư a ra kh ôn g hề có bả ng ch ứn g ha y lin k dẫ n ch ứn g cụ th ể	
--	---	--	---	--

			nà o.	
Artifact #31 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2023-22515 Severity (Mức độ nghiêm trọng) Điểm CVSS: 10.0 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng - mức tối đa theo thang đo CVSS). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng. Lỗ hổng này từng bị khai thác dạng zero-day rộng rãi trên thực tế bởi các nhóm tấn công mạng trước khi Atlassian phát hành bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng mang lại hậu quả nặng nề: Leo thang đặc quyền trái phép: Kẻ tấn công tự tạo được tài khoản với quyền Administrator tối cao trên hệ thống Confluence. Kiểm soát toàn bộ dữ liệu: Dễ dàng truy cập, đánh cắp, sửa đổi toàn bộ tài liệu, thông tin nội bộ doanh nghiệp lưu trữ trong không gian làm việc của Confluence. Bàn đạp tấn công sâu hơn (Lateral Movement): Kẻ xấu có thể cài cắm mã độc, plug-in độc hại hoặc dùng quyền quản trị này để mở rộng phạm vi xâm nhập sang các hệ thống nội bộ khác kết nối với máy chủ Confluence. Tool: ChatGPT Timestamp: 23:47 PM 22/09/2026	Output Gemini này khá chính xác , nhưng vẫn có vài chỗ bị phóng đại. Với tiêu chí bài của bạn là phải tìm ra AI hallucination/bias , tôi sẽ đánh giá là INCOMPLETE . Đánh giá của sinh viên: AI đã xác định đúng CVE-2023-22515 là lỗ hổng Broken Access Control trong Confluence Data Center và Server, cho phép attacker chưa xác thực tạo tài khoản Confluence Administrator trái phép. AI cũng xác định đúng mức độ Critical, CVSS 10.0 , việc lỗ hổng đã bị khai thác thực tế và các phiên bản đã được Atlassian vá. Atlassian và CISA đều xác nhận các thông tin này. Tuy nhiên, AI có dấu hiệu overstatement khi mô tả attacker có thể “kiểm soát toàn bộ dữ liệu”, “cài cắm mã độc, plug-in độc hại” và thực hiện “lateral movement” như những hậu quả trực tiếp của CVE. Nguồn Atlassian và CISA chủ yếu xác nhận khả năng tạo tài khoản	V A LI D	IS TQ B đề cậ p để n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó ,	Đọc lại những dẫn chứng, chúng cứ trong link AI đưa ra, cũng như trang lỗi chín h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI đang bị ảo giác vì mô tả attac ker có thể “kiế

	Administrator trái phép và truy cập Confluence; các hành động tiếp theo cần được xem là hoạt động có thể thực hiện sau khi attacker đã có quyền Administrator, chứ không phải tác động trực tiếp được CVE đảm bảo. CISA cũng xác nhận CVE đã được sử dụng trong các ransomware campaigns, nhưng điều này không có nghĩa mọi lần khai thác đều dẫn đến toàn bộ các hậu quả mà AI liệt kê. Ngoài ra, phần mô tả rất cụ thể về endpoint server-info.action và cơ chế ép setupComplete=false cần được kiểm chứng bằng tài liệu kỹ thuật tương ứng; các nguồn chính được đối chiếu ở đây xác nhận kết quả của lỗi nhưng không cung cấp đầy đủ các chi tiết kỹ thuật này. Vì vậy không nên coi toàn bộ phần cơ chế mà AI trình bày là thông tin đã được nguồn chính xác nhận. Điểm này khá tốt để đưa vào bài vì Gemini không sai hoàn toàn; lỗi nằm ở việc nó mở rộng hậu quả vượt quá những gì nguồn chính thức trực tiếp xác nhận.	tôi nh ờ tr ợ gi úp AI xá c đị nh đ ng b n ch ất l và đ a ra nh ữn g b ng ch ứn g cũ ng nh ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ	m soát toàn bộ dữ liệu”, “cài cắm mã độc, plug- in độc hại” và thực hiện “late ral move ment ”. Các hành động này có thể xảy ra sau khi attac ker đã có quyề n Admi nistr ator chứ chưa phải là tác động trực tiếp của CVE này. Và
--	---	--	---

	Nguồn tham khảo: https://confluence.atlassian.com/security/data-center-and-server-1295682276.html?utm_source=chatgpt.com		thể chỉ tiết t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	cũng chưa chắc đúng hết nếu mỗi lần khai thác đều dẫn đến kết quả mà AI đã liệt kê trên
Artifact #32 Prompt: Hãy giải thích CVE-2023-6345 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 11:01 AM 23/09/2026	CVE-2023-6345 là một lỗi hổng bảo mật nghiêm trọng liên quan đến thư viện đồ họa mã nguồn mở Skia, được sử dụng rộng rãi làm công cụ dựng hình (graphics engine) trong Google Chrome, hệ điều hành ChromeOS, Android và nhiều ứng dụng dựa trên nền tảng Chromium khác. 1. Description (Mô tả) Bản chất: Đây là lỗi hổng Integer Overflow (Tràn số nguyên) được	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch	Dựa vào các thôn g tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thôn

	định danh theo CWE-190, xảy ra trong thư viện đồ họa Skia (cụ thể tại hàm xử lý lưới MeshOp::onCombineIf Possible). Cơ chế: Khi trình duyệt xử lý dữ liệu hình ảnh hoặc cấu trúc đồ họa phức tạp (đặc biệt là tệp đồ họa chứa các thao tác vẽ đa giác/đỉnh), các phép tính toán kích thước bộ nhớ bị tràn số nguyên, dẫn đến việc hệ thống cấp phát một vùng nhớ heap quá nhỏ so với thực tế. Khi dữ liệu thực tế được ghi đè vào, nó gây ra hiện tượng ghi tràn bộ đệm (Heap Out-of-Bounds Write). Điểm đáng chú ý: Kẻ tấn công thường lợi dụng lỗ hổng này như một bước đệm Sandbox Escape (Thoát khỏi vùng cách ly sandbox của trình duyệt) sau khi đã xâm nhập thành công vào tiến trình dựng hình (renderer process) bằng một lỗ hổng khác. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.6 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Yêu cầu người dùng tương tác (như truy cập vào một trang web độc hại hoặc mở tệp đồ họa/hình ảnh được thiết kế sẵn). Lỗ hổng này từng bị khai thác dạng zero-day rộng rãi		defect tính đúng ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả	g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	---	---

	trên thực tế (In-the-wild) trước khi được vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog). 3. Consequences (Hậu quả) Khi bị khai thác thành công (thường nằm trong một chuỗi tấn công phức tạp - exploit chain), kẻ tấn công có thể: Thoát khỏi Sandbox của trình duyệt: Vượt qua hàng rào bảo vệ cô lập tiến trình của Chrome để tiếp cận sâu hơn vào hệ thống bên dưới. Thực thi mã lệnh tùy ý (RCE): Chạy mã lệnh độc hại trực tiếp trên hệ điều hành của người dùng dưới quyền hạn của tiến trình ứng dụng. Kiểm soát thiết bị: Tạo cơ hội cho kẻ xấu cài cắm phần mềm độc hại, phần mềm gián điệp (spyware) hoặc đánh cắp dữ liệu cá nhân nhạy cảm. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật ngay lập tức phần mềm duyệt web lên phiên bản đã được vá lỗi từ nhà phát triển: Đối với Google Chrome: Nâng cấp lên phiên bản 119.0.6045.199 (hoặc		và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tín ch ư a xá c nh ận) bở i vì m ột số	
--	---	--	---	--

	các bản phát hành mới hơn trên kênh Stable). Đối với các trình duyệt nhân Chromium khác (như Microsoft Edge, Brave, Opera...) hoặc các ứng dụng tích hợp sẵn thư viện Skia: Áp dụng bản cập nhật bảo mật mới nhất từ nhà cung cấp tương ứng. Giải pháp phòng ngừa: Luôn bật tính năng tự động cập nhật (Auto-update) cho trình duyệt để đảm bảo các bản vá lỗi hồng bảo mật quan trọng được áp dụng kịp thời.		hậ u qu ả Ge mi ni đư a ra kh ôn g hề có bả ng ch ứn g ha y lin k dẫ n ch ứn g cụ th ể nà o.	
Artifact #33 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2023-6345 Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.6 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Yêu cầu người dùng tương tác (như truy cập vào một trang web độc hại hoặc mở tệp đồ họa/hình ảnh được thiết kế sẵn). Lỗi hồng này từng bị khai thác dạng zero-day rộng rãi trên thực tế (In-the-wild) trước khi được vá, và nằm trong danh mục các lỗi hồng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog).	Output Gemini này khá sát nguồn, nhưng có một số chỗ AI tự suy diễn thêm. Tôi đánh giá INCOMPLETE. Đánh giá của sinh viên: AI đã xác định đúng CVE-2023-6345 là lỗi Integer Overflow (CWE-190) trong Skia của Google Chrome, phiên bản bị ảnh	V A LI D	IS TQ B đề cậ p để n việ c lự a ch on và	Đọc lại những g dẫn chứn g, chứn g cứ trong link AI đưa ra, cũng như

Consequences (Hậu quả) Khi bị khai thác thành công (thường nằm trong một chuỗi tấn công phức tạp - exploit chain), kẻ tấn công có thể: Thoát khỏi Sandbox của trình duyệt: Vượt qua hàng rào bảo vệ cô lập tiến trình của Chrome để tiếp cận sâu hơn vào hệ thống bên dưới. Thực thi mã lệnh tùy ý (RCE): Chạy mã lệnh độc hại trực tiếp trên hệ điều hành của người dùng dưới quyền hạn của tiến trình ứng dụng. Kiểm soát thiết bị: Tạo cơ hội cho kẻ xấu cài cắm phần mềm độc hại, phần mềm gián điệp (spyware) hoặc đánh cắp dữ liệu cá nhân nhạy cảm. Tool: ChatGPT Timestamp: 11:18 AM 23/09/2026	hướng trước 119.0.6045.199, và đúng với mô tả của NVD rằng attacker có thể thực hiện sandbox escape sau khi đã compromise renderer process. AI cũng ghi đúng CVSS 9.6 – Critical và việc Google xác nhận exploit của CVE-2023-6345 đã tồn tại in the wild. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi trình bày quá cụ thể về cơ chế như MeshOp: :onCombine IfPossible, việc integer overflow “khiến hệ thống cấp phát vùng nhớ heap quá nhỏ” rồi trực tiếp dẫn tới heap out-of-bounds write. Các nguồn chính được đối chiếu chỉ xác nhận integer overflow trong Skia và khả năng sandbox escape sau khi renderer process đã bị compromise, không cung cấp đầy đủ các chi tiết kỹ thuật này. AI cũng có xu hướng mở rộng hậu quả khi nói rằng attacker có thể trực tiếp thực hiện RCE, cài spyware hoặc đánh cắp dữ liệu. NVD không mô tả CVE này như một RCE trực tiếp; điều được xác nhận là khả năng potentially perform a sandbox	sử dụng cá c cô ng cụ hỗ tr ợ ki ể m th ử đ ể cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá đị nh đ ứ ng bả n ch ất	trang lỗi chín h thức đ ể so sánh với outp ut rồi đ ưa vào báo cáo. Chín h sửa và đ ưa vào báo cáo: AI đang có dấu hiệu ảo giác vì RCE và kiểm soát thiết bị là hậu quả có thể có trong 1 chuỗi khai thác chứ chưa phải tác
---	---	--	--

	escape trong điều kiện attacker đã compromise renderer process. Do đó, RCE và kiểm soát thiết bị nên được xem là hậu quả có thể có trong một exploit chain, không phải tác động trực tiếp đã được nguồn xác nhận của riêng CVE này. Ngoài ra, AI nói “zero-day rộng rãi trên thực tế” hơi mạnh. Google chỉ xác nhận rằng một exploit tồn tại in the wild, chứ nguồn được kiểm tra không khẳng định mức độ “rộng rãi”. Case này khá đẹp cho phần AI Audit vì Gemini đúng các thông tin chính nhưng thêm nhiều chi tiết kỹ thuật và hậu quả vượt quá nguồn. Nguồn tham khảo: https://chromereleases.googleblog.com/2023/11/stable-channel-update-for-desktop_28.html?utm_source=chatgpt.com https://nvd.nist.gov/vuln/detail/cve-2023-6345?utm_source=chatgpt.com	lỗi và đưa ra những bằng chứng ủng hộ cũ hơn rõ ràng hơn bất chấp AI giả thiết cụ thể chi tiết từ những lỗi có trên output. AI đã cu	động trực tiếp của nguồn CVE này.
--	--	---	--

			ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	
Artifact #34 Prompt: Hãy giải thích CVE-2024-21762 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 11:27 AM 23/09/2026	CVE-2024-21762 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng trực tiếp đến hệ điều hành FortiOS được sử dụng trên các thiết bị tường lửa FortiGate của hãng Fortinet. 1. Description (Mô tả) Bản chất: Đây là lỗi Out-of-Bounds Write (Ghi quá giới hạn vùng nhớ) trong tiến trình ssvpnd chuyên xử lý kết nối SSL VPN. Cơ chế: Lỗ hổng cho phép kẻ tấn công ở bên ngoài gửi các HTTP request được thiết kế đặc biệt tới thiết bị. Do thiếu cơ chế kiểm tra kích thước bộ nhớ đệm an toàn, dữ liệu ghi đè vượt quá vùng nhớ được cấp phát, từ đó thao túng cấu trúc bộ nhớ hệ thống. Điểm đáng chú ý: Lỗ hổng hoàn toàn không cần xác thực (unauthenticated). Kẻ tấn công không cần tài khoản hay quyền hạn hợp lệ nào trước đó	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đú ng vớ i pr o m pt. IS TQ B đề cậ p để	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính thức của lỗi và các bài báo liên quan đến lỗi. Các thông tin chưa được

	mà vẫn có thể khai thác trực tiếp qua giao diện SSL VPN. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: Lên tới 9.6 / 10.0 đến 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng, khai thác từ xa qua mạng. Lỗ hổng này từng bị ghi nhận khai thác dạng zero-day trên thực tế bởi các nhóm tấn công có tổ chức trước khi bản vá chính thức được phát hành rộng rãi, đồng thời nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA. 3. Consequences (Hậu quả) Vì thiết bị tường lửa FortiGate đóng vai trò là "cổng gác biên" kiểm soát toàn bộ lưu lượng ra vào mạng của doanh nghiệp, hậu quả khi bị chiếm đoạt là vô cùng tàn khốc: Remote Code Execution (RCE): Thực thi mã lệnh hoặc lệnh hệ điều hành tùy ý với đặc quyền cao nhất (root) trên thiết bị. Kiểm soát hoàn toàn thiết bị: Kẻ tấn công có thể thay đổi cấu hình, chặn hoặc chuyển hướng lưu lượng mạng, vô hiệu hóa tính năng bảo mật. Bàn đạp thâm nhập nội bộ (Lateral		n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử đề cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc	xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	--	--

	Movement): Từ thiết bị tường lửa bị chiếm quyền, kẻ xấu dễ dàng xâm nhập sâu vào toàn bộ hệ thống mạng nội bộ của tổ chức để triển khai mã độc tổng tiền (ransomware) hoặc đánh cắp dữ liệu nhạy cảm. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng cấp phiên bản FortiOS lên các bản vá lỗi chính thức từ hãng: FortiOS 7.4: Nâng cấp lên phiên bản 7.4.3 hoặc cao hơn. FortiOS 7.2: Nâng cấp lên phiên bản 7.2.7 hoặc cao hơn. FortiOS 7.0: Nâng cấp lên phiên bản 7.0.14 hoặc cao hơn. FortiOS 6.4 và 6.2: Nâng cấp lên phiên bản tương ứng đã vá (6.4.15, 6.2.16 hoặc mới hơn). Giải pháp tạm thời (Nếu chưa thể cập nhật ngay): Tạm thời vô hiệu hóa tính năng SSL VPN trên các thiết bị FortiGate để ngăn chặn hoàn toàn vectors tấn công này (dù có thể gây bất tiện cho người dùng từ xa).		tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hệ u qu ả Ge mi ni đư a ra kh ôn g hề có bả ng ch	
--	---	--	---	--

			ún g h a y l i n k đ ẫ n c h ứ n g c ụ t h ể n à o.	
Artifact #35 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-21762 Severity (Mức độ nghiêm trọng) Điểm CVSS: Lên tới 9.6 / 10.0 đến 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không cần tương tác người dùng, khai thác từ xa qua mạng. Lỗi hổng này từng bị ghi nhận khai thác dạng zero-day trên thực tế bởi các nhóm tấn công có tổ chức trước khi bản vá chính thức được phát hành rộng rãi, đồng thời nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA. Consequences (Hậu quả) Vì thiết bị tường lửa FortiGate đóng vai trò là "cổng gác biên" kiểm soát toàn bộ lưu lượng ra vào mạng của doanh nghiệp, hậu quả khi bị chiếm đoạt là vô cùng tàn khốc: Remote Code Execution (RCE): Thực thi mã lệnh hoặc lệnh hệ điều hành tùy ý với đặc quyền cao nhất (root) trên thiết bị. Kiểm soát hoàn toàn thiết bị: Kẻ tấn công có thể thay đổi cấu hình, chặn hoặc chuyển hướng lưu lượng mạng, vô hiệu hóa tính năng bảo mật. Bàn đạp thâm nhập nội bộ (Lateral Movement): Từ thiết bị tường lửa bị chiếm quyền, kẻ xấu dễ dàng xâm nhập sâu vào toàn bộ hệ thống mạng nội bộ của tổ chức để triển khai mã độc tống tiền (ransomware) hoặc đánh cắp dữ liệu nhạy cảm. Solution (Giải pháp khắc phục) Tool: ChatGPT Timestamp: 11:39 AM 23/09/2026	Output này có một số lỗi khá rõ Đánh giá của sinh viên: AI đã xác định đúng CVE-2024-21762 là lỗ hổng Out-of-Bounds Write (CWE-787) trong FortiOS, cho phép attacker từ xa chưa xác thực gửi HTTP request được tạo đặc biệt để thực thi code hoặc command. CISA cũng xác nhận CVE này đã được khai thác thực tế và đưa vào Known Exploited Vulnerabilities Catalog. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi đưa ra khoảng CVSS 9.6 đến 9.8 thay vì xác định rõ điểm CVSS theo nguồn đang sử dụng. AI cũng khẳng định attacker có thể thực thi mã với	V A L I D	IS TQ B đề cậ p đế n việ c lự a ch on và sử d ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi	Đọc lại nhữn g dẫn chứn g, chứn g cứ trong link AI đưa ra, cũng như trang lỗi chín h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào

	“đặc quyền cao nhất (root)”, kiểm soát hoàn toàn firewall và thực hiện lateral movement vào mạng nội bộ. Các thông tin này không được CISA xác nhận như tác động trực tiếp trong mô tả CVE; CISA chỉ xác nhận khả năng remote unauthenticated code/command execution. Ngoài ra, AI mô tả lỗ hổng như một lỗi “trong tiến trình ssvpn chuyên xử lý SSL VPN” và khẳng định việc vô hiệu hóa SSL VPN là biện pháp tạm thời. Những chi tiết này cần được đối chiếu trực tiếp với advisory của Fortinet trước khi đưa vào báo cáo, thay vì mặc định xem là thông tin đã được xác nhận. Đặc biệt, phần “Known To Be Used in Ransomware Campaigns: Known” được CISA xác nhận, nên đoạn Gemini nói về ransomware không phải hoàn toàn bịa; vấn đề là Gemini đã mở rộng từ thông tin đó thành các hậu quả cụ thể như lateral movement và kiểm soát toàn bộ mạng.	ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đủ ng bả n ch ất lỗi và đư a ra nh ữn g bả ng ch ứn g cũ ng nh ư lin k	báo cáo: AI đang bị ảo giác khi đánh giá chưa chín h xác sever ity của nguồn n. Ngoài ra hậu quả AI đưa ra chưa được CISA xác nhận.
--	--	---	--

			rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	
Artifact #36 Prompt: Hãy giải thích CVE-2024-21410 bao gồm description, severity, consequences, solution.	CVE-2024-21410 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng trực tiếp đến	IN C O M	AI cu ng cấ	Dựa vào các thôn

Tool: Geimini Timestamp: 11:42 AM 23/09/2026	các hệ thống máy chủ Microsoft Exchange Server. Dưới đây là thông tin chi tiết: 1. Description (Mô tả) Bản chất: Đây là lỗ hổng Elevation of Privilege (Leo thang đặc quyền), xuất phát từ việc xử lý không đúng cách các thông tin xác thực và thiếu cơ chế kiểm tra tính hợp lệ dữ liệu. Cơ chế: Lỗ hổng cho phép kẻ tấn công lợi dụng giao thức NTLM (cụ thể là thực hiện tấn công NTLM Relay) bằng cách đánh lừa máy chủ Exchange chấp nhận các thông tin xác thực bị chuyển hướng hoặc giả mạo. Thông qua việc gửi các request được tinh chỉnh đặc biệt, kẻ tấn công có thể mạo danh người dùng hợp pháp hoặc chiếm quyền hạn cao hơn trên hệ thống. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu người dùng tương tác. Lỗ hổng này từng bị ghi nhận khai thác dạng zero-day trên thực tế trước khi Microsoft phát hành bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited	P L E T E	p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đú ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr	g tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thôn g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác cần được loại bỏ khỏi báo cáo.
---	---	-----------------------	--	---

	Vulnerabilities Catalog). 3. Consequences (Hậu quả) Khi bị khai thác thành công, kẻ tấn công có thể: Leo thang đặc quyền: Đạt được quyền hạn của quản trị viên hoặc các tài khoản đặc quyền khác trên máy chủ Exchange. Thực thi mã lệnh từ xa (RCE) / Kiểm soát hệ thống: Kết hợp với các điểm yếu hoặc quyền hạn vừa có được để truy cập vào hộp thư người dùng, đọc dữ liệu nhạy cảm hoặc chạy mã lệnh tùy ý trên hạ tầng máy chủ. Bàn đạp tấn công mạng nội bộ: Chiếm quyền kiểm soát Exchange Server giúp kẻ xấu dễ dàng thực hiện các bước tấn công sâu hơn vào toàn bộ hệ thống Active Directory của doanh nghiệp. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật và áp dụng gói bản vá bảo mật (Security Update - SU) từ Microsoft phát hành trong chuỗi bản vá tháng 2/2024 (hoặc các Cumulative Update mới hơn) cho các phiên bản Exchange Server đang sử dụng. Giải pháp phòng ngừa bổ sung:		ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g	
--	---	--	---	--

	Kích hoạt Extended Protection for Authentication (EPA): Tính năng bảo vệ mở rộng này giúp ngăn chặn các cuộc tấn công NTLM Relay. EPA đã được Microsoft bật sẵn theo mặc định trên các phiên bản mới (như Exchange Server 2019 CU14), nhưng cần được cấu hình thủ công hoặc kiểm tra kỹ trên các phiên bản cũ hơn. Hạn chế hoặc vô hiệu hóa việc sử dụng giao thức xác thực cũ NTLM trong mạng nội bộ, chuyển đổi sang Kerberos nếu có thể.		tin ch ư a xá c nh ận) bở i vì m ột số hạ u qu ả Ge mi ni đư a ra kh ôn g hề có bằ ng ch ứn g hà y lin k dẫ n ch ứn g cụ th ể nà o.	
--	---	--	--	--

Artifact #37 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-21410 Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu người dùng tương tác. Lỗi hổng này từng bị ghi nhận khai thác dạng zero-day trên thực tế trước khi Microsoft phát hành bản vá, và nằm trong danh mục các lỗ hổng bị khai thác biết trước của CISA (Known Exploited Vulnerabilities Catalog). Consequences (Hậu quả) Khi bị khai thác thành công, kẻ tấn công có thể: Leo thang đặc quyền: Đạt được quyền hạn của quản trị viên hoặc các tài khoản đặc quyền khác trên máy chủ Exchange. Thực thi mã lệnh từ xa (RCE) / Kiểm soát hệ thống: Kết hợp với các điểm yếu hoặc quyền hạn vừa có được để truy cập vào hộp thư người dùng, đọc dữ liệu nhạy cảm hoặc chạy mã lệnh tùy ý trên hạ tầng máy chủ. Bàn đạp tấn công mạng nội bộ: Chiếm quyền kiểm soát Exchange Server giúp kẻ xấu dễ dàng thực hiện các bước tấn công sâu hơn vào toàn bộ hệ thống Active Directory của doanh nghiệp. Tool: ChatGPT Timestamp: 11:50 AM 23/09/2026	Output Gemini này có lỗi khá rõ ở CVSS, Đánh giá của sinh viên: AI đã xác định đúng CVE-2024-21410 là lỗ hổng Elevation of Privilege liên quan đến NTLM relay trong Microsoft Exchange Server và đúng rằng lỗ hổng đã được khai thác thực tế. Microsoft cũng xác nhận CVE này có thể bị khai thác để thực hiện NTLM relay và leo thang đặc quyền. CISA đã đưa CVE-2024-21410 vào Known Exploited Vulnerabilities Catalog. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi ghi CVSS 9.8 – Critical. Theo NVD, CVE-2024-21410 có CVSS 3.1 = 9.8, nhưng đây là điểm số của NVD; Microsoft phân loại lỗ hổng ở mức Important, không phải Critical. Vì vậy nếu AI chỉ ghi “9.8 = Critical” mà không phân biệt hệ thống đánh giá của NVD và Microsoft thì thông tin bị thiếu ngữ cảnh. AI cũng phóng đại hậu quả khi nói rằng attacker có thể trực tiếp đạt quyền Administrator, thực	IN C O M P L E T E	AI ch ư a đư a ra đầ y đủ th ôn g tin , dẫ n ch ứ n g cầ n th i ết nh ư c á c tra ng we b bà i bá o cụ th ể. Vi ph ạ m về độ chí nh xá c và tiê	Đọc lại và kiểm tra các xác định lỗi mà AI đưa ra và đối chiếu với trang lỗi chín h thức rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI đang phóng đại hậu quả khi nói rằng attac ker có thể trực tiếp đạt quyền
--	--	---	--	---

	hiện RCE, truy cập hộp thư và kiểm soát Active Directory. Tác động được Microsoft mô tả trực tiếp là elevation of privilege thông qua NTLM relay. Các hành động như RCE, chiếm Active Directory hoặc lateral movement cần có điều kiện và bước khai thác tiếp theo, không nên trình bày như hậu quả trực tiếp chắc chắn của riêng CVE này. Lưu ý quan trọng: Với case này, lỗi AI dễ thấy nhất là đánh đồng CVSS 9.8 với nhãn “Critical” của Microsoft. Trong report nên ghi rõ nguồn nào đưa ra mức nào, thay vì coi hai hệ thống đánh giá là giống nhau.		u chí đầ y đủ có tr on g IS TQ B.	n Admi nistra tor, thực hiện RCE, truy cập hộp thư và kiểm soát Activ e Direc tory. Tron g khi Micr osoft mô tả trực tiếp là eleva tion of privil ege thông qua NTL M relay.
Artifact #38 Prompt: Hãy giải thích CVE-2024-3400 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 11:53 AM 23/09/2026	CVE-2024-3400 là một lỗ hổng bảo mật cực kỳ nghiêm trọng ảnh hưởng đến hệ điều hành PAN-OS trên các thiết bị tường lửa thế hệ mới (Next-Generation Firewall) của Palo Alto Networks. 1. Description (Mô tả) Bản chất: Đây là lỗ hổng OS Command	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn	Dựa vào các thôn g tin AI cung cấp phải tìm kiếm và kiểm

	Injection (Tiêm mã lệnh hệ điều hành) dẫn đến khả năng tạo tệp tùy ý, được định danh theo CWE-77. Cơ chế: Lỗ hổng xuất hiện trong tính năng GlobalProtect (cụ thể là cấu hình GlobalProtect Gateway hoặc Portal) của PAN-OS. Kẻ tấn công từ bên ngoài có thể gửi các HTTP request được tinh chỉnh đặc biệt để đánh lừa hệ thống, cho phép thực thi các lệnh hệ điều hành tùy ý trên thiết bị. Điều kiện khai thác: Lỗ hổng ảnh hưởng đến các thiết bị chạy phiên bản PAN-OS 10.2, 11.0 và 11.1 có cấu hình tính năng GlobalProtect Gateway hoặc Portal. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 10.0 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng - điểm tối đa theo thang đo CVSS). Đặc điểm tấn công: Hoàn toàn không cần xác thực (unauthenticated), độ phức tạp thấp và không yêu cầu người dùng tương tác. Lỗ hổng này từng bị khai thác dạng zero-day trên thực tế trong các chiến dịch tấn công nhắm vào hạ tầng trọng yếu (như chiến dịch Operation MidnightEclipse)		g tin về ea ch de fec t đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi	tra lại với trang thôn g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	---	--

	trước khi hăng kịp phát hành bản vá. 3. Consequences (Hậu quả) Vì thiết bị Palo Alto Firewall đóng vai trò là "chốt chặn" bảo mật biên cốt lõi của doanh nghiệp, hậu quả khi bị chiếm đoạt là vô cùng nặng nề: Thực thi mã lệnh với quyền Root: Kẻ tấn công có thể chạy bất kỳ câu lệnh nào với quyền cao nhất (root) trên thiết bị. Kiểm soát toàn bộ tường lửa: Cho phép kẻ xấu thay đổi cấu hình, đánh cắp thông tin nhạy cảm, cấu hình mạng, hoặc vô hiệu hóa toàn bộ các tính năng bảo mật. Bàn đạp tấn công nội bộ (Lateral Movement): Kẻ tấn công sử dụng thiết bị tường lửa đã bị chiếm quyền làm bàn gốc để thâm nhập sâu vào toàn bộ hệ thống mạng nội bộ bên trong của tổ chức. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật ngay lập tức hệ điều hành PAN-OS lên các phiên bản đã được vá lỗi chính thức từ nhà sản xuất: PAN-OS 10.2: Nâng cấp lên phiên bản 10.2.9-h1 hoặc cao hơn. PAN-OS 11.0: Nâng cấp lên phiên bản		ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở	
--	--	--	--	--

	11.0.4-h1 hoặc cao hơn. PAN-OS 11.1: Nâng cấp lên phiên bản 11.1.2-h3 hoặc cao hơn. Giải pháp phòng ngừa / Giảm thiểu tạm thời: Nếu chưa thể nâng cấp ngay, khách hàng đang sử dụng gói dịch vụ Threat Prevention có thể bật các quy tắc Threat ID (như Threat ID 95187, 95189, 95191) và đảm bảo tính năng Vulnerability Protection đã được áp dụng trực tiếp lên giao diện GlobalProtect. Rà soát hệ thống kỹ lưỡng (kiểm tra tệp hỗ trợ kỹ thuật - Tech Support File) để tìm kiếm các dấu hiệu thỏa hiệp (IoC) hoặc tệp tin bất thường nhằm xác định thiết bị có từng bị xâm nhập trước đó hay không.		i vì m ột số hạ u qu ả Ge mi ni đư a ra kh ôn g hề có bằ ng ch ứn g hà y lin k dẫ n ch ứn g cụ th ể nà o.	
Artifact #39 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-3400 Vì thiết bị Palo Alto Firewall đóng vai trò là "chốt chặn" bảo mật biên cốt lõi của doanh nghiệp, hậu quả khi bị chiếm đoạt là vô cùng nặng nề: Thực thi mã lệnh với quyền Root: Kẻ tấn công có thể chạy bất kỳ câu lệnh nào với quyền cao nhất (root) trên thiết bị. Kiểm soát toàn bộ tường lửa: Cho phép kẻ xấu thay đổi cấu hình, đánh cắp thông tin nhạy cảm,	Tôi kiểm tra lại trực tiếp với advisory của Palo Alto. Case này Gemini làm khá tốt, và có một điểm tôi cần sửa so với cách đánh giá trước: RCE với root ở đây là thông tin chính thức, không phải hallucination.	V A LI D	IS TQ B đề cậ p đế n việ c lự	Đọc lại nhữn g dẫn chứn g, chứn g cứ trong link AI

cấu hình mạng, hoặc vô hiệu hóa toàn bộ các tính năng bảo mật. Bàn đạp tấn công nội bộ (Lateral Movement): Kẻ tấn công sử dụng thiết bị tường lửa đã bị chiếm quyền làm bàn gốc để thâm nhập sâu vào toàn bộ hệ thống mạng nội bộ bên trong của tổ chức. Tool: ChatGPT Pro Timestamp: 11:58 AM 23/09/2026	Palo Alto xác nhận CVE-2024-3400 cho phép unauthenticated attacker thực thi arbitrary code với root privileges trên firewall. Đánh giá của sinh viên: AI đã xác định đúng CVE-2024-3400 là lỗ hổng OS Command Injection do Arbitrary File Creation trong tính năng GlobalProtect của PAN-OS. AI cũng xác định đúng các điều kiện quan trọng: lỗ hổng ảnh hưởng đến PAN-OS 10.2, 11.0 và 11.1 khi firewall được cấu hình GlobalProtect Gateway hoặc Portal; attacker không cần authentication hoặc user interaction; CVSS là 10.0 – Critical. Những thông tin này được Palo Alto Networks xác nhận trực tiếp. AI cũng xác định đúng hậu quả chính là arbitrary code execution với root privileges trên firewall. Đây không phải hallucination vì Palo Alto Networks mô tả trực tiếp tác động của CVE là unauthenticated attacker có thể thực thi arbitrary code với root privileges.	a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đủ ng	đưa ra, cũng như trang lỗi chín h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI có dấu hiệu ảo giác vì AI đưa ra hậu quả trực tiếp là kiểm soát toàn bộ tường lửa và bàn đạp tấn công
--	---	---	---

	Tuy nhiên, AI có dấu hiệu overstatement khi trình bày “kiểm soát toàn bộ tường lửa” và đặc biệt là lateral movement vào toàn bộ mạng nội bộ như hậu quả trực tiếp của CVE. Nguồn Palo Alto xác nhận khả năng thực thi code với root trên firewall, nhưng không khẳng định rằng mọi lần khai thác đều dẫn đến lateral movement hoặc kiểm soát toàn bộ mạng nội bộ. Đây nên được xem là khả năng post-exploitation, phụ thuộc vào môi trường và các bước tấn công tiếp theo. Palo Alto cũng phân biệt rõ initial remote command execution với các kỹ thuật persistence sau khai thác. Ngoài ra, AI nói rằng lỗ hổng được khai thác trong chiến dịch Operation MidnightEclipse. Thông tin về việc CVE bị khai thác thực tế là đúng; Palo Alto xác nhận có “an increasing number of attacks” khai thác lỗ hổng và CISA cũng xác nhận CVE-2024-3400 là một lỗ hổng bị khai thác. Tuy nhiên, nếu muốn ghi tên cụ thể của một campaign như Operation MidnightEclipse thì cần dẫn nguồn riêng	bả n ch ất lỗi và đư a ra nh ữn g bả ng ch ứn g cũ ng nh ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp	nội bộ (Lateral Movement) . Tuy nhiên không phải mọi lần khai thác đều dẫn đến hậu quả đó. Đây nên được coi là giai đoạn hậu khai thác nên phụ thuộc vào môi trường và các bước tấn công tiếp theo
--	---	--	---

	cho campaign đó thay vì chỉ dựa vào advisory CVE. Phần Solution nhìn chung chính xác. Các bản 10.2.9-h1, 11.0.4-h1 và 11.1.2-h3 đều được Palo Alto xác nhận là các phiên bản đã sửa. Các Threat ID 95187, 95189 và 95191 cũng thực sự là mitigation được Palo Alto cung cấp. Một điểm rất quan trọng cho AI Audit của bạn: đừng đánh Gemini sai ở “RCE/root” trong case này. Đây là trường hợp nguồn chính thức nói rõ điều đó. Lỗi đáng ghi nhận của Gemini nằm ở việc mở rộng từ root RCE trên firewall → kiểm soát toàn bộ mạng nội bộ, chứ không phải ở việc nói CVE này có RCE. Nguồn tham khảo: https://security.paloaltonetworks.com/CVE-2024-3400?utm_source=chatgpt.com		ut. AI đã cung cấp đầy đủ thông tin cần thiết.	
Artifact #40 Prompt: Hãy giải thích CVE-2024-4577 bao gồm description, severity, consequences, solution.	CVE-2024-4577 là một lỗ hổng bảo mật nghiêm trọng ảnh hưởng trực tiếp đến	IN C O M	AI cung cấp	Dựa vào các thôn

Tool: Geimini Timestamp: 20:38 PM 23/09/2026	ngôn ngữ lập trình PHP khi chạy trên hệ điều hành Windows (đặc biệt trong chế độ CGI hoặc khi tích hợp với máy chủ web Apache). 1. Description (Mô tả) Bản chất: Đây là lỗ hổng Argument Injection (Tiêm tham số). Cơ chế: Lỗ hổng xuất phát từ một thiếu sót trong quá trình chuyển đổi bảng mã ký tự (tính năng "Best-Fit" của Windows encoding) khi PHP xử lý các tham số dòng lệnh. Trước đây, các phiên bản PHP từng có cơ chế phòng thủ để chặn các cuộc tấn công tương tự (CVE-2012-1823), nhưng kẻ tấn công có thể lợi dụng các chuỗi ký tự đặc biệt (như ký tự chuyển đổi mã hóa %AD) để vượt qua các lớp lọc này. Điểm đáng chú ý: Kẻ tấn công từ bên ngoài có thể gửi các HTTP request được tinh chỉnh sẵn để ép tệp thực thi php-cgi.exe nhận các đối số dòng lệnh tùy ý (ví dụ: cờ -d để cấu hình lại các tham số .ini của PHP) mà không cần xác thực (unauthenticated). Lỗ hổng này ảnh hưởng rất nặng nề đối với các gói cài đặt sẵn có cấu hình mặc định công khai thư mục CGI (như XAMPP cho Windows).	P L E T E	p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr	g tin AI cung cấp phải tìm kiếm và kiếm tra lại với trang thôn g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	--	----------------------------------	--	--

	2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu người dùng tương tác, thực thi từ xa qua mạng. Lỗ hổng này đã bị khai thác rộng rãi trên thực tế ngay sau khi được công bố (nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA) để phát tán mã độc tổng tiền (ransomware), cài cắm web shell và botnet. 3. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng mang lại những hậu quả nặng nề: Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình máy chủ web trên hệ thống Windows. Kiểm soát hệ thống: Kẻ tấn công có thể cài đặt web shell để duy trì quyền truy cập, đánh cắp dữ liệu nhạy cảm hoặc triển khai mã độc tổng tiền (ví dụ: nhóm ransomware TellYouThePass). 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Nâng cấp PHP lên các phiên bản đã được vá lỗi từ nhà phát triển:		ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g	
--	---	--	---	--

	PHP phiên bản 8.3: Nâng cấp lên 8.3.8 hoặc mới hơn. PHP phiên bản 8.2: Nâng cấp lên 8.2.20 hoặc mới hơn. PHP phiên bản 8.1: Nâng cấp lên 8.1.29 hoặc mới hơn. (Lưu ý: Các phiên bản cũ hơn như PHP 8.0, 7 và 5 đã ngừng hỗ trợ - End-of-Life, nên cần chuyển đổi sang nhánh mới hơn). Giải pháp tạm thời / Phòng ngừa bổ sung: Nếu sử dụng XAMPP hoặc các môi trường phát triển trên Windows mà không cần dùng tính năng PHP-CGI, hãy cấu hình lại tệp httpd.conf của Apache để vô hiệu hóa hoặc xóa bỏ các cấu hình ảnh xạ tới php-cgi. Sử dụng quy tắc Rewrite của máy chủ web (như chặn các chuỗi query string độc hại chứa mã %ad) nếu chưa thể cập nhật ngay lập tức.		tin ch ư a xá c nh ận) bở i vì m ột số hậ u qu ả Ge mi ni đư a ra kh ôn g hề có bằ ng ch ứn g ha y lin k đẫ n ch ứn g cụ th ể nà o.	
--	--	--	---	--

Artifact #41 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-4577 Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Độ phức tạp thấp, không yêu cầu người dùng tương tác, thực thi từ xa qua mạng. Lỗ hổng này đã bị khai thác rộng rãi trên thực tế ngay sau khi được công bố (nằm trong danh mục các lỗ hổng bị khai thác thực tế của CISA) để phát tán mã độc tống tiền (ransomware), cài cắm web shell và botnet. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng mang lại những hậu quả nặng nề: Remote Code Execution (RCE): Thực thi mã lệnh tùy ý dưới quyền của tiến trình máy chủ web trên hệ thống Windows. Kiểm soát hệ thống: Kẻ tấn công có thể cài đặt web shell để duy trì quyền truy cập, đánh cắp dữ liệu nhạy cảm hoặc triển khai mã độc tống tiền (ví dụ: nhóm ransomware TellYouThePass). Tool: ChatGPT Pro Timestamp: 20:52 PM 23/09/2026	Mình đã đối chiếu output Gemini với NVD, PHP và CISA. Với case này, Gemini khá chính xác ở phần thông tin cốt lõi , nhưng vẫn có một số chỗ mở rộng quá mức. NVD xác nhận CVE-2024-4577 là OS Command Injection, CVSS 9.8 Critical, ảnh hưởng PHP 8.1 trước 8.1.29, 8.2 trước 8.2.20 và 8.3 trước 8.3.8; CISA cũng xác nhận khả năng arbitrary code execution và việc CVE này được sử dụng trong ransomware campaigns. Bạn có thể ghi phần đánh giá vào report như sau: Đánh giá AI – CVE-2024-4577 Đánh giá của sinh viên: AI xác định đúng bản chất của CVE-2024-4577 là lỗ hổng OS Command Injection/Argument Injection trong PHP-CGI trên Windows, mức độ Critical với CVSS 9.8, cũng như khả năng thực thi mã tùy ý và việc lỗ hổng đã được khai thác thực tế. Các phiên bản khắc phục 8.1.29, 8.2.20 và 8.3.8 cũng phù hợp với thông tin từ PHP và NVD. Tuy nhiên, AI có dấu hiệu overstatement khi trình bày web shell,	V A LI D	IS TQ B đề cậ p để n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ	Đọc lại những dẫn chứng, chứng cứ trong link AI đưa ra, cũng như trang lỗi chính thức để so sánh với output rồi đưa vào báo cáo. Chỉnh sửa và đưa vào báo cáo: AI đang ảo giác khi trình bày web shell, đánh cắp dữ liệu
--	--	-------------------	--	---

	đánh cắp dữ liệu và triển khai ransomware như những hậu quả trực tiếp của lỗ hổng. CISA xác nhận CVE này đã được sử dụng trong ransomware campaigns, nhưng điều đó không có nghĩa mọi lần khai thác đều dẫn đến các hậu quả trên. Ngoài ra, chi tiết nhóm TellYouThePass và một số biện pháp phòng ngừa cụ thể cần nguồn riêng để xác nhận. Lưu ý: phần phiên bản vá mà Gemini đưa ra là đúng; PHP ghi nhận CVE-2024-4577 được sửa trong PHP 8.1.29 và 8.2.20, còn NVD xác nhận các ngưỡng phiên bản tương ứng. Nguồn tham khảo: https://nvd.nist.gov/vuln/detail/cve-2024-4577?utm_source=chatgpt.com	tr ợ gi úp AI xá c đị nh đủ ng bả n ch ất lỗi và đư a ra nh ữn g bả ng ch ứn g cũ ng nh ư lin k rõ ràng mi nh bạ ch. AI giả i thí ch cụ th ể chi	và triển khai ranso mwar e như một hậu quả trực tiếp. Khôn g phải mỗi lần khai thác đều dẫn đến hậu quả trên. Phải dựa vào nhữn g hoạt động trong thực tế.
--	--	--	---

			tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	
Artifact #42 Prompt: Hãy giải thích CVE-2024-3094 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 20:57 PM 23/09/2026	CVE-2024-3094 là một lỗi hỏng bảo mật dạng supply-chain (cung ứng phần mềm) cực kỳ nổi tiếng, được phát hiện có chủ ý gài cắm mã độc backdoor vào các bản phát hành của thư viện XZ Utils (cụ thể trên các phiên bản 5.6.0 và 5.6.1). 1. Description (Mô tả) Bản chất: Đây là lỗi Malicious Backdoor (Cài cắm mã độc có chủ ý) vào quá trình đóng gói và xây dựng mã nguồn (build/packaging process) của thư viện	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính h

	nén dữ liệu xz (liblzma). Cơ chế: Kẻ tấn công (đóng vai trò là nhà phát triển cốt lõi qua một quá trình dài tạo lòng tin) đã âm thầm đưa các tệp cấu hình bản dựng bị nhiễm mã độc vào gói mã nguồn phân phối (tarball release). Khi các nhà phân phối bản Linux build gói này, tập lệnh độc hại sẽ can thiệp vào quá trình liên kết (linking) của trình biên dịch với OpenSSH (thông qua libsystemd), qua đó lồng ghép một đoạn mã độc chặn bắt các tiến trình xác thực SSH trước khi chúng hoàn tất. Điểm đáng chú ý: Đây là một trong những cuộc tấn công tinh vi nhất vào chuỗi cung ứng mã nguồn mở từng được phát hiện, được ví như "bom nổ chậm" suýt tàn phá hệ sinh thái Linux nếu không nhờ kỹ sư Andres Freund phát hiện ra tình cờ do lỗi tiêu thụ tài nguyên CPU. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 10.0 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng - điểm tối đa theo thang đo). Đặc điểm tấn công: Kẻ tấn công có thể qua mặt toàn bộ các cơ chế xác thực thông thường bằng một khóa công	đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ế m th ử để cải thi ện hi ệu qu ả và hi ệu	thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	--

	khai (public key) được lồng sẵn trong backdoor. Nó cho phép thực thi mã lệnh từ xa trước khi tiến trình xác thực SSH diễn ra. 3. Consequences (Hậu quả) Nếu hệ thống sử dụng phiên bản bị ảnh hưởng và phơi bày dịch vụ SSH trực tiếp ra ngoài: Bypass xác thực (Authentication Bypass): Kẻ tấn công có thể xâm nhập trái phép vào hệ thống từ xa mà không cần mật khẩu hay khóa SSH hợp lệ nếu biết khóa bí mật tương ứng được gài trong mã độc. Kiểm soát toàn bộ hệ thống: Do tiến trình SSH chạy với đặc quyền cao hoặc liên kết chặt chẽ với hệ thống Linux, việc chiếm được phiên đăng nhập giúp kẻ xấu nắm toàn bộ quyền kiểm soát máy chủ. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Hạ cấp (Downgrade) hoặc vá lỗi: Chuyển ngay lập tức về các phiên bản XZ Utils ổn định và an toàn (như phiên bản 5.4.x trở xuống, ví dụ 5.4.6) hoặc nâng cấp lên các bản vá sau khi sự cố được khắc phục hoàn toàn. Kiểm tra và phòng ngừa:		su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hệ u qu	
--	---	--	--	--

	Kiểm tra xem hệ thống Linux của bạn có đang dùng phiên bản 5.6.0 hoặc 5.6.1 hay không (thường xuất hiện trên một số bản phân phối rolling release hoặc bản thử nghiệm cập nhật nhanh như Debian testing/unstable, Fedora Rawhide, openSUSE Tumbleweed). Các bản phân phối Linux truyền thống (như Ubuntu LTS, RHEL ổn định) thường không bị ảnh hưởng do chưa nâng cấp lên nhánh 5.6.x chứa mã độc.		ả Ge mi ni đư a ra kh ôn g hề có bằ ng ch ứn g ha y lin k dẫ n ch ứn g cụ th ể nà o.	
Artifact #43 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-3094 Điểm CVSS: 10.0 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng - điểm tối đa theo thang đo). Đặc điểm tấn công: Kẻ tấn công có thể qua mặt toàn bộ các cơ chế xác thực thông thường bằng một khóa công khai (public key) được lồng sẵn trong backdoor. Nó cho phép thực thi mã lệnh từ xa trước khi tiến trình xác thực SSH diễn ra. Nếu hệ thống sử dụng phiên bản bị ảnh hưởng và phơi bày dịch vụ SSH trực tiếp ra ngoài: Bypass xác thực (Authentication Bypass): Kẻ tấn công có thể xâm nhập trái phép vào hệ thống từ xa mà không cần mật khẩu hay khóa SSH hợp lệ nếu biết khóa bí mật tương ứng được gài trong mã độc. Kiểm soát toàn bộ hệ thống: Do tiến trình SSH chạy với đặc quyền cao hoặc liên kết	Mình đã đối chiếu output Gemini với nguồn Microsoft. Case này có một lỗi khá rõ, nên rất phù hợp để đưa vào phần AI hallucination/overstatement. Microsoft xác nhận CVE-2024-3094 là software supply-chain compromise ảnh hưởng XZ Utils 5.6.0 và 5.6.1, CVSS 10.0; mã độc có thể được kích hoạt thông qua kết nối	V A LI D	IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng	Đọc lại nhữn g dẫn chứn g, chứn g cứ trong link AI đưa ra, cũng như trang lỗi chín

chặt chẽ với hệ thống Linux, việc chiếm được phiên đăng nhập giúp kẻ xấu nắm toàn bộ quyền kiểm soát máy chủ. Tool: ChatGPT Pro Timestamp: 21:05 PM 23/09/2026	từ xa tới SSH và có khả năng dẫn tới compromise hệ thống. Microsoft cũng khuyến nghị downgrade về bản không bị ảnh hưởng như 5.4.6. Đánh giá của sinh viên: AI xác định đúng các thông tin cốt lõi của CVE-2024-3094: đây là một software supply-chain compromise/backdoor trong XZ Utils, ảnh hưởng các phiên bản 5.6.0 và 5.6.1, có CVSS 10.0 và liên quan đến khả năng compromise hệ thống thông qua SSH. Các thông tin về việc downgrade về XZ Utils 5.4.6 cũng phù hợp với hướng dẫn của Microsoft. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi khẳng định kẻ tấn công có thể sử dụng một “khóa bí mật tương ứng được gài trong mã độc” để bypass xác thực SSH và trình bày việc chiếm toàn bộ hệ thống như một kết quả trực tiếp, tất yếu. Các nguồn được kiểm tra xác nhận nguy cơ remote compromise nhưng không hỗ trợ cách diễn giải cụ thể về “public key/private key” như AI trình bày. Ngoài ra, câu “một trong những cuộc tấn công tinh vi nhất” mang tính đánh giá và	cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đủ ng bả n ch ất lỗi và đư	h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI có dấu hiệu ảo giác khi khẩn g định kẻ tấn công có thể sử dụng một “khó a bí mật tương ứng được gài trong mã độc” để bypas s xác thực SSH
---	---	--	--

	không cần thiết cho mô tả kỹ thuật. Nguồn tham khảo: https://techcommunity.microsoft.com/blog/vulnerability-management/microsoft-faq-and-guidance-for-xz-utils-backdoor/4101961/?utm_source=chatgpt.com	a ra nh ữn g bả ng ch ứn g cũ ng nh ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p	và trình bày việc chiế m toàn bộ hệ thống như một kết quả trực tiếp Các nguồn n kiểm tra xác nhận nguy cơ remot e comp romis e nhưn g khôn g hề hỗ trợ cách diễn giải cụ thể về “publ ic key/p rivate key” như AI đã trình bày.
--	--	--	--

			đầy đủ thông tin cần thiết.	
Artifact #44 Prompt: Hãy giải thích CVE-2024-48145 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 21:12 PM 23/09/2026	CVE-2024-48145 là một lỗ hổng bảo mật liên quan đến ứng dụng trợ lý AI, cụ thể ảnh hưởng đến hộp thoại chat (chatbox) của Netangular Technologies ChatNet AI (phiên bản v1.0). Dưới đây là thông tin chi tiết: 1. Description (Mô tả) Bản chất: Đây là một lỗ hổng Prompt Injection (Tiêm câu lệnh nhắc lệnh AI). Cơ chế: Lỗ hổng xuất hiện trong phần xử lý giao diện chatbox của ChatNet AI phiên bản v1.0. Do thiếu cơ chế kiểm soát và phân định rõ ràng giữa lệnh hệ thống/chỉ thị của nhà phát triển với dữ liệu đầu vào do người dùng (hoặc kẻ tấn công) cung cấp, ứng dụng bị lừa thực thi các đoạn mã lệnh hướng dẫn độc hại được ngụy trang trong tin nhắn. Điểm đáng chú ý: Kẻ tấn công có thể gửi một thông điệp được tinh chỉnh khéo léo (crafted message)	INCOМПЛЕТЕН	AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính thức của lỗi và các bài báo liên quan đến lỗi. Các thông tin chưa được xác thực	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính thức của lỗi và các bài báo liên quan đến lỗi. Các thông tin chưa được xác thực

	thông qua khung chat để ép trợ lý AI thực hiện các hành vi ngoài ý muốn mà không cần có quyền quản trị hay xác thực trước. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.1 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Khai thác từ xa qua mạng (Network Vector), độ phức tạp thấp và không đòi hỏi người dùng phải tương tác phức tạp ngoài việc tiếp nhận nội dung độc hại do kẻ tấn công điều hướng. 3. Consequences (Hậu quả) Khi khai thác thành công lỗ hổng này, kẻ tấn công có thể: Rò rỉ dữ liệu người dùng (Data Exfiltration): Kẻ xấu có thể lợi dụng trợ lý AI để truy cập, đọc và trích xuất toàn bộ lịch sử trò chuyện trước đó cũng như các đoạn chat phát sinh sau đó giữa người dùng thực tế và trợ lý AI. Lộ lọt thông tin nhạy cảm: Nếu người dùng từng cung cấp các dữ liệu cá nhân, thông tin bí mật hoặc tài liệu nội bộ trong các phiên chat với AI, toàn bộ dữ liệu này có nguy cơ bị kẻ tấn công thu thập thông qua các lệnh chuyển hướng dữ liệu tự động.		c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t	cần được loại bỏ khỏi báo cáo.
--	---	--	--	---

	4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Liên hệ với nhà cung cấp (Netangular Technologies) để cập nhật lên các phiên bản vá lỗi mới hơn của ChatNet AI (nếu có) hoặc vô hiệu hóa ứng dụng cho đến khi bản vá được phát hành. Giải pháp phòng ngừa: Thiết lập các lớp lọc đầu vào và đầu ra (Input/Output Guardrails) cho các hệ thống chat tích hợp AI nhằm ngăn chặn các hành vi ép AI tuân theo các câu lệnh trái phép (Prompt Injection). Tránh trao đổi hoặc đưa các thông tin, dữ liệu nhạy cảm của cá nhân/doanh nghiệp vào các ứng dụng chat AI bên thứ ba chưa được kiểm định mức độ bảo mật kỹ càng.		ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hệ u qu ả Ge mi ni đư a ra kh ôn g hề có bả ng ch ứn g	
--	--	--	--	--

			hay lin k đ n ch ứn g cụ th ể nà o.	
Artifact #45 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-48145 Severity (Mức độ nghiêm trọng) Điểm CVSS: 9.1 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Khai thác từ xa qua mạng (Network Vector), độ phức tạp thấp và không đòi hỏi người dùng phải tương tác phức tạp ngoài việc tiếp nhận nội dung độc hại do kẻ tấn công điều hướng. Consequences (Hậu quả) Khi khai thác thành công lỗ hổng này, kẻ tấn công có thể: Rò rỉ dữ liệu người dùng (Data Exfiltration): Kẻ xấu có thể lợi dụng trợ lý AI để truy cập, đọc và trích xuất toàn bộ lịch sử trò chuyện trước đó cũng như các đoạn chat phát sinh sau đó giữa người dùng thực tế và trợ lý AI. Lộ lọt thông tin nhạy cảm: Nếu người dùng từng cung cấp các dữ liệu cá nhân, thông tin bí mật hoặc tài liệu nội bộ trong các phiên chat với AI, toàn bộ dữ liệu này có nguy cơ bị kẻ tấn công thu thập thông qua các lệnh chuyển hướng dữ liệu tự động. Tool: ChatGPT Pro Timestamp: 21:20 PM 23/09/2026	Output Gemini lần này nhìn chung khá sát nguồn, nhưng vẫn có một số chỗ cần chỉnh. Điểm đáng chú ý nhất là Gemini đã thêm một số chi tiết về cơ chế prompt injection mà CVE/NVD không mô tả cụ thể. Bạn có thể đưa phần này vào report: Đánh giá AI – CVE-2024-48145 Đánh giá của sinh viên: AI xác định đúng các thông tin chính của CVE-2024-48145: lỗ hổng Prompt Injection trong Netangular Technologies ChatNet AI v1.0, CVSS 9.1 Critical và khả năng truy cập, trích xuất dữ liệu chat trước và sau khi khai thác. Các thông tin này phù hợp với mô tả của NVD. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi mô tả chi tiết cơ chế như việc	IN C O M P L E T E	AI ch ư a đ ư a ra đ ầ y đ ủ th ôn g t in , đ ẫ n ch ứn g c ầ n th i ết nh ư c á c tr a ng we b b à i b á o c ụ	Đ ọc l ại và ki ể m tr a c ác x ác đ ị nh l ỗi m à AI đ ư a ra và đ ối chi ếu v ớ i tr ang l ỗi ch ín h th ứ c r ồ i đ ư a v ào b á o c áo. Ch ín h s ử a và đ ư a v ào b á o c áo: AI đ ang có nh ữn

	ứng dụng “thiếu cơ chế phân định giữa system/developer instruction và user input” và cho rằng attacker có thể “ép trợ lý AI thực hiện các hành vi ngoài ý muốn”; đây là diễn giải hợp lý về prompt injection nhưng không được CVE/NVD xác nhận cụ thể. Ngoài ra, AI đề xuất cập nhật lên “các phiên bản mới hơn” nhưng không đưa ra được một phiên bản đã được xác nhận là bản vá		thể. Vì phạm về độ chính xác và tiêu chí đầy đủ có trên g IS TQ B.	g định kiến riêng mà chưa được CVE hay NVD xác nhận cụ thể vì AI cho rằng attacker có thể “ép trợ lý AI thực hiện các hành vi ngoài ý muốn”. Tuy nhiên nó cũng là 1 diễn giải hợp lý trong trường hợp xảy ra như trên.
--	--	--	---	---

Artifact #46 Prompt: Hãy giải thích CVE-2024-42478 bao gồm description, severity, consequences, solution. - Tool: Geimini - Timestamp: 21:29 PM 23/09/2026	CVE-2024-42478 là một lỗi hỏng bảo mật ảnh hưởng đến llama.cpp (thư viện chạy suy luận Large Language Model - LLM bằng C/C++). Dưới đây là thông tin chính xác về CVE-2024-42478: 1. Description (Mô tả) Bản chất: Đây là lỗi hỏng Out-of-Bounds Read (Đọc quá giới	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g	Dựa vào các thôn g tin AI cung cấp phải tìm kiểm và kiểm tra

	hạn vùng nhớ) được định danh theo CWE-125. Cơ chế: Lỗi hỏng xuất hiện trong thành phần RPC Server của llama.cpp (dùng để phân tán tác vụ suy luận LLM qua mạng). Cụ thể, con trỏ data không được kiểm soát an toàn trong cấu trúc dữ liệu rpc_tensor. Kẻ tấn công có thể tinh chỉnh các gói tin gửi đến RPC server để thao túng con trỏ này, ép hệ thống đọc dữ liệu từ các địa chỉ bộ nhớ bất kỳ mà không bị giới hạn phạm vi. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: Lên tới 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng theo đánh giá của NVD do khả năng cho phép truy cập đọc bộ nhớ từ xa không cần xác thực). Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng thông qua các cổng dịch vụ RPC của llama.cpp nếu dịch vụ này mở phơi bày ra ngoài mà không có cơ chế kiểm soát mạng an toàn. 3. Consequences (Hậu quả) Khi bị khai thác thành công, lỗi hỏng có thể dẫn đến: Rò rỉ thông tin bộ nhớ (Arbitrary Memory Read): Kẻ tấn công có thể đọc các vùng nhớ	tin về ea ch de fec t đủ ng vớ i pr o m pt. IS TQ B đề cậ p để n việ c lự a ch ọn và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện	lại với trang thôn g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	---	---

	tùy ý trên tiến trình đang chạy máy chủ RPC, qua đó có thể trích xuất các dữ liệu nhạy cảm đang lưu trữ trong RAM (như thông tin cấu hình, dữ liệu mô hình đang xử lý, hoặc các khóa bí mật). Kết hợp tấn công (Chaining): Lỗ hổng đọc bộ nhớ này có thể được kẻ xấu lợi dụng kết hợp với các lỗi khác (như lỗi ghi bộ nhớ CVE-2024-42479 đi kèm) để đạt mục tiêu thực thi mã lệnh từ xa (RCE). 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật/nâng cấp llama.cpp lên phiên bản b3561 hoặc các phiên bản mới hơn (nơi bản vá lỗi đã được tích hợp sẵn trong mã nguồn). Giải pháp phòng ngừa: Nếu bạn đang chạy llama.cpp ở chế độ RPC Server (rpc-server), tuyệt đối không phơi bày cổng dịch vụ này trực tiếp ra Internet công cộng. Sử dụng tường lửa hoặc mạng riêng ảo (VPN) để giới hạn quyền truy cập vào các node RPC nội bộ, chỉ cho phép các máy chủ tin cậy giao tiếp với nhau.		hi ệ u qu ả và hi ệ u su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i	
--	--	--	---	--

			vì m ột số hệ u qu ả Ge mi ni đư a ra kh ôn g hề có bằ ng ch ứn g hà y lin k đẫ n ch ứn g cụ th ể nà o.	
Artifact #47 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-42478 Severity (Mức độ nghiêm trọng) Điểm CVSS: Lên tới 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng theo đánh giá của NVD do khả năng cho phép truy cập đọc bộ nhớ từ xa không cần xác thực). Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng thông qua các cổng dịch vụ RPC của llama.cpp nếu dịch vụ này mở phơi bày ra ngoài mà không có cơ chế kiểm soát mạng an toàn.	Mình đã đối chiếu output Gemini với advisory chính thức của llama.cpp. Case này Gemini đúng phần lớn, nhưng có một điểm rất đáng chú ý về CVSS. Đánh giá của sinh viên: AI xác định đúng CVE-	V A LI D	IS TQ B đề cậ p đế n việ c lự a	Đọc lại những g dẫn chứn g, chứn g cứ trong link AI đưa

Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng có thể dẫn đến: Rò rỉ thông tin bộ nhớ (Arbitrary Memory Read): Kẻ tấn công có thể đọc các vùng nhớ tùy ý trên tiến trình đang chạy máy chủ RPC, qua đó có thể trích xuất các dữ liệu nhạy cảm đang lưu trữ trong RAM (như thông tin cấu hình, dữ liệu mô hình đang xử lý, hoặc các khóa bí mật). Kết hợp tấn công (Chaining): Lỗ hổng đọc bộ nhớ này có thể được kẻ xấu lợi dụng kết hợp với các lỗi khác (như lỗi ghi bộ nhớ CVE-2024-42479 đi kèm) để đạt mục tiêu thực thi mã lệnh từ xa (RCE). Tool: ChatGPT Pro Timestamp: 21:44 PM 23/09/2026	2024-42478 là lỗ hổng Out-of-Bounds Read trong RPC server của llama.cpp, liên quan đến <code>rpc_server::get_tensor</code> và có thể dẫn đến arbitrary address read. AI cũng xác định đúng phiên bản đã sửa là b3561. Tuy nhiên, AI có dấu hiệu incomplete context khi chỉ trình bày CVSS 9.8 Critical theo NVD mà không đề cập rằng advisory chính thức của llama.cpp đánh giá lỗ hổng ở mức 5.3 Medium. Ngoài ra, AI mở rộng hậu quả sang việc đọc trực tiếp các khóa bí mật, dữ liệu mô hình và khả năng kết hợp với CVE-2024-42479 để đạt RCE; những khả năng này cần được phân biệt với tác động trực tiếp đã được advisory của CVE-2024-42478 xác nhận. Đây là một defect khá tốt cho phần AI Audit vì Gemini không hẳn “bịa”, mà mắc lỗi bỏ sót ngữ cảnh và mở rộng tác động	ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử đề cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả	ra, cũng như trang lỗi chín h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI đang có dấu hiệu ảo giác khi mở rộng hậu quả sang việc đọc trực tiếp các khóa bí mật, dữ liệu mô hình
---	--	--	--

		n ch ất lỗi và đư a ra nh ữn g bằ ng ch ứn g cũ ng nh ư lin k rõ rằ ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut.	và khả năng kết hợp với đề đạt RCE. Ngoà i ra, AI còn cung cấp thiếu thông tin đánh giá lỗ hổng ở mức 5.3 Medi um từ Githu b.
--	--	---	--

			AI đã cung cấp đầy đủ thông tin cần thiết.	
Artifact #48 Prompt: Hãy giải thích CVE-2024-5565 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 21:48 PM 23/09/2026	CVE-2024-5565 là một lỗ hổng bảo mật liên quan đến ứng dụng AI/Machine Learning, cụ thể ảnh hưởng đến thư viện mã nguồn mở Python Vanna.AI (một công cụ phổ biến giúp chuyển đổi ngôn ngữ tự nhiên thành câu lệnh SQL). 1. Description (Mô tả) Bản chất: Đây là lỗ hổng Prompt Injection dẫn đến Remote Code Execution (RCE). Cơ chế: Trong thư viện Vanna, phương thức mặc định ask() cho phép người dùng nhập câu hỏi bằng văn bản để LLM vừa tạo mã SQL truy vấn cơ sở dữ liệu, vừa tự động sinh mã Python (sử dụng thư viện Plotly) để trực quan hóa dữ liệu. Quá trình này sử dụng hàm exec() trong Python để chạy đoạn mã do AI tạo ra. Kẻ tấn công có thể chèn các câu lệnh độc hại	INCOPELTEE	AI cung cấp đầy đủ thông tin về cách thức kiểm tra lại với trang thông báo chính thức của lỗi và các bài báo liên quan đến lỗi. Các thôn	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông báo chính thức của lỗi và các bài báo liên quan đến lỗi. Các thôn

	(Prompt Injection) vào dữ liệu đầu vào hoặc cơ sở dữ liệu, lừa LLM sinh ra mã Python chứa mã độc thay vì mã vẽ biểu đồ thông thường. Điểm đáng chú ý: Tính năng trực quan hóa (visualize=True) được bật sẵn theo mặc định trong thư viện, tạo ra điểm yếu trực tiếp cho phép biến các cuộc tấn công tiêm nhiễm câu lệnh ngôn ngữ tự nhiên thành các hành vi thực thi mã lệnh trên máy chủ. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: Đạt mức 8.1 đến 9.2 / 10.0 (Thuộc nhóm High đến Critical — Cao đến Cực kỳ nghiêm trọng) tùy theo hệ thống đánh giá. Đặc điểm tấn công: Kẻ tấn công từ bên ngoài có thể khai thác thông qua các luồng dữ liệu đầu vào không được kiểm soát mà không cần đặc quyền phức tạp, biến lỗi logic của AI thành nguy cơ kiểm soát hệ thống. 3. Consequences (Hậu quả) Khi khai thác thành công lỗ hổng này, kẻ tấn công có thể: Thực thi mã lệnh từ xa (RCE): Chạy bất kỳ đoạn mã Python hoặc lệnh hệ điều hành nào dưới quyền hạn của tiến trình đang vận hành ứng dụng Vanna		cập p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng	g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	---	--

	(thường là quyền của máy chủ backend). Chiếm đoạt hệ thống: Đánh cắp dữ liệu nhạy cảm từ cơ sở dữ liệu, chỉnh sửa hệ thống, hoặc làm tê liệt toàn bộ hoạt động của ứng dụng tích hợp AI. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật thư viện vanna lên các phiên bản mới hơn đã được vá lỗi từ nhà phát triển (vô hiệu hóa việc thực thi trực tiếp mã không an toàn hoặc áp dụng các cơ chế kiểm duyệt đầu ra của LLM). Giải pháp phòng ngừa tạm thời: Vô hiệu hóa tham số trực quan hóa (visualize=False) trong phương thức ask() nếu không thực sự bắt buộc phải sử dụng tính năng sinh mã Plotly tự động. Triển khai các lớp lọc đầu vào/đầu ra (Guardrails) nghiêm ngặt để kiểm tra mã Python trước khi chuyển vào hàm exec(), hoặc chạy ứng dụng trong môi trường cô lập (Sandbox/Container) để giới hạn thiệt hại nếu xảy ra sự cố thực thi mã độc.		uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ư a xá c nh ận) bở i vì m ột số hạ u qu ả Ge mi ni đư a ra kh ôn g hề có	
--	---	--	--	--

			bằng chứng hay link dẫn chứng cụ thể nào.	
Artifact #49 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-5565 Severity (Mức độ nghiêm trọng) Điểm CVSS: Đạt mức 8.1 đến 9.2 / 10.0 (Thuộc nhóm High đến Critical — Cao đến Cực kỳ nghiêm trọng) tùy theo hệ thống đánh giá. Đặc điểm tấn công: Kẻ tấn công từ bên ngoài có thể khai thác thông qua các luồng dữ liệu đầu vào không được kiểm soát mà không cần đặc quyền phức tạp, biến lỗi logic của AI thành nguy cơ kiểm soát hệ thống. Consequences (Hậu quả) Khi khai thác thành công lỗ hổng này, kẻ tấn công có thể: Thực thi mã lệnh từ xa (RCE): Chạy bất kỳ đoạn mã Python hoặc lệnh hệ điều hành nào dưới quyền hạn của tiến trình đang vận hành ứng dụng Vanna (thường là quyền của máy chủ backend). Chiếm đoạt hệ thống: Đánh cắp dữ liệu nhạy cảm từ cơ sở dữ liệu, chỉnh sửa hệ thống, hoặc làm tê liệt toàn bộ hoạt động của ứng dụng tích hợp AI. Tool: ChatGPT Pro Timestamp: 21:52 PM 23/09/2026	Gemini trả lời đúng khá nhiều phần cốt lõi, nhưng có một lỗi quan trọng ở phần Solution. Đánh giá của sinh viên: AI xác định đúng CVE-2024-5565 là lỗ hổng Prompt Injection trong Vanna AI có thể dẫn đến thực thi mã Python tùy ý/RCE. AI cũng xác định đúng việc chức năng visualization liên quan đến việc thực thi code do LLM tạo ra và mức độ CVSS nằm trong khoảng 8.1–9.2 tùy phiên bản đánh giá. Tuy nhiên, AI có dấu hiệu hallucination/overstatement khi khẳng định rằng Vanna đã có “các phiên bản mới hơn đã được vá lỗi”, trong khi GitHub Advisory chưa xác định phiên bản patched cụ thể. Ngoài	V A L I D	IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử	Đọc lại những dẫn chứng, chứng cứ trong link AI đưa ra, cũng như trang lỗi chín h thức để so sánh với output rồi đưa vào báo cáo. Chỉnh sửa

	ra, các tuyên bố như attacker có thể “chiếm đoạt hệ thống”, “đánh cắp dữ liệu” hoặc “làm tê liệt toàn bộ ứng dụng” là những hậu quả có thể xảy ra sau RCE nhưng không nên trình bày như hậu quả trực tiếp đã được CVE xác nhận Một điểm nữa: Gemini viết “LLM vừa tạo mã SQL vừa tự động sinh Python” hơi khái quát. Khi đưa vào report, nên giữ trọng tâm vào LLM-generated Python code được thực thi không an toàn, vì đây là phần trực tiếp liên quan đến vulnerability. Nguồn tham khảo: https://github.com/advisories/GHSA-7735-w2jp-gvg6?utm_source=chatgpt.com		để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả n ch ất lỗi và đư a ra nh ữn g bằ ng ch ứn g cũ ng nh	và đưa vào báo cáo: AI đang ảo giác khi cho rằng Vanna đã có phiên bản mới hơn đã được vá lỗi. Trong khi hiện tại chưa xác định được có bản vá chính thức nào cả.
--	--	--	--	---

		ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ th ể chi tiế t từ ng lỗi có tr on g ou tp ut. AI đã cu ng cấ p đầ y đủ th ôn g tin cầ n thi ết.	
--	--	---	--

Artifact #50 Prompt: Hãy giải thích CVE-2024-5131 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 22:10 PM 23/09/2026	CVE-2024-5131 là một lỗ hổng bảo mật ảnh hưởng đến Lunary (lunary-ai/lunary), một nền tảng mã nguồn mở chuyên quản lý và giám sát các ứng dụng LLM/AI. 1. Description (Mô tả) Bản chất: Đây là lỗ hổng Improper Access Control / Authorization Bypass Through User-Controlled Key (Lỗi kiểm soát truy cập không đúng cách / Bỏ qua phân quyền thông qua khóa do người dùng kiểm soát), được định danh theo CWE-639. Cơ chế: Lỗ hổng tồn tại trong cách các endpoint của Lunary xử lý việc truy xuất dữ liệu prompt. Khi người dùng gửi một yêu cầu HTTP kèm theo một prompt ID cụ thể, hệ thống đã thiếu cơ chế kiểm tra quyền sở hữu (ownership validation) xem tài khoản hiện tại có thực sự thuộc về dự án chứa prompt đó hay không. Điểm đáng chú ý: Bất kỳ người dùng nào có tài khoản thông thường (thậm chí có quyền hạn thấp) đều có thể lợi dụng điểm yếu này để đọc dữ liệu chéo giữa các dự án khác nhau.	IN C O M P L E T E	AI cu ng cấ p đầ y đủ nh ữn g th ôn g tin về ea ch de fec t đủ ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang thông g báo chín thức của lỗi và các bài báo báo liên quan đến lỗi. Các thông tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
---	--	--	--	---

	2. Severity (Mức độ nghiêm trọng) Điểm CVSS: 6.5 / 10.0 (Mức Medium - Trung bình theo đánh giá chuẩn, tác động bảo mật tập trung vào tính bảo mật dữ liệu). Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng (Network Vector) với độ phức tạp thấp, không cần tương tác phức tạp từ người dùng khác ngoài việc có một tài khoản hợp lệ để gọi API hoặc truy cập endpoint bị lỗi. 3. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng có thể gây ra: Rò rỉ dữ liệu nhạy cảm (Data Exposure): Kẻ tấn công có thể xem trái phép toàn bộ các câu lệnh nhắc lệnh (prompts) của bất kỳ dự án nào khác trên hệ thống mà họ không có quyền quản lý hay tham gia. Lộ lọt thông tin chiến lược AI: Các prompt template có thể chứa logic nghiệp vụ độc quyền, system instructions quan trọng hoặc dữ liệu cấu hình ứng dụng AI của các tổ chức khác dùng chung hệ thống, gây ảnh hưởng nghiêm trọng đến tính bảo mật thông tin. 4. Solution (Giải pháp khắc phục)		ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ	
--	---	--	---	--

	Giải pháp tối ưu và triệt để nhất: Cập nhật/nâng cấp nền tảng Lunary lên phiên bản 1.2.25 hoặc các phiên bản cao hơn (nơi nhà phát triển đã vá lỗi kiểm tra quyền sở hữu đối với các endpoint prompt). Giải pháp phòng ngừa tạm thời: Hạn chế quyền truy cập mạng công khai vào các instance Lunary tự triển khai (self-hosted) nếu chưa được cập nhật bản vá. Giám sát chặt chẽ nhật ký truy cập API (Access Logs) để phát hiện các hành vi dò quét ID bất thường nhằm truy vấn dữ liệu trái phép.		B (thôn g tin ch ư a x á c nh ậ n) b ỏ i vì m ột số h ậ u q u ả Ge mi ni đư a ra kh ôn g h ề có b ả ng ch ứ n g h a y l i n k đ ẫ n ch ứ n g c ụ th ể	
--	---	--	--	--

			nà o.	
Artifact #51 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-5131 Severity (Mức độ nghiêm trọng) Điểm CVSS: 6.5 / 10.0 (Mức Medium - Trung bình theo đánh giá chuẩn, tác động bảo mật tập trung vào tính bảo mật dữ liệu). Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng (Network Vector) với độ phức tạp thấp, không cần tương tác phức tạp từ người dùng khác ngoài việc có một tài khoản hợp lệ để gọi API hoặc truy cập endpoint bị lỗi. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng có thể gây ra: Rò rỉ dữ liệu nhạy cảm (Data Exposure): Kẻ tấn công có thể xem trái phép toàn bộ các câu lệnh nhắc lệnh (prompts) của bất kỳ dự án nào khác trên hệ thống mà họ không có quyền quản lý hay tham gia. Lộ lọt thông tin chiến lược AI: Các prompt template có thể chứa logic nghiệp vụ độc quyền, system instructions quan trọng hoặc dữ liệu cấu hình ứng dụng AI của các tổ chức khác dùng chung hệ thống, gây ảnh hưởng nghiêm trọng đến tính bảo mật thông tin. - Tool: ChatGPT Pro - Timestamp: 22:15 PM 23/09/2026	Gemini lần này trả lời khá chính xác. Điểm cần sửa chủ yếu nằm ở việc nó mô tả mức độ dữ liệu có thể bị lộ rộng hơn so với nội dung CVE xác nhận. Đánh giá của sinh viên: AI xác định đúng CVE-2024-5131 là lỗi Improper Access Control/Authorization Bypass trong Lunar, thuộc CWE-639, và mô tả đúng việc người dùng có thể sử dụng prompt ID để truy cập prompt thuộc project khác. AI cũng xác định đúng phiên bản bị ảnh hưởng và phiên bản đã sửa là 1.2.25. Tuy nhiên, AI có dấu hiệu overstatement khi khẳng định attacker có thể xem “toàn bộ các prompt của bất kỳ dự án nào” và các prompt chắc chắn chứa system instructions, logic nghiệp vụ hoặc dữ liệu nhạy cảm. Nguồn CVE xác nhận việc truy cập trái phép prompt của project khác, nhưng không đảm bảo mọi prompt đều chứa những loại thông tin trên. Ngoài ra, AI không đề cập sự khác biệt giữa các đánh giá CVSS từ các nguồn khác nhau. Nguồn tham khảo:	V A LI D	IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó ,	Đọc lại những dẫn chứng, chú ý trong link AI đưa ra, cũng như trang lỗi chín h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI đang mở rộng hậu quả vì chưa chắc prom pt

	https://nvd.nist.gov/vuln/detail/CVE-2024-5131?utm_source=chatgpt.com	tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả n ch ất lỗi và đư a ra nh ữn g bả ng ch ứn g cũ ng nh ư lin k rõ rà ng mi nh bạ ch. AI giả i thí ch cụ	nào cũng chứa các logic nghiệ p vụ hoặc dữ liệu nhạy cảm.
--	---	--	--

			thể chi tiết từ ngữ lỗi có trong output. AI đã cung cấp đầy đủ thông tin cần thiết.	
Artifact #52 Prompt: Hãy giải thích CVE-2024-8309 bao gồm description, severity, consequences, solution. Tool: Geimini Timestamp: 22:24 PM 23/09/2026	CVE-2024-8309 thực tế là một lỗ hổng bảo mật liên quan đến khung phát triển ứng dụng AI LangChain (cụ thể là gói langchain-community). Dưới đây là thông tin chính xác về CVE-2024-8309: 1. Description (Mô tả) Bản chất: Đây là lỗ hổng SQL Injection (hoặc Cypher Injection) thông qua Prompt Injection.	INCOМПLЕТЕ	AI cung cấp đầy đủ những thông tin về ea	Dựa vào các thông tin AI cung cấp phải tìm kiếm và kiểm tra lại với trang

	Cơ chế: Lỗ hổng xuất hiện trong thành phần GraphCypherQChain của LangChain (dùng để kết nối LLM với các cơ sở dữ liệu đồ thị như Neo4j). Do thiếu cơ chế kiểm soát đầu vào và lọc dữ liệu đầu ra từ mô hình, kẻ tấn công có thể chèn các câu lệnh nhắc lệnh độc hại (Prompt Injection) vào luồng chat. LLM sẽ bị lừa tạo ra các câu lệnh truy vấn cơ sở dữ liệu (ví dụ: Cypher queries) mang tính phá hoại hoặc độc hại, và hệ thống sẽ thực thi trực tiếp các câu lệnh này ở backend mà không qua kiểm duyệt. 2. Severity (Mức độ nghiêm trọng) Điểm CVSS: Lên tới 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng thông qua giao diện ứng dụng AI mà không cần có đặc quyền hay xác thực từ trước. 3. Consequences (Hậu quả) Khi bị khai thác thành công, lỗ hổng có thể dẫn đến: Thao túng hoặc xóa dữ liệu (Data Deletion/Manipulation): Kẻ tấn công có thể ép LLM tạo ra các câu lệnh xóa toàn bộ các node, mối quan hệ hoặc dữ liệu trong cơ sở dữ liệu (gây từ chối dịch vụ - DoS).		ch de fec t đú ng vớ i pr o m pt. IS TQ B đề cậ p đế n việ c lự a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ủ đề cải thi ện hi ệu qu	thôn g báo chín h thức của lỗi và các bài báo liên quan đến lỗi. Các thôn g tin chưa được xác thực cần được loại bỏ khỏi báo cáo.
--	---	--	---	--

	Trích xuất dữ liệu trái phép (Data Exfiltration): Đọc lên các thông tin nhạy cảm lưu trữ trong cơ sở dữ liệu thông qua các truy vấn chéo. Vi phạm bảo mật đa đối tượng (Multi-tenant Breaches): Cho phép truy cập trái phép vào dữ liệu của các tenant/người dùng khác trong cùng một hệ thống kết nối. 4. Solution (Giải pháp khắc phục) Giải pháp tối ưu và triệt để nhất: Cập nhật thư viện langchain-community lên phiên bản 0.2.19, 0.3.0 hoặc các phiên bản mới hơn. Lưu ý về bản vá: Từ phiên bản vá lỗi, LangChain đã bổ sung tham số bắt buộc <code>allow_dangerous_requests=True</code> khi khởi tạo <code>GraphCypherQAChain</code> nhằm buộc các nhà phát triển phải ý thức rõ rủi ro khi cho phép LLM tự động sinh câu lệnh chạy trực tiếp xuống cơ sở dữ liệu. Giải pháp phòng ngừa: Thực hiện kiểm tra, xác thực và làm sạch nghiêm ngặt mọi dữ liệu đầu vào từ người dùng cũng như các câu lệnh do LLM sinh ra trước khi truyền xuống tầng cơ sở dữ liệu thực thi.		ả và hi ệu su ất. Tu y nh iê n vi ph ạ m ng uy ên tắc tes t ba sis và tra ce ab ilit y củ a IS TQ B (th ôn g tin ch ưa xá c nh ận) bở i vì m ột	
--	--	--	--	--

			số hạ u qu ả Ge mi ni đư a ra kh ôn g hề có bằ ng ch ứn g hà y lin k đấ n ch ứn g cụ th ể nà o.	
Artifact #53 Prompt: Tìm một lỗi được coi là ảo giác AI trong đoạn này với lỗi CVE-2024-8309 Severity (Mức độ nghiêm trọng) Điểm CVSS: Lên tới 9.8 / 10.0 (Mức Critical - Cực kỳ nghiêm trọng). Đặc điểm tấn công: Kẻ tấn công có thể khai thác từ xa qua mạng thông qua giao diện ứng dụng AI mà không cần có đặc quyền hay xác thực từ trước. Consequences (Hậu quả)	Gemini lần này trả lời khá chính xác. Điểm cần sửa chủ yếu nằm ở việc nó mô tả mức độ dữ liệu có thể bị lộ rộng hơn so với nội dung CVE xác nhận. Đánh giá của sinh viên: AI xác định đúng CVE-2024-5131 là lỗi Improper Access Control/Authorization Bypass trong Lunary, thuộc CWE-639, và mô tả đúng việc người	V A LI D	IS TQ B đề cậ p để n việ c lự a ch on và	Đọc lại những g dẫn chứn g, chứn g cứ trong link AI đưa ra, cũng như

Khi bị khai thác thành công, lỗ hổng có thể dẫn đến: Thao túng hoặc xóa dữ liệu (Data Deletion/Manipulation): Kẻ tấn công có thể ép LLM tạo ra các câu lệnh xóa toàn bộ các node, mối quan hệ hoặc dữ liệu trong cơ sở dữ liệu (gây từ chối dịch vụ - DoS). Trích xuất dữ liệu trái phép (Data Exfiltration): Đọc lên các thông tin nhạy cảm lưu trữ trong cơ sở dữ liệu thông qua các truy vấn chéo. Vi phạm bảo mật đa đối tượng (Multi-tenant Breaches): Cho phép truy cập trái phép vào dữ liệu của các tenant/người dùng khác trong cùng một hệ thống kết nối. - Tool: ChatGPT Pro - Timestamp: 22:27 PM 23/09/2026	dùng có thể sử dụng prompt ID để truy cập prompt thuộc project khác. AI cũng xác định đúng phiên bản bị ảnh hưởng và phiên bản đã sửa là 1.2.25. Tuy nhiên, AI có dấu hiệu overstatement khi khẳng định attacker có thể xem “toàn bộ các prompt của bất kỳ dự án nào” và các prompt chắc chắn chứa system instructions, logic nghiệp vụ hoặc dữ liệu nhạy cảm. Nguồn CVE xác nhận việc truy cập trái phép prompt của project khác, nhưng không đảm bảo mọi prompt đều chứa những loại thông tin trên. Ngoài ra, AI không đề cập sự khác biệt giữa các đánh giá CVSS từ các nguồn khác nhau. Nguồn tham khảo: https://nvd.nist.gov/vuln/detail/cve-2024-8309 https://github.com/advisories/GHSA-45pg-36p6-83v9	sử dụng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. Do đó , tôi nh ờ tr ợ gi úp AI xá c đị nh đú ng bả n ch ất	trang lỗi chín h thức để so sánh với outp ut rồi đưa vào báo cáo. Chín h sửa và đưa vào báo cáo: AI khẳng định bản vá bổ sung tham số allow _dan gero us_re quest s=True, nhưn g thôn g tin này khôn g đượ c thể hi ện trong mô tả
--	--	--	--

		lỗi và đưa ra những bằng chứng rất cũ nhưng vẫn linh hoạt rõ ràng minh bạch. AI giả lập thí nghiệm để chi tiết từng lỗi có trong output. AI đã cu	CVE/ GitH ub Advi sory. Điều này chưa được xác thực nên rất có thể AI đã đưa thôn g tin sai lệch.
--	--	--	--

			ng cấ p đầ y đủ th ôn g tín cầ n thi ết.	
Artifact #54 Prompt: Quạt bàn Senko B1216 công suất 40W Design 15 test cases (Objective / Input / Steps / Expected / Actual / Verdict). Clarification: 15 test cases total. Execute and record videos for ≥ 5 out of the 15 (not all 15 need videos). Also aim to find ≥ 5 defects from the device during execution. Liệt kê từng TC Tool: ChatGPT Pro Timestamp: 22:40 PM 23/09/2026	Lưu ý: vì bạn chưa thực hiện kiểm thử thực tế nên phần Actual và Verdict nên điền sau khi test, không nên tự bịa kết quả. Mình đánh dấu ★ cho 5 test case nên quay video. Test Case 1 – Bật quạt Objective: Kiểm tra quạt có bật và hoạt động bình thường hay không. Input: Quạt đang được kết nối với nguồn điện; quạt đang tắt. Steps: Cắm điện cho quạt. Nhấn nút nguồn. Quan sát quạt. Expected: Quạt bật, cánh quạt bắt đầu quay và không có âm thanh bất thường. Actual: Điền kết quả thực tế sau khi kiểm thử. Verdict: PASS / FAIL ★ Nên quay video. Test Case 2 – Tắt quạt Objective: Kiểm tra chức năng tắt quạt.	V A LI D	AI cu đã lấy 12 TC trong đó loại bỏ đi 3 TC là 11, 12, 13 để thay thế 3 Edge case. Ngoà i ra do quạt tôi khôn g có nút nguồn bật quạt nên được thay thế bằng cách chọn	Tôi đã lấy 12 TC trong đó loại bỏ đi 3 TC là 11, 12, 13 để thay thế 3 Edge case. Ngoà i ra do quạt tôi khôn g có nút nguồn bật quạt nên được thay thế bằng cách chọn

	Input: Quạt đang hoạt động. Steps: Nhấn nút tắt nguồn. Quan sát cánh quạt. Expected: Quạt ngừng hoạt động hoàn toàn. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Test Case 3 – Kiểm tra các mức tốc độ ★ Objective: Kiểm tra quạt có thay đổi tốc độ theo từng mức hay không. Input: Quạt đang tắt. Steps: Bật quạt. Chọn mức tốc độ thấp. Quan sát tốc độ quay. Chuyển sang mức tốc độ cao hơn. Tiếp tục chuyển qua các mức tốc độ còn lại. Expected: Tốc độ quay thay đổi tương ứng với từng mức được chọn. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL ★ Nên quay video. Test Case 4 – Kiểm tra chế độ quay trái/phải (Oscillation) ★ Objective: Kiểm tra khả năng tự động quay trái và phải của quạt. Input: Quạt đang hoạt động. Steps: Bật quạt. Kích hoạt chức năng quay. Quan sát hướng chuyển động của đầu quạt.	a ch on và sử dụ ng cá c cô ng cụ hỗ tr ợ ki ể m th ử để cải thi ện hi ệu qu ả và hi ệu su ất. AI đá p ứn g đú ng yê u cầ u về độ chí nh xá c	nút mức tốc độ bất kì
--	--	--	--

	Expected: Đầu quạt tự động quay từ trái sang phải và ngược lại. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL ★ Nên quay video. Test Case 5 – Tắt chế độ quay Objective: Kiểm tra quạt có dừng quay khi tắt chức năng oscillation hay không. Input: Quạt đang hoạt động và đang quay trái/phải. Steps: Bật chức năng quay. Chờ quạt bắt đầu quay. Tắt chức năng quay. Quan sát đầu quạt. Expected: Đầu quạt dừng quay và giữ nguyên hướng hiện tại. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Test Case 6 – Điều chỉnh góc nghiêng đầu quạt Objective: Kiểm tra khả năng điều chỉnh góc lên/xuống. Input: Quạt đang tắt. Steps: Giữ phần đầu quạt. Điều chỉnh đầu quạt lên. Điều chỉnh đầu quạt xuống. Kiểm tra độ chắc chắn sau khi điều chỉnh. Expected: Đầu quạt có thể điều chỉnh lên/xuống và giữ được vị trí đã chọn.		và tín h đầ y đủ củ a IS TQ B	
--	--	--	---	--

	Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Test Case 7 – Kiểm tra độ ổn định của chân đế ★ Objective: Kiểm tra quạt có đứng vững trong quá trình hoạt động hay không. Input: Quạt được đặt trên mặt phẳng. Steps: Đặt quạt trên mặt phẳng. Bật quạt ở tốc độ thấp. Tăng lên tốc độ cao. Quan sát chân đế và thân quạt. Expected: Quạt đứng vững, không bị nghiêng, trượt hoặc rung lắc bất thường. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL ★ Nên quay video. Test Case 8 – Kiểm tra tiếng ồn ★ Objective: Kiểm tra quạt có phát ra tiếng ồn bất thường khi hoạt động hay không. Input: Quạt hoạt động ở các mức tốc độ khác nhau. Steps: Bật quạt. Kiểm tra ở tốc độ thấp. Kiểm tra ở tốc độ trung bình. Kiểm tra ở tốc độ cao. Lắng nghe âm thanh phát ra. Expected: Quạt hoạt động với âm thanh ở mức bình thường,			
--	--	--	--	--

	không xuất hiện tiếng kêu, rè hoặc va chạm bất thường. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL ★ Nên quay video. Test Case 9 – Kiểm tra lồng quạt Objective: Kiểm tra lồng quạt có được cố định chắc chắn hay không. Input: Quạt đang tắt. Steps: Kiểm tra lồng phía trước và phía sau. Dùng tay kiểm tra nhẹ độ chắc chắn. Quan sát các vị trí cố định của lồng. Expected: Lồng quạt được gắn chắc chắn, không bị lỏng hoặc rung bất thường. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Test Case 10 – Kiểm tra cánh quạt Objective: Kiểm tra cánh quạt có hoạt động bình thường hay không. Input: Quạt đang tắt. Steps: Kiểm tra trực quan các cánh quạt. Bật quạt. Quan sát chuyển động của cánh quạt ở các mức tốc độ. Expected: Cánh quạt không bị nứt, gãy; quay đều và không va chạm vào lồng.			
--	---	--	--	--

	Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Test Case 11 – Kiểm tra dây nguồn Objective: Kiểm tra dây nguồn có đảm bảo an toàn và hoạt động ổn định. Input: Quạt và dây nguồn. Steps: Kiểm tra trực quan toàn bộ dây nguồn. Cắm điện. Bật quạt. Quan sát xem quạt có bị ngắt điện bất thường hay không. Expected: Dây nguồn không bị hở, đứt hoặc hư hỏng; quạt nhận điện ổn định. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Test Case 12 – Kiểm tra nút điều khiển Objective: Kiểm tra các nút điều khiển có hoạt động đúng chức năng hay không. Input: Quạt đang được kết nối với nguồn điện. Steps: Nhấn từng nút điều khiển. Quan sát phản hồi của quạt. Kiểm tra nhiều lần với từng nút. Expected: Mỗi nút thực hiện đúng chức năng tương ứng và không bị kẹt. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL			
--	---	--	--	--

	Test Case 13 – Bật/tắt quạt liên tục Objective: Kiểm tra quạt có hoạt động ổn định khi thực hiện nhiều lần bật/tắt. Input: Quạt được kết nối với nguồn điện. Steps: Bật quạt. Chờ quạt hoạt động. Tắt quạt. Lặp lại thao tác bật/tắt khoảng 5 lần. Quan sát hoạt động của quạt. Expected: Quạt bật và tắt chính xác trong tất cả các lần thử, không bị treo hoặc mất chức năng. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Test Case 14 – Kiểm tra hoạt động liên tục ★ Objective: Kiểm tra quạt có duy trì hoạt động ổn định trong thời gian dài hay không. Input: Quạt được bật ở một mức tốc độ cố định. Steps: Bật quạt. Chọn một mức tốc độ. Để quạt hoạt động liên tục trong một khoảng thời gian. Quan sát tiếng ồn, tốc độ quay và độ rung. Kiểm tra lại sau thời gian thử. Expected: Quạt tiếp tục hoạt động ổn định,			
--	---	--	--	--

	không tự tắt, không xuất hiện tiếng động hoặc rung bất thường. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL ★ Nên quay video. Test Case 15 – Kiểm tra hoạt động khi thay đổi tốc độ và hướng quay Objective: Kiểm tra quạt có hoạt động ổn định khi người dùng thay đổi nhiều chức năng liên tiếp. Input: Quạt đang hoạt động. Steps: Bật quạt. Chọn tốc độ thấp. Bật chế độ quay trái/phải. Chuyển sang tốc độ cao. Tắt chế độ quay. Điều chỉnh góc quạt. Chuyển lại tốc độ thấp. Tắt quạt. Expected: Quạt thực hiện đúng từng thao tác, không bị dừng đột ngột, kẹt, rung mạnh hoặc phát ra âm thanh bất thường. Actual: Điền kết quả thực tế. Verdict: PASS / FAIL Tổng hợp 15 test case <table><tr><th>TC</th><th>Nội dung</th><th>Video</th></tr></table>	TC	Nội dung	Video			
TC	Nội dung	Video					

		kiểm thử			
	TC0 1	Bật quạt	★		
	TC0 2	Tắt quạt			
	TC0 3	Các mức tốc độ	★		
	TC0 4	Quay trái/ph ải	★		
	TC0 5	Tắt chế độ quay			
	TC0 6	Điều chỉnh góc nghiên g			
	TC0 7	Độ ổn định chân đế	★		
	TC0 8	Tiếng ồn	★		
	TC0 9	Lồng quạt			
	TC1 0	Cánh quạt			
	TC1 1	Dây nguồn			
	TC1 2	Nút điều khiển			

	TC1 3	Bật/tắt liên tục			
	TC1 4	Hoạt động liên tục	★		
	TC1 5	Kết hợp nhiều chức năng			
Như vậy có 15 test case, trong đó có 7 test case được đề xuất quay video, đáp ứng yêu cầu tối thiểu ≥ 5 video. Đối với yêu cầu “aim to find ≥ 5 defects”, không nên cố tình ghi 5 lỗi nếu thực tế thiết bị không có. Khi bạn thực hiện test, nếu phát hiện ví dụ nút bị kẹt, quạt rung mạnh, tiếng ồn bất thường, chế độ quay không hoạt động, tốc độ không thay đổi... thì ghi chúng vào Actual + Verdict = FAIL và lập thêm danh sách defect riêng.					

Artifact #55

Prompt: AI Tool draws a QA/QC role mindmap
Tool: ChatGPT Pro
Timestamp: 14:34 PM 24/09/2026



IN V A LI D

AI đã vẽ sai yêu cầu của prompt. AI không chỉ ra role của QA/QC. Ngoài ra, không phân loại kỹ để mô tả rõ ràng.

Đọc và kiểm tra lại lỗi sai. Sau đó, Chỉ ra những lỗi sai của AI để AI vẽ lại

			nh iề u cấ p độ . Vi ph ạ m tín h chí nh xá c củ a IS TQ B.	
Artifact #56 Prompt: AI đang không phân biệt rõ 2 role, những nhiệm vụ như ghi nhận và theo dõi bug ,test plan,.... chủ yếu là hoạt động của QC nhưng nó là ở bên nhánh nhiệm vụ chính QA. AI đang trộn cả 2 vai trò thành 1. Phân Loại hình kiểm thử đang bị trộn lẫn nhiều cấp độ như: Functional và Non-functional là test type Regression là mục đích kiểm thử Integration là test level UAT thường được thực hiện ở mức acceptance nhưng nó lại bị xếp như 1 loại testing ngang với Functional Testing. - Tool: ChatGPT Pro - Timestamp: 14:40 PM 24/09/2026		V A L I D	AI đã sử dụng lại đúng yêu cầu tôi đã đưa ra. Đảm bảo độ chính xác theo yêu	Đọc và kiểm tra lại toàn bộ nhánh mà AI tạo ra.

			u cầ u củ a pr o m pt.	
Artifact #57 - Prompt: "[Test cases / script / dataset / report] was initially generated by [AI tool name]; I reviewed and modified [section X], added [edge cases Y, Z]; [section W] was written entirely by me. The detailed AI Audit Report is attached as Appendix A. I confirm I did not use AI to generate any artifact listed in the prohibited category below." Điền template này đúng với những gì tôi prompt hỏi - Tool: ChatGPT Pro - Timestamp: 13:04 PM 25/09/2026	Với bài HW01 của bạn, không nên giữ nguyên placeholder [AI tool name], [section X]... mà thay bằng đúng những gì bạn thực sự đã làm. Bạn có thể điền như sau: The QA/QC job market analysis, software defect analysis, initial test cases, and QA/QC role mindmap were initially generated with the assistance of ChatGPT and Gemini. I reviewed and modified the AI-generated content, including correcting unsupported or hallucinated information in the software defect analysis, verifying job-posting information against the original sources, and revising the initial TC01-TC15 test cases and QA/QC mindmap. The physical-device test execution results, actual observations, defect reports,	V A LI D	AI đã hỗ trợ khám phá đầy đủ và chính xác những vấn đề tồn tại trong QA/QC job market analysis, software are defect analysis, detecting AI hallucinations , searching for	Đọc và thêm 1 số ý nhỏ còn thiếu mà AI đã bỏ qua. Tôi đã highlight lại: The QA/QC job market analysis, software are defect analysis, detecting AI hallucinations , searching for

	GitHub Issues, Prompt Log, AI Critique, and this Mandatory Disclosure were written and completed by me. I confirm I did not use AI to generate any artifact listed in the prohibited category below. Nếu muốn bám sát hơn với thực tế bạn đã làm, tôi khuyên dùng bản này: The QA/QC job market analysis, software defect analysis, initial TC01-TC15 test cases, and QA/QC role mindmap were initially generated with the assistance of ChatGPT and Gemini. I reviewed and modified these outputs by verifying information against original sources, correcting incomplete or hallucinated information, revising test cases, and correcting mistakes in the mindmap. The actual physical-device test execution, test results, defect observations, GitHub Issues, Prompt Log, AI Critique, and final verification were completed by me. I confirm I did not use		TQ B.	softw are evid ence, TC01 – TC15 test cases, and QA/ QC role mind map, Com plete mand atory discl osure were initial ly gener ated with the assist ance of Chat GPT and Gemi ni. I revie wed and modi fied these outpu ts by verif ying infor matio n again st
--	--	--	----------	--

	AI to generate any artifact listed in the prohibited category below. Nhưng có một chỗ rất quan trọng Template gốc viết: “The detailed AI Audit Report is attached as Appendix A.” Trong HW01 của bạn, Appendix A được quy định là prompt_log.md, còn AI-02 là AI Audit Report. Vì vậy đừng tự sửa câu template thành “AI Audit Report is attached as Appendix A” nếu bạn muốn bám đúng Submission Regulations. Bạn có thể giữ nguyên template nếu giảng viên yêu cầu paste verbatim, nhưng về cấu trúc bài của bạn: • AI-02 = AI Audit Report. • Appendix A = prompt_log.md. • AI-03 = AI Use Disclosure Form. • AI-05 = Privacy & Responsible AI Checklist.		original sources, correcting incomplete or hallucinated information, revising test cases, and correcting mistakes in the mind map. The actual physical-device test execution, test results, defect observations, GitHub Issues, Prompt Log,
--	--	--	---

	Ngoài ra, câu cuối “I confirm I did not use AI to generate any artifact listed in the prohibited category” chỉ nên giữ nếu đúng với thực tế của bạn. Đề của bạn cấm AI tạo một số evidence như device photo + student ID, execution videos có voice của bạn, job screenshots có username, và prompt log. Với những gì bạn đã làm, câu cuối này phù hợp vì các phần đó bạn tự thực hiện.			AI Critique, Test Summary Report, Checklists and final verification were completed by me. I confirm I did not use AI to generate any artifact listed in the prohibited category below.

V. AI Critique

Khi thực hiện bài tập HW#01, AI đã hỗ trợ tôi rất nhiều trong việc tạo test case kiểm thử thiết bị, tìm kiếm thông tin, gợi ý ý tưởng, cách trình bày đánh giá. Ngoài ra, AI còn giúp tôi trong việc phân tích lỗi sai, tìm và đưa ra dẫn chứng cụ thể trên các trang web,... Nhưng AI vẫn mắc một số lỗi về độ chính xác và cung cấp không đủ thông tin cho người dùng. Điển hình là ở requirement 2 về phần ảo giác AI. Ví dụ: 12. CVE-2024-21410 AI đã cho rằng attacker có thể trực tiếp đạt quyền Administrator, thực hiện RCE, truy cập hộp thư và kiểm soát Active Directory, đây là những thông tin chưa được trang chính thức về lỗi xác nhận, đó đều là dự đoán có thể xảy ra do AI suy nghĩ. Ngoài ra, còn một số bài post tìm kiếm QA/QC ở requirement 1, AI đã đưa những bài đăng không đầy đủ thông tin như lương trong khi đã prompt đầy đủ thông tin cần thiết. Và ở requirement 3, tôi thấy AI thiếu trải nghiệm thực tế khi không thể tìm ra những Edge Case. Những Edge Case là trải nghiệm của người dùng, trong khi AI chỉ tập trung vào những TC về chức năng cơ bản. Tôi đã học được là mình chỉ nên xem AI là một công cụ hỗ trợ đắc lực, dù mình hiểu và prompt đúng nhưng vẫn sẽ có lúc AI trả lời thiếu và chưa đúng kết quả. Do đó, chúng ta vẫn là người kiểm tra, đọc lại dữ liệu và chốt lại kết quả cuối cùng.

VI. Mandatory Disclosure

The QA/QC job market analysis, software defect analysis, detecting AI hallucinations, searching for software evidence, TC01–TC15 test cases, and QA/QC role mindmap, Complete mandatory disclosure were initially generated with the assistance of ChatGPT and Gemini. I reviewed and modified these outputs by verifying information against original sources, correcting incomplete or hallucinated information, revising test cases, and correcting mistakes in the mindmap. The actual physical-device test execution, test results, defect observations, GitHub Issues, Prompt Log, AI Critique, Test Summary Report, Checklists and final verification were completed by me. I confirm I did not use AI to generate any artifact listed in the prohibited category below.

